

O-RAN Work Group 11 (Security Work Group)

Security Requirements and Controls Specifications

Copyright © 2025 by the O-RAN ALLIANCE e.V.

The copying or incorporation into any other work of part or all of the material available in this specification in any form without the prior written permission of O-RAN ALLIANCE e.V. is prohibited, save that you may print or download extracts of the material of this specification for your personal use, or copy the material of this specification for the purpose of sending to individual third parties for their information provided that you acknowledge O-RAN ALLIANCE as the source of the material and that you inform the third party that these conditions apply to them and that they must comply with them.

O-RAN ALLIANCE e.V., Buschkauler Weg 27, 53347 Alfter, Germany
Register of Associations, Bonn VR 11238, VAT ID DE321720189

Contents

Foreword	4
Modal verbs terminology	4
1 Scope	5
2 References	5
2.1 Normative references	5
2.2 Informative references	8
3 Definition of terms, symbols and abbreviations	10
3.1 Terms	10
3.2 Symbols	14
3.3 Abbreviations	15
4 Objectives and scope	16
4.1 Objectives	16
4.2 Perimeter	17
4.2.1 Void	18
4.2.2 Void	18
4.2.3 Void	18
5 Security Requirements and Controls	18
5.0 Introduction	18
5.1 O-RAN Architecture Elements	18
5.1.1 Service Management and Orchestration (SMO)	18
5.1.2 Non-RT RIC and rApps	24
5.1.3 Near-RT RIC and xApps	25
5.1.4 O-CU-CP/UP	31
5.1.5 O-DU	31
5.1.6 O-RU	31
5.1.7 O-eNB	32
5.1.8 O-Cloud	32
5.1.9 Shared O-RU	43
5.2 Interfaces maintained by O-RAN	44
5.2.1 A1 Interface	44
5.2.2 O1 Interface	45
5.2.3 O2 Interface	47
5.2.4 E2 Interface	47
5.2.5 Open Fronthaul Interface	48
5.2.6 R1 Interface	61
5.2.7 Y1 Interface	62
5.3 Transversal requirements	63
5.3.1 Software Bill of Materials	63
5.3.2 Application Lifecycle Management Security	63
5.3.3 Network Protocols and Services	67
5.3.4 Robustness of Common Protocols	67
5.3.5 Robustness against Volumetric DDoS Attack	68
5.3.6 Robustness of O-RAN architecture element software	68
5.3.7 Password-Based Authentication	68
5.3.8 Security Log Management	69
5.3.9 Certificate Management Framework	78
5.3.10 Application Programming Interfaces (APIs)	80
5.3.11 Trust Anchor Provisioning	81
5.3.12 AI/ML Security	82
6 SBOM Guidelines for O-RAN	85
6.1 SBOM Overview	85
6.2 85	

6.3	SBOM Requirements for O-RAN	85
6.3.1	Requirements	85
6.3.2	Security Controls	86
Annex A (informative): Security Principles mapping to Security Requirements		86
Annex B (informative): Security: List of 3GPP security requirements		88
Annex C (informative): Guidance on Security Requirements & Controls		108
Annex D (informative): Mapping of Threats to Requirements and Requirements to Controls		116
Annex E (informative): Summary of O-RAN Security Controls		150
Annex F (informative): Change history		152

List of Tables

Table 5-1: Summary of the Security Controls for Near-RT RIC APIs	27
Table 5.2.2.3-1: Default values of the NACM Global Enforcement	46
Table 5.2.5.4.3-1: Default values of the NACM Global Enforcement	53
Table 5.3.8.11.1-1: Types of Security Events by O-RAN Component	73
Table A-1: Security Principles mapping to Security Requirements defined in [i.14].	86
Table B-1: References for 3GPP Security requirements	88
Table B-2: 3GPP Security requirements	89
Table C.3.1-1: Certificate enrolment for NF Deployment	113
Table D-1: Mapping of Threats defined in [i.14] to Security Requirements	117
Table D-2: Map between Security Requirements and Security Controls	130
Table E-1. Summary of O-RAN Security Controls	150

List of Figures

Figure 4-1: Logical Architecture of O-RAN system [2]	17
Figure 5.1.1.2.2-1: mTLS or TLS for SMOS Communication	21
Figure 5.1.1.2.3-1: mTLS with SMO External Consumers and Producers	22
Figure 5.1.2.2-1: TLS for Kafka-based protocol	25
Figure 5.1.3.2-1: UML code of security procedure for xApp registration	29
Figure 5.1.3.2-2: Security procedure for xApp registration	29
Figure 5.2.1.2-1: mTLS on A1 interface	44
Figure 5.2.5.5.3.2-1: UML code of 802.1X Port Based Authentication in the O-RAN Fronthaul architecture	56
Figure 5.2.5.5.3.2-2: Operation of 802.1X Port Based Authentication in the O-RAN Fronthaul architecture	57
Figure 5.2.5.6.2-1: End-to-End MACsec solution for Fronthaul security protection	59
Figure 5.2.6.2-1: mTLS on R1 interface	62
Figure 5.3.12.2-1: EXAMPLE of a deep neural network AI/ML model split across five inference	83
Figure C.1.2-1: Example of Remote AS	110
Figure C.3.1-1: UML Code of certificate enrolment for NF Deployment	114
Figure C.3.1-2: Certificate enrolment for NF Deployment	115

Foreword

This Technical Specification (TS) has been produced by O-RAN ALLIANCE.

The content of the present document is subject to continuing work within O-RAN and may change following formal O-RAN approval. Should the O-RAN ALLIANCE modify the contents of the present document, it will be re-released by O-RAN with an identifying change of version date and an increase in version number as follows:

version xx.yy.zz

where:

xx: the first digit-group is incremented for all changes of substance, i.e. technical enhancements, corrections, updates, etc. (the initial approved document will have xx=01). Always 2 digits with leading zero if needed.

yy: the second digit-group is incremented when editorial only changes have been incorporated in the document. Always 2 digits with leading zero if needed.

zz: the third digit-group included only in working versions of the document indicating incremental changes during the editing process. External versions never include the third digit-group. Always 2 digits with leading zero if needed.

Modal verbs terminology

In the present document "**shall**", "**shall not**", "**should**", "**should not**", "**may**", "**need not**", "**will**", "**will not**", "**can**" and "**cannot**" are to be interpreted as described in clause 3.2 of the O-RAN Drafting Rules (Verbal forms for the expression of provisions).

"**must**" and "**must not**" are **NOT** allowed in O-RAN deliverables except when used in direct citation.

1 Scope

The present document provides security specifications for vendor support in each O-RAN interface and O-RAN architecture element.

Operator use of the specified security controls is not covered by this document.

The following interfaces are not covered by this document:

- E1
- F1-c
- F1-u
- NG-c
- NG-u
- X2-c
- X2-u
- Xn-c
- Xn-u
- Uu

2 References

2.1 Normative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies. In the case of a reference to a 3GPP document, a non-specific reference implicitly refers to the latest version of that document in Release 18, or the latest 3GPP release prior to Release 18 that includes that document.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, O-RAN cannot guarantee their long-term validity.

The following referenced documents are necessary for the application of the present document.

- | | |
|------|---|
| [1] | 3GPP TR 21.905: "Vocabulary for 3GPP Specifications" |
| [2] | O-RAN ALLIANCE TS: "O-RAN Architecture Description" |
| [3] | O-RAN ALLIANCE TS: "O-RAN Security Protocols Specifications" |
| [4] | Void |
| [5] | O-RAN ALLIANCE TS: "O-RAN A1 interface: Transport Protocol" |
| [6] | O-RAN ALLIANCE TS: "O-RAN O2 General Aspects and Principles" |
| [7] | O-RAN ALLIANCE TS: "O-RAN Near-Real-time RAN Intelligent Controller Architecture & E2 General Aspects and Principles" |
| [8] | O-RAN ALLIANCE TS: "Cloud Platform Reference Designs" |
| [9] | IETF RFC 6241: "Network Configuration Protocol (NETCONF)" |
| [10] | IETF RFC 8341: "Network Configuration Access Control Model" |

- [11] IETF RFC 4513: "Lightweight Directory Access Protocol (LDAP): Authentication Methods and Security Mechanisms"
- [12] IEEE Std 802.1X-2020: "IEEE Standard for Local and Metropolitan Area Networks--Port-Based Network Access Control" (Revision of IEEE Std 802.1X-2010 Incorporating IEEE Std 802.1Xbx-2014 and IEEE Std 802.1Xck-2018), vol., no., pp.1-289, 28 Feb. 2020, doi: 10.1109/IEEESTD.2020.9018454
- [13] O-RAN ALLIANCE TS: "O-RAN Control, User and Synchronization Plane Specification"
- [14] O-RAN ALLIANCE TS: "O-RAN Management Plane Specification"
- [15] O-RAN ALLIANCE TS: "O-RAN Deployment Scenarios and Base Station Classes"
- [16] O-RAN ALLIANCE TS: "O-RAN Operations and Maintenance Architecture"
- [17] "The Minimum Elements for a Software Bill of Materials (SBOM), Pursuant to Executive Order 14028 on Improving the Nation's Cybersecurity", U.S. DoC and NTIA, July 2021"
- [18] SPDX, <https://spdx.dev/>
- [19] CycloneDX, <https://cyclonedx.org/>
- [20] NISTIR 8060: "Guidelines for the Creation of Interoperable Software Identification (SWID) Tags, David Waltermire et al., U.S. NIST, 2016, <http://dx.doi.org/10.6028/NIST.IR.8060>
- [21] ISO/IEC 5962:2021 - "Information technology — SPDX® Specification", V2.2.1, August 2021
- [22] IETF RFC 2865: "Remote Authentication Dial In User Service (RADIUS)"
- [23] IETF RFC 2866: "RADIUS accounting"
- [24] IETF RFC 2869: "RADIUS Extensions"
- [25] IETF RFC 4072: "Diameter Extensible Authentication Protocol (EAP) Application"
- [26] O-RAN ALLIANCE TS: "Xhaul Packet Switched Architectures and Solutions"
- [27] IEEE 1588-2019: "IEEE Standard for a Precision Clock Synchronization Protocol for Networked Measurement and Control Systems"
- [28] IETF RFC 7384: "Security Requirements of Time Protocols in Packet Switched Networks"
- [29] 3GPP TS 33.511: "Security Assurance Specification (SCAS) for the next generation Node B (gNodeB) network product class"
- [30] O-RAN ALLIANCE TS: "Synchronization Architecture and Solution Specification"
- [31] O-RAN ALLIANCE TS: "O-RAN Control, User, and Synchronization Plane Specification"
- [32] 3GPP TS 38.323: "NR; Packet Data Convergence Protocol (PDCP)"
- [33] O-RAN ALLIANCE TS: "Near-RT RIC Architecture"
- [34] IETF RFC 6749: "The OAuth 2.0 Authorization Framework"
- [35] IETF RFC 7519: "JSON Web Token (JWT)"
- [36] IETF RFC 7515: "JSON Web Signature (JWS)"
- [37] O-RAN ALLIANCE TS: "Non-RT RIC: Architecture"
- [38] O-RAN ALLIANCE TS: "A1 interface General Aspects & Principles Specification"
- [39] O-RAN ALLIANCE TS: "R1 interface: General Aspects and Principles"
- [40] O-RAN ALLIANCE TS: "Non-RT RIC & A1 Interface: Use Cases and Requirements"

- [41] ETSI GS NFV-SEC 021: "VNF Package Security Specification"
- [42] ETSI GS NFV-SOL 004: "Protocols and Data Models; VNF Package specification"
- [43] ETSI GS NFV-IFA 011: "Management and Orchestration; VNF Descriptor and Packaging Specification"
- [44] Void
- [45] Void
- [46] "Security Guidance for 5G Cloud Infrastructures, Part I: Prevent and Detect Lateral Movement", page 5, US NSA ESF and US DHS CISA, October 2021, https://media.defense.gov/2021/Oct/28/2002881720/-1/-1/0/SECURITY_GUIDANCE_FOR_5G_CLOUD_INFRASTRUCTURES_PART_I_20211028.PDF.
- [47] Void
- [48] Void
- [49] Void
- [50] Void
- [51] Kubernetes Documentation - Encrypting Secret Data at Rest, <https://kubernetes.io/docs/tasks/administer-cluster/encrypt-data/>
- [52] Federal Information Processing Standards Publication (FIPS PUB) 140-3: "Security Requirements for Cryptographic Modules", <https://csrc.nist.gov/publications/detail/fips/140/3/final> <https://csrc.nist.gov/CSRC/media/Projects/cryptographic-module-validation-program/documents/fips%20140-3/FIPS%20140-3%20IG.pdf>
- [53] TPM 2.0 Library <https://trustedcomputinggroup.org/resource/tpm-library-specification/>
- [54] Void
- [55] 3GPP TS 33.501: "Security architecture and procedures for 5G System"
- [56] 3GPP TS 33.401: "3GPP System Architecture Evolution (SAE); Security architecture"
- [57] ISO/IEC 27000:2018: "Information technology - Security techniques - Information security management systems - Overview and vocabulary"
- [58] NIST SP 800-92: "Guide to Computer Security Log Management", <https://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-92.pdf>
- [59] IETF RFC 4210: "Internet X.509 Public Key Infrastructure Certificate Management Protocol (CMP)".
- [60] IETF RFC 5905: "Network Time Protocol Version 4: Protocol and Algorithms Specification"
- [61] IETF RFC 3339, "Date and Time on the Internet: Timestamps"
- [62] ISO 8601: "Date-time formats"
- [63] IETF RFC 8915: "Network Time Security for the Network Time Protocol"
- [64] IETF RFC 5424: "The Syslog Protocol"
- [65] IETF RFC 5425: "Transport Layer Security (TLS) Transport Mapping for Syslog"
- [66] O-RAN ALLIANCE TS: "Y1 interface: General Aspects and Principles"
- [67] NIST SP800-162: "Guide to ABAC Definition and Considerations", <https://doi.org/10.6028/NIST.SP.800-162>

- [68] NIST SP800-122: "Guide to Protecting the Confidentiality of Personally Identifiable Information (PII)", <https://doi.org/10.6028/NIST.SP.800-122>.
- [69] IETF RFC 8366: "A Voucher Artifact for Bootstrapping Protocols"
- [70] IETF RFC 8995: "Bootstrapping Remote Secure Key Infrastructure (BRSKI)"
- [71] IETF RFC 8572: "Secure Zero Touch Provisioning (SZTP)"
- [72] 3GPP TS 28.314: "Management and orchestration; Plug and connect; Concepts and requirements"
- [73] 3GPP TS 28.315: "Management and orchestration; Plug and connect; Procedure flows"
- [74] 3GPP TS 28.316: "Management and orchestration; Plug and connect; Data formats"
- [75] NIST SP 800-88: "Guidelines for Media Sanitization", <https://csrc.nist.gov/publications/detail/sp/800-88/rev-1/final>
- [76] 3GPP TS 33.117: "Catalogue of general security assurance requirements"
- [77] Void
- [78] IETF RFC 4493: "The AES-CMAC Algorithm"
- [79] IEEE Std 802.1AE-2018: "IEEE Standard for Local and metropolitan area networks —Media Access Control (MAC) Security"
- [80] O-RAN ALLIANCE TS: "O-RAN O2dms Interface Specification: Profile based on ETSI NFV Protocol and Data Models"
- [81] IETF RFC 5280: "Internet X.509 Public Key Infrastructure Certificate and Certificate Revocation List (CRL) Profile"
- [82] O-RAN ALLIANCE TS: "Cloudification and Orchestration Use Cases and Requirements for O-RAN Virtualized RAN"
- [83] Secure by Design: Product Security Bad Practices, US DHS CISA, October 16, 2024, <https://www.cisa.gov/resources-tools/resources/product-security-bad-practices>
- [84] IETF RFC 9562: "Universally Unique Identifiers (UUIDs)"
- [85] O-RAN ALLIANCE TS: "Transport Protocols for R1 Services"
- [86] IEEE Std 802.1Q-2018: "IEEE Standard for Local and Metropolitan Area Networks —Bridges and Bridged Networks"
- [87] O-RAN ALLIANCE TS: "Onboarding SMOS General Aspects and Principles"

2.2 Informative references

References are either specific (identified by date of publication and/or edition number or version number) or non-specific. For specific references, only the cited version applies. For non-specific references, the latest version of the referenced document (including any amendments) applies. In the case of a reference to a 3GPP document, a non-specific reference implicitly refers to the latest version of that document in Release 18, or the latest 3GPP release prior to Release 18 that includes that document.

NOTE: While any hyperlinks included in this clause were valid at the time of publication, O-RAN cannot guarantee their long-term validity.

The following referenced documents are not necessary for the application of the present document, but they assist the user with regard to a particular subject area.

- [i.1] NIST SP 800-190: "APPLICATION CONTAINER SECURITY GUIDE", <https://nvlpubs.nist.gov/nistpubs/specialpublications/nist.sp.800-190.pdf>

- [i.2] ENISA: "NFV SECURITY IN 5G Challenges and Best Practices",
<https://www.enisa.europa.eu/publications/nfv-security-in-5g-challenges-and-best-practices>
- [i.3] Void
- [i.4] Void
- [i.5] Thales: "Kubernetes Secrets Encryption - Integration Guide",
<https://cpl.thalesgroup.com/resources/encryption/kubernetes-secrets-encryption-integration-guide>
- [i.6] IBM: "Encrypting Kubernetes secrets with Key Management Service plug-in",
<https://www.ibm.com/docs/en/cloud-private/3.2.x?topic=kmskag-encrypting-kubernetes-secrets-key-management-service-plug-in>
- [i.7] NIST IR 8320: "HARDWARE-ENABLED SECURITY: ENABLING A LAYERED APPROACH TO PLATFORM SECURITY", <https://nvlpubs.nist.gov/nistpubs/ir/2022/NIST.IR.8320.pdf>.
- [i.8] "Recent trends in applying TPM to cloud computing",
<https://onlinelibrary.wiley.com/doi/full/10.1002/spy2.93>
- [i.9] API Security Project, Open Worldwide Application Security Project (OWASP), OWASP API Security Project | OWASP Foundation.
- [i.10] Kafka Documentation, <https://kafka.apache.org/documentation.html>
- [i.11] Void
- [i.12] NIST IR 4734: "Foundations of a Security Policy for Use of the National Research and Educational Network", <https://nvlpubs.nist.gov/nistpubs/Legacy/IR/nistir4734.pdf>
- [i.13] O-RAN ALLIANCE TR: "Study on Security for Fronthaul CUS-Plane"
- [i.14] O-RAN ALLIANCE TR: "O-RAN Security Threat Modeling and Risk Assessment"
- [i.15] 3GPP TR 33.848: "Study on Security Impacts of Virtualisation"
- [i.16] ETSI EG 203 647: "Methods for Testing and Specification (MTS); Methodology for RESTful APIs specifications and testing"
- [i.17] ETSI TR 28.908 v18.1.0 5G; Study on Artificial Intelligence/Machine Learning (AI/ML) management (3GPP TR 28.908 version 18.1.0 Release 18)
- [i.18] AI security concerns in a nutshell- Practical AI-Security guide, 2023, Federal Office for Information Security, https://www.bsi.bund.de/SharedDocs/Downloads/EN/BSI/KI/Practical_AI-Security_Guide_2023.pdf
- [i.19] <https://www.hopsworks.ai/dictionary/feature>
- [i.20] NIST AI 100-2e2023 Adversarial Machine Learning: A Taxonomy and Terminology of Attacks and Mitigations, draft white paper, US DoC NIST January 2024
- [i.21] Kubernetes documentation - Admission Controllers Reference,
<https://kubernetes.io/docs/reference/access-authn-authz/admission-controllers/>
- [i.22] RedHat OpenShift documentation - Managing security Policies,
<https://docs.openshift.com/acs/4.5/operating/manage-security-policies.html>
- [i.23] O-RAN ALLIANCE TR: "AI/ML workflow description and requirements"
- [i.24] Ensemble Methods in Machine Learning: A Comprehensive Guide.
<https://datasciencedojo.com/blog/ensemble-methods-in-machine-learning/>

- [i.25] Knowledge Distillation: A Survey: <https://arxiv.org/pdf/2006.05525>
- [i.26] NIST 800-63B: Digital Identity Guidelines: Authentication and Lifecycle Management, <https://pages.nist.gov/800-63-3/sp800-63b.html>.
- [i.27] ETSI GR NFV-SEC 009: "Network Functions Virtualisation (NFV); NFV Security; Report on use cases and technical approaches for multi-layer host administration"
- [i.28] ETSI GR NFV-SEC 018: "Network Functions Virtualisation (NFV); Security; Report on NFV Remote Attestation Architecture"
- [i.29] What is data augmentation? <https://www.ibm.com/think/topics/data-augmentation>
- [i.30] Four Principles of Explainable Artificial Intelligence, NIST Interagency/Internal Report (NISTIR) – 8312, <https://www.nist.gov/publications/four-principles-explainable-artificial-intelligence>
- [i.31] TechTarget: AI watermarking; <https://www.techtarget.com/searchenterpriseai/definition/AI-watermarking>
- [i.32] European Parliament briefing: “Generative AI and watermarking“; [https://www.europarl.europa.eu/RegData/etudes/BRIE/2023/757583/EPRS_BRI\(2023\)757583_EN.pdf](https://www.europarl.europa.eu/RegData/etudes/BRIE/2023/757583/EPRS_BRI(2023)757583_EN.pdf)
- [i.33] Aiwei Liu et al: A Survey of Text Watermarking in the Era of Large Language Models <https://arxiv.org/abs/2312.07913>
- [i.34] ModelObfuscator: Obfuscating Model Information to Protect Deployed ML-Based Systems, ISSTA 2023: Proceedings of the 32nd ACM SIGSOFT International Symposium on Software Testing and Analysis, Pages 1005 – 1017, <https://doi.org/10.1145/3597926.359811>

3 Definition of terms, symbols and abbreviations

3.1 Terms

For definitions of the security terms Attack, Risk, Security control, Technical control, Threat, and Vulnerability used in this document, refer to [i.14].

For the purposes of the present document, the following terms apply:

A1: Interface between Non-RT RIC and Near-RT RIC to enable policy-driven guidance of Near-RT RIC applications/functions, and support AI/ML workflow.

A1 policy: Type of declarative policies expressed using formal statements that enable the Non-RT RIC function in the SMO to guide the Near-RT RIC function, and hence the RAN, towards better fulfilment of the RAN intent.

A1 Enrichment information (EI): Information utilized by Near-RT RIC that is collected or derived at SMO/Non-RT RIC either from non-network data sources or from network functions themselves.

Account and Identity Events: Events generated by user identification and access control.

Adversarial training: A general method that augments the training data with adversarial examples generated iteratively during training using their correct labels. The stronger the adversarial attacks for generating adversarial examples are, the more resilient the trained model becomes [i.20].

AI/ML model: An algorithm that applies AI/ML techniques to produce model output data based on model input data. (see [37] clause 3.1).

Application descriptor: A template that defines the characteristics and requirements of the Application, allowing it to be deployed, managed, and orchestrated within the O-Cloud.

NOTE: An application descriptor typically includes information such as the application's functional behaviour, deployment requirements, resource needs (such as CPU, memory, and storage), connectivity requirements, performance metrics, scalability options, and any dependencies or prerequisites. It can also contain information related to security, including the service availability requirements and access rules for controlling the traffic direction to the application.

Application Events: Events generated by O-RAN Network Functions.

Audit Records: "Audit records contain security event information such as successful and failed authentication attempts, file accesses, security policy changes, account changes (e.g., account creation and deletion, account privilege assignment), and use of privileges. OSs typically permit system administrators to specify which types of events should be audited and whether successful and/or failed attempts to perform certain actions should be logged." Defined in NIST SP 800-92 [58], clause 2.1.2.

black-side: Identifies the Ethernet Data Encryption device (EDE) port that uses MACsec to protect transmitted frames and verify received frames.

Common Port: An instance of the MAC Internal Sublayer Service (ISS) used by the MAC Security Entity (SecY) to provide transmission and reception of frames for both the controlled and uncontrolled ports.

Controlled Port: The access point used to provide the secure MAC Service to a client of a MAC Security Entity (SecY).

Data Access Event: Events generated by any O-RAN component accessing, retrieving, modifying, or deleting data in files or databases.

Data augmentation: Data augmentation uses pre-existing data to create new data samples that can improve model optimization and generalizability [i.29].

Data Sanitization: Removing all the sensitive parts of the data before using it for training makes it impossible for intruders to extract the data from the trained model [i.18].

E2: Interface connecting the Near-RT RIC and one or more O-CU-CPs, one or more O-CU-UPs, and one or more O-DUs.

E2 Node: a logical node terminating E2 interface. In this version of the specification, O-RAN nodes terminating E2 interface are:

- for NR access: O-CU-CP, O-CU-UP, O-DU or any combination.
- for E-UTRA access: O-eNB.

End-to-End MACsec: MACsec is enabled at the Open Fronthaul endpoints, providing encryption for remote endpoints, while intermediary switches and TNE remain MACsec-unaware.

Ensemble Methods: Ensemble methods are techniques that create multiple AI/ML models and then combine them to produce a more accurate and robust final prediction. By aggregating the predictions of several base models, the ensemble can capture the strengths of each individual model while mitigating their weaknesses [i.24].

Entity: An individual (person), device, or process that interacts with an ORAN component.

Ethernet Data Encryption device (EDE): A two-port bridge that transmits and receives frames that are assumed to be unprotected to and from one red-side port, and conditionally relays those frames to and from its other black-side port, protecting and verifying frames transmitted and received on the black-side port using MACsec.

Explainable AI: Explainable AI is characterized by (i) accompanying evidence or reasons for outcomes and processes; (ii) explanations that are understandable to individual users; (iii) explanations that correctly reflect the system's process for generating the output; and (iv) decision making only under conditions for which the AI system was designed and when it reaches sufficient confidence in its output [i.30].

FCAPS: Fault, Configuration, Accounting, Performance, Security.

Feature: In the AI/ML context, a feature is a measurable property of some data sample that is used as input for an ML model for training and inference. A feature should have predictive power for the model it is being used in.[i.19]

Feature Scaling: Feature scaling in AI/ML is a data preprocessing technique (i.e., using suitable mathematical transformations) used to standardize the range of independent features present in a dataset. By suitable Feature Scaling, the impact of variations in the data on the Model's output is reduced.

General Security Event: Events generated by the enabling, disabling or configuration of security features in O-RAN components.

Hop-by-Hop MACsec: MACsec is enabled at the Open Fronthaul endpoints and TNEs providing point-to-point encryption at every hop in the Open Fronthaul network.

Information Security Event: "Identified occurrence of a system, service or network state indicating a possible breach of information security policy or failure of controls, or a previously unknown situation that can be security relevant." Defined in ISO/IEC 27000:2018 [57], clause 3.30.

Information Security Incident: "Single or a series of unwanted or unexpected information security events that have a significant probability of compromising business operations and threatening information security." Defined in ISO/IEC 27000:2018 [57], clause 3.31.

Intents: A declarative policy to steer or guide the behaviour of RAN functions, allowing the RAN function to calculate the optimal result to achieve stated objective.

Isolation: A security strategy that separates individual applications or software components from one another, ensuring that they run independently and do not interfere with each other's operations.

Log: "A log is a record of the events occurring within an organization's systems and networks. Logs are composed of log entries; each entry contains information related to a specific event that has occurred within a system or network." Defined in NIST SP 800-92 [58], clause 2.

Log streaming: In information technology, log streaming refers to the near real-time transmission and analysis of log data generated by various software applications, systems, or devices.

MAC Security Entity (SecY): The entity that operates the MAC Security protocol within a system.

Management and Orchestration Event: Events generated by SMO operations.

ML Training Host: The architecture element which hosts the training of the model, including offline and online training [i.23].

ML Inference Host: The architecture element which hosts the ML model during inference mode (which includes both the model execution as well as any online learning if applicable) [i.23].

ML Storage Host: An architecture element which hosts a storage service of AI/ML models. See [39] clause 5.6.3 and [33] clause 6A.2.1 for more detailed definitions of such a service.

ML (model) Life-cycle: The life-cycle of the ML model includes deployment, instantiation and termination of ML model components [i.23].

AI/ML Model Obfuscation: AI/ML Model obfuscation techniques hide and obfuscate the key information of ML model – structure, parameters and attributes - by renaming, parameter encapsulation, neural structure obfuscation, shortcut injection, and extra layer injection [i.34]

Model splitting: Model splitting includes the ability to distribute different parts of an AI/ML model across multiple nodes or domains, ensuring that no single node has access to the complete model. This approach can help mitigate the risk of model theft, data leakage, and unauthorized access.

Near-RT RIC: O-RAN Near-Real-Time RAN Intelligent Controller: An O-RAN Network Function (NF) comprised of the Near-RT RIC platform and Near-RT RIC Applications (xApps) [2].

Near-RT RIC APIs: A set of service-based interfaces that can be produced and consumed by the Near-RT RIC Platform and xApps [2].

Near-RT RIC platform: Platform supporting A1, E2, Y1 and O1 interfaces and providing a set of services via Near-RT RIC APIs needed for xApp functionality [2].

Network Events: Events generated by network activity from operating systems, hypervisors, or container engines.

Non-RT RIC: O-RAN non-real-time RAN Intelligent Controller: a logical function that enables non-real-time control and optimization of RAN elements and resources, AI/ML workflow including model training and updates, and policy-based guidance of applications/features in Near-RT RIC.

O-CU: O-RAN Central Unit: a logical node hosting O-CU-CP and O-CU-UP

O-CU-CP: O-RAN Central Unit – Control Plane: a logical node hosting the RRC and the control plane part of the PDCP protocol.

O-CU-UP: O-RAN Central Unit – User Plane: a logical node hosting the user plane part of the PDCP protocol and the SDAP protocol.

O-DU: O-RAN Distributed Unit: a logical node hosting RLC/MAC/High-PHY layers based on a lower layer functional split.

O-RU: O-RAN Radio Unit: a logical node hosting Low-PHY layer and RF processing based on a lower layer functional split.

O-RAN vendor: Provider of any component of O-RAN

O1: Interface used by the SMO framework, as specified in Clause 5.3.1, for operation and management of O-RAN NFs as specified in [2] [16].

O2: Interface between SMO and the O-Cloud to provide cloud resources management and workload management for supporting O-RAN cloudified network functions.

Open FH interface: The Open FH (Fronthaul) Interface is defined in the WG1 TS O-RAN Architecture Description [2], clause 5.4.7.

R1: Interface between rApps and Non-RT RIC Framework via which R1 Services can be produced and consumed.

R1 Services: A collection of services including, but not limited to, service registration and discovery services, authentication and authorization services, AI/ML workflow services, and A1, O1 and O2 related services.

RAN: Generally referred to as Radio Access Network.

rApps: Non-RT RIC application: an application designed to consume and/or produce R1 services.

rApp instance: An individual occurrence of an application running in the Non-RT RIC runtime environment. [37]

rApp instance identifier: A unique identifier for each rApp instance, assigned by the SMO/Non-RT RIC framework during rApp registration. [37].

red-side: Identifies the Ethernet Data Encryption device (EDE) port that does not use MACsec to protect transmitted frames or verify received frames.

Relevant Features: Relevant Features are individual measurable properties or characteristics of a data sample that have a significant impact on the model's ability to make accurate predictions or classifications. These features are directly linked to the target variable or outcome the model is trying to predict.

Security Controls: A solution designed to meet a set of defined security requirements to protect the confidentiality, integrity, and availability of O-RAN elements.

Security Group Rules: Policies that control network traffic to and from application connection points. They define the direction (ingress/egress), protocols, and port ranges for traffic, ensuring secure and controlled communication.

Security Log: A log that contains audit records and security-related system events.

Sensitive: A descriptor of information whose loss, misuse, or unauthorized access or modification could adversely affect security [i.12].

Shared Data Layer (SDL): API for accessing shared data storage.

Solution Provider: An application developer who delivers applications to Service Providers. [16].

Service Provider: A network provider who is planning to deploy applications into their network. [16].

NOTE: The term is also used to refer to the Telco Operator and/or the O-Cloud Provider since the Application package verification might be performed by both or by one or the other, depending upon the O-Cloud deployment models. The Telco Operator might act as the O-Cloud Provider (in case of private cloud model), or they might be two different entities (in case of hybrid or public cloud models).

System Events: "System events are operational actions performed by OS components, such as shutting down the system or starting a service. Typically, failed events and the most significant successful events are logged, but many OSs permit administrators to specify which types of events will be logged. The details logged for each event also vary widely; each event is usually timestamped, and other supporting information could include event, status, and error codes; service name; and user or system account associated with an event." Defined in NIST SP 800-92 [58], clause 2.1.2.

Time of Day (ToD): Within the O-Cloud, ToD represents the precise hour, minute, and second of a day, serving as a unified time reference across the infrastructure. This consistent time reference is essential to ensure that all nodes hosting O-RAN applications, operate in synchronization. Accurate ToD alignment in the O-Cloud is vital for tasks like event logging, data processing, and transaction sequencing, ensuring operational consistency and reliability across the entire O-Cloud environment.

Uncontrolled Port: The access point used to provide the insecure MAC Service to a client of a MAC Security Entity (SecY).

Unique cryptographic watermark for AI/ML models: This refers to a specialized technique used to embed distinct, verifiable information into an AI/ML model or its outputs. This watermark serves as a digital signature that identifies the model's origin, ownership, or specific instance, providing protection against unauthorized use, theft, or redistribution [i.31], [i.32], [i.33]. Key characteristics of such watermarks include:

- The watermark is embedded into the model's weights or architectural parameters using a cryptographic method that ensures uniqueness to the model's owner, and is detectable through a secure verification process accessible only to the legitimate owner or authorized entities.
- The watermark remains identifiable even if the model is subjected to adversarial attacks aiming to remove or alter the watermark, modifications such as pruning, quantization, or retraining, or distribution across different hardware/software environments.

xApp: An application consuming and/or producing Near-RT RIC services via the Near-RT RIC API to provide value added control of, or guidance to the E2 Nodes.

Y1: An interface between Near-RT RIC and Y1 consumers, as defined in O-RAN Architecture Description [2], clause 5.4.18. The interface enables RAN analytics information exposure from Near-RT RIC.

For definition of the terms Service Management and Orchestration (SMO), SMO External Interface, SMO External Consumer, SMO Function (SMOF), and SMO Service (SMOS) see the O-RAN Architecture Description (OAD) document [2], clause 2.3.1. Other terms defined in O-RAN Architecture Description (OAD) [2] also apply.

For definition of the terms Application, Application Artifact, and Application Package see the WG10 Onboarding SMOS General Aspects and Principles document [87], clause 3.1. Other terms defined in WG10 Onboarding SMO General Aspects and Principles [87] also apply.

For definition of the terms NF Deployment, O-Cloud Node, O-Cloud Node Cluster, and O-Cloud Platform see the O2 General Aspects and Principles (GAP) specification [6], clause 1.3.1. Other terms defined in [6] also apply.

3.2 Symbols

Void.

3.3 Abbreviations

For the purposes of the present document, the abbreviations given in 3GPP TR 21.905 [1] and the following apply. An abbreviation defined in the present document takes precedence over the definition of the same abbreviation, if any, in 3GPP TR 21.905 [1].

AI/ML	Artificial Intelligence/Machine Learning
BMCA	Best Master Clock Algorithm
CAK	Connectivity Association Key
CE	Customer Equipment as in IEEE802.1Q [86]
CKN	Connectivity Association Key Name
CNF	Cloud-native Network Function
DDoS	Distributed Denial of Service
DME	Data Management and Exposure
DMS	Deployment management services (of O-Cloud)
DTLS	Datagram Transport Layer Security
EAP	Extensible Authentication Protocol
eCPRI	enhanced Common Public Radio Interface
EDE-CC	Ethernet Data Encryption device with red-side recognition of C-TAGs and black-side addition and removal of C-TAGs
eNB	e NodeB (applies to LTE)
FH	Fronthaul
FHM	Fronthaul Multiplexer
FOCOM	Federated O-Cloud Orchestration & Management
FOSS	Free and Open Source Software
FTP	File Transfer Protocol
FTPES	File Transfer Protocol Explicit Secure sockets layer
FTPS	File Transfer Protocol Secure
gNB	g NodeB (applies to NR)
ICK	Integrity Check Key
IMS	Infrastructure management services (of O-Cloud)
ISS	MAC Internal Sublayer Service
IPsec	Internet Protocol Security
KEK	Key Encrypting Key
KPI	Key Performance Indicator
LLS	Lower Layer Split
MACsec	Media Access Control security
MFA	Multi-Factor Authentication
MKA	MACsec Key Agreement
MSK	Master Session Key
mTLS	mutual Transport Layer Security
NETCONF	Network Configuration Protocol
NF	Network Function
NFO	Network Function Orchestration
O-DU	O-RAN Distributed Unit
O-RU	O-RAN Radio Unit
OSC	O-RAN Software Community
PDCP	Packet Data Convergence Protocol
PKIX	Public-Key Infrastructure using X.509 [81]
PNF	Physical Network Function
PTP	Precision Timing Protocol
RAN	Radio Access Network
rAppId	rApp Instance Identifier
RBAC	Role-based Access Control
RIC	O-RAN RAN Intelligent Controller
SAK	Secure Association Key
SBOM	Software Bill of Materials

SDL	Shared Data Layer
SDLC	Software Development Life Cycle
SecY	MAC Security Entity
SME	Service Management and Exposure
SMO	Service Management and Orchestration
SMOS	SMO Service
SOH	Shared Operator Host
SPDX	Software Package Data eXchange
SRO	Shared Resource Operator
SSH	Secure Shell
SWID	Software Identification
T-BC	Telecom Boundary Clock
T-GM	Telecom Grandmaster
TNE	Transport Network Equipment (an O-RAN term to denote a transport device)
TLS	Transport Layer Security
T-TC	Telecom Transparent Clock
T-TSC	Telecom Time Synchronous Clock
VM	Virtual machine
VNF	Virtual Network Function

4 Objectives and scope

4.1 Objectives

The present document specifies security requirements and security controls per O-RAN defined interface and O-RAN defined network function. It elaborates on O-RAN Threat Modeling and Risk Assessment [4] that identified assets to be protected, analysed the O-RAN components for vulnerabilities, examined potential threats associated with those vulnerabilities and provided security principles which stakeholders should address when building a secure end-to-end O-RAN system.

4.2 Perimeter

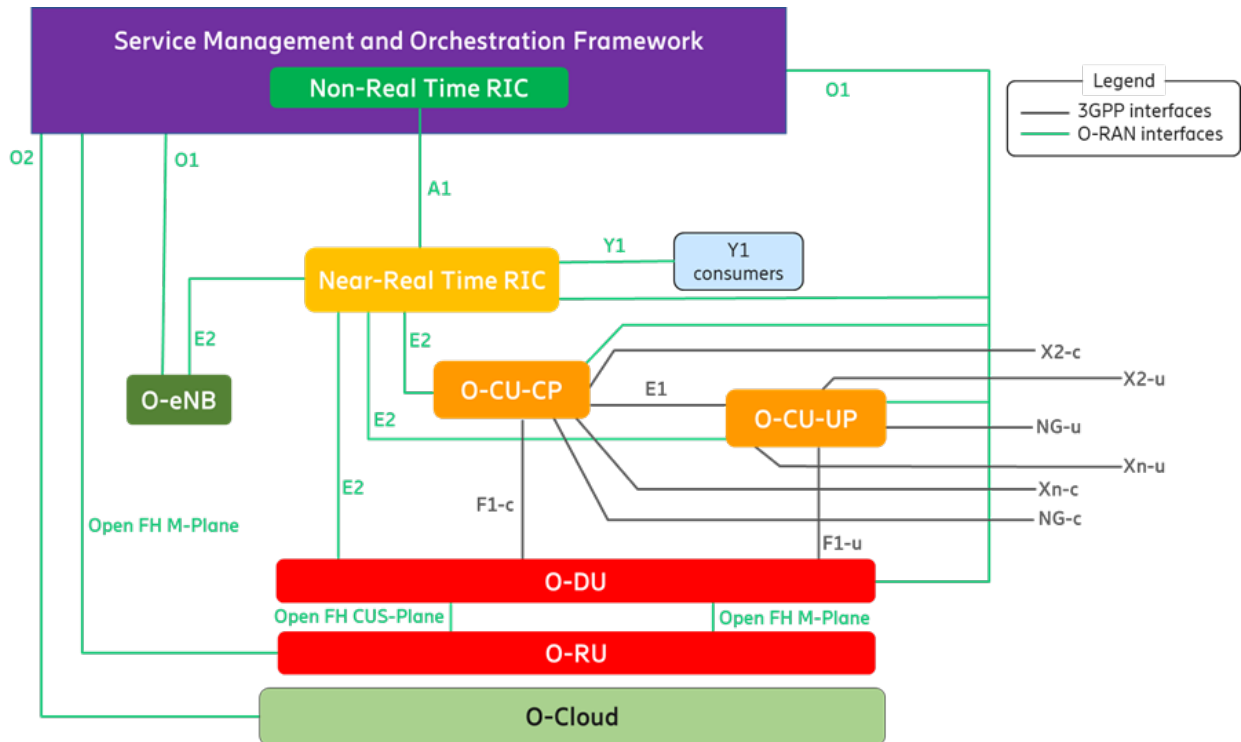


Figure 4-1: Logical Architecture of O-RAN system [2]

As specified in [2] and illustrated in Figure 4-1, the logical architecture of O-RAN includes the following components, interfaces, and protocols:

1. O-RAN Architecture components
 - Network functions and applications
 - Service Management and Orchestration (SMO)
 - Non-RT RIC and rApps
 - Near-RT RIC and xApps
 - O-CU-CP/UP
 - O-DU
 - O-RU
 - O-eNB
 - Cloud computing platform
 - O-Cloud comprising physical infrastructure nodes to host the relevant O-RAN functions (such as Near-RT RIC, O-CU-CP, O-CU-UP, and O-DU) and, supporting software components (such as Operating System, Virtual Machine Monitor, Container Runtime) and the appropriate management and orchestration functions.
2. Interfaces defined by O-RAN
 - A1 Interface between Non-RT RIC and Near-RT RIC to enable policy-driven guidance of Near-RT RIC applications/functions, and support AI/ML workflow.
 - O1 Interface connecting the SMO to the Near-RT RIC, one or more O-CU-CPs, one or more O-CU-UPs, and one or more O-DUs.
 - O2 Interface between the SMO and the O-Cloud
 - E2 Interface connecting the Near-RT RIC and one or more O-CU-CPs, one or more O-CU-UPs, one or more O-DUs, and one or more O-eNBs.
 - Open Fronthaul CUS-Plane Interface between O-RU and O-DU

- Open Fronthaul M-Plane Interface between O-RU and O-DU as well as between O-RU and SMO

4.2.1 Void

4.2.2 Void

4.2.3 Void

5 Security Requirements and Controls

5.0 Introduction

This clause describes the O-RAN security requirements and controls per O-RAN maintained interfaces and network functions. Security requirements and controls specified in this document are built upon Security Principles defined in [4] which intent to protect critical assets identified.

Protection levels of critical assets as defined in [4] – Confidentiality, Integrity, Replay, Authentication, Authorisation – are now specified as normative Security Requirements and Controls.

In Annex D, mappings between threats and requirements, and between requirements and controls, are provided. These mappings illustrate how the specific threats defined in [i.14] are addressed by corresponding security requirements and how these requirements are subsequently implemented through various controls.

5.1 O-RAN Architecture Elements

5.1.1 Service Management and Orchestration (SMO)

5.1.1.1 Security Requirements

5.1.1.1.1 SMO

REQ-SEC-SMO-1: SMO shall support authentication of SMO functions.

REQ-SEC-SMO-2: SMO shall support authentication of SMO External Consumers.

REQ-SEC-SMO-3: SMO functions shall support authorization as a resource owner/server and client for internal requests.

REQ-SEC-SMO-4: SMO shall support authorization of the service requests received from SMO External Consumers.

REQ-SEC-SMO-5: SMO shall be able to recover, without catastrophic failure, from a volumetric DDoS attack across the O2 interface, due to anomalous behaviour or malicious intent.

REQ-SEC-SMO-6: SMO shall be able to recover, without catastrophic failure, from a volumetric DDoS attack across an SMO External Interface, due to anomalous behaviour or malicious intent.

REQ-SEC-SMO-7: Each SMO function shall be able to recover, without catastrophic failure, from a volumetric DDoS attack during SMO Internal Communications, due to anomalous behaviour or malicious intent.

REQ-SEC-SMO-8: SMO shall support encryption to provide confidentiality and integrity of data at rest.

NOTE: Support for encryption of data at rest can be implemented native to the SMO or with encryption capabilities provided by the platform running the SMO.

5.1.1.1.2 SMOS Communication

REQ-SEC-SMO-Internal-1: SMOS Communication shall support confidentiality, integrity, and replay protection for data-in-transit between SMOS Producers and SMOS Consumers.

REQ-SEC-SMO-Internal-2: SMOS Communication shall support mutual authentication between SMOS Producers and SME, and between SMOS Consumers and SME.

5.1.1.1.3 SMO External Interfaces

SMOS can expose SMO External Interfaces to SMO External Consumers and Producers of SMO services and data [2]. SMO External Interfaces are not specified by O-RAN but shall meet security requirements specified in this clause.

REQ-SEC-SMO-External-1: SMOS exposing a SMO External Interface shall support confidentiality, integrity, and replay protection for data-in-transit with a SMO External Consumer or Producer.

REQ-SEC-SMO-External-2: SMOS exposing a SMO External Interface shall support mutual authentication with a SMO External Consumer or Producer..

REQ-SEC-SMO-External-3: SMOS exposing a SMO External Interface shall support authorization with the principle of least privilege for the SMO External Consumer or Producer.

5.1.1.1.4 SMO Logging

The below mentioned requirements are referring to securing the event logs in SMO.

REQ-SEC-SMO-Log-1: SMO shall support forwarding of event logs to a mutually authenticated remote location.

REQ-SEC-SMO-Log-2: SMO shall provide confidentiality and integrity protection for event logs transferred to a remote server.

REQ-SEC-SMO-Log-3: SMO may support configuration settings that allow selection of remote servers to securely transfer the event logs.

REQ-SEC-SMO-Log-4: SMO shall be capable of logging the event logs locally on itself.

REQ-SEC-SMO-Log-5: SMO shall provide confidentiality protection for the locally stored event logs.

REQ-SEC-SMO-Log-6: SMO shall provide integrity protection for the locally stored event logs.

REQ-SEC-SMO-Log-7: SMO shall support access to event logs by authorized external services.

REQ-SEC-SMO-Log-8: SMO shall be capable of forwarding event logs to an authorized remote location.

REQ-SEC-SMO-Log-9: SMO shall be able to record all the security related log events.

REQ-SEC-SMO-Log-10: The security logs of SMO should be separate from other system logs.

REQ-SEC-SMO-Log-11: The SMO shall permit only authorized configuration changes to logging level(s) of any component on the SMO.

REQ-SEC-SMO-Log-12: SMO shall support access to event logs by authorized internal services.

5.1.1.1.5 NFO and FOCOM

The below mentioned requirements are referring to securing the NFO and FOCOM in SMO.

REQ-SEC-NFO-FOCOM-1: NFO and FOCOM shall support confidentiality, integrity, and replay protection.

REQ-SEC-NFO-FOCOM-2: Void

REQ-SEC-NFO-FOCOM-3: NFO shall support mutual authentication with the O-Cloud DMS on the O2 interface.

REQ-SEC-NFO-FOCOM-4: FOCOM shall support mutual authentication with the O-Cloud IMS on the O2 interface.

REQ-SEC-NFO-FOCOM-5: NFO and FOCOM shall support authorization with the principle of least privilege for access attempts by O-Cloud service consumers, on a per-session basis.

REQ-SEC-NFO-FOCOM-6: NFO shall be able to recover, without catastrophic failure, from a volumetric DDoS attack due to anomalous behaviour or malicious intent.

REQ-SEC-NFO-FOCOM-7: Void

REQ-SEC-NFO FOCOM-8: FOCOM shall be able to recover, without catastrophic failure, from a volumetric DDoS attack due to anomalous behaviour or malicious intent.

5.1.1.1.6 SME

REQ-SEC-SME-1: SME shall support mutual authentication with a SMOS Consumer requesting access to a SMOS Producer.

REQ-SEC-SME-2: SME shall support mutual authentication with a SMO External System requesting access to SMOS Producer.

REQ-SEC-SME-3: SME shall support mutual authentication with a SMOS Producer.

REQ-SEC-SME-4: SME shall support authorization of a SMOS Consumer requesting access to a SMOS Producer.

REQ-SEC-SME-5: SME shall support authorization of a SMO External System requesting access to a SMOS Producer.

REQ-SEC-SME-6: SME shall support confidentiality, integrity, and replay protection.

REQ-SEC-SME-7: SME shall be able to recover, without catastrophic failure, from a volumetric DDoS attack from another SMOS.

REQ-SEC-SME-8: SME shall be able to recover, without catastrophic failure, from a volumetric DDoS attack across a SMO External Interface.

REQ-SEC-SME-9: SME shall support authorization of R1 service requests.

5.1.1.1.7 SMOS

REQ-SEC-SMOS-1: SMOS Producers and SMOS Consumers shall support mutual authentication with the SME.

REQ-SEC-SMOS-2: SMOS Producer shall support authorization of a SMOS Consumer using the SME authorization service.

REQ-SEC-SMOS-3: SMOS Producers and SMOS Consumers shall support confidentiality, integrity, and replay protection.

REQ-SEC-SMOS-4: SMOS Producers and SMOS Consumers shall be able to recover, without catastrophic failure, from a volumetric DDoS attack from SMOS Communication.

REQ-SEC-SMOS-5: SMOS Producers and SMOS Consumers shall support encryption to provide confidentiality and integrity of data at rest.

NOTE: Support for encryption of data at rest can be implemented native to the SMOS or with encryption capabilities provided by the platform running the SMOS.

5.1.1.1.8 DME

REQ-SEC-DME-1: DME shall support authentication for a SMOS Consumer requesting access to Data.

REQ-SEC-DME-2: DME shall support authentication of an SMO External System requesting access to Data.

REQ-SEC-DME-3: DME shall support authorization for a SMOS Consumer requesting access to Data.

REQ-SEC-DME-4: DME shall support authorization for an SMO External System requesting access to Data.

REQ-SEC-DME-5: DME shall support confidentiality, integrity, and replay protection.

REQ-SEC-DME-6: DME shall be able to recover, without catastrophic failure, from a volumetric DDoS attack from another SMOS.

REQ-SEC-DME-7: DME shall be able to recover, without catastrophic failure, from a volumetric DDoS attack across SMO External Interface.

5.1.1.2 Security Controls

5.1.1.2.1 SMO

SEC-CTL-SMO-1: SMO may support OAuth 2.0 authorization server and provide a token end-point, as specified in O-RAN Security Protocols Specifications [3], clause 4.7.

SEC-CTL-SMO-2: Void

SEC-CTL-SMO-3: SMO shall support OAuth 2.0 resource owner/server, as specified in O-RAN Security Protocols Specifications [3], clause 4.7, for service requests received from other SMO functions.

SEC-CTL-SMO-4: SMO shall support OAuth 2.0 client functionality, as specified in O-RAN Security Protocols Specifications [3], clause 4.7, for service requests to other SMO functions.

SEC-CTL-SMO-5: SMO shall support mutual authentication of SMO functions using mTLS with PKI X.509v3 certificates as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-SMO-6: SMO functions may support authentication of other SMO functions using TLS with pre-shared key (PSK) as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

5.1.1.2.2 SMOS Communication

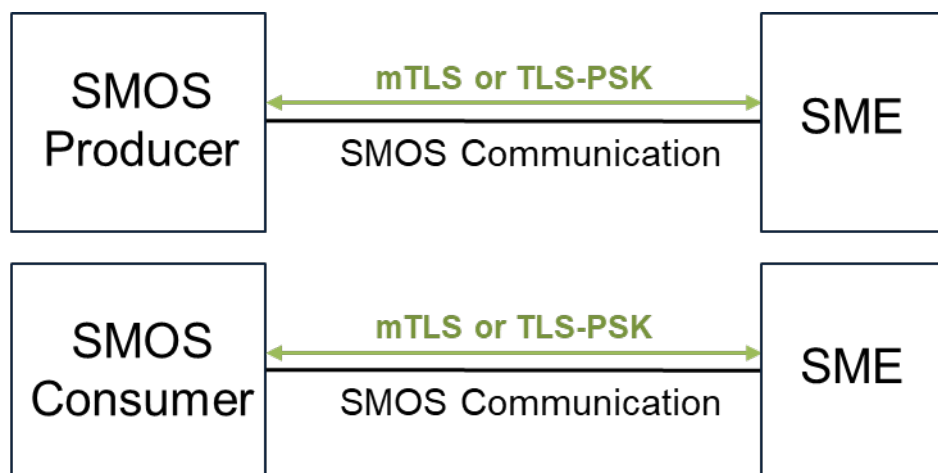


Figure 5.1.1.2.2-1: mTLS or TLS for SMOS Communication

SEC-CTL-SMO-Internal-1: For security protection at the transport layer, SMOS Communication shall support TLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-SMO-Internal-2: For mutual authentication between SMOS Producers and SME, and SMOS Consumers and SME, SMOS Communication shall support mTLS, as shown in Figure 5.1.1.2.2-1 and specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-SMO-Internal-3: For authentication between SMOS, SMOS Communication may support TLS with pre-shared key (PSK), as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

5.1.1.2.3 SMO External Interfaces

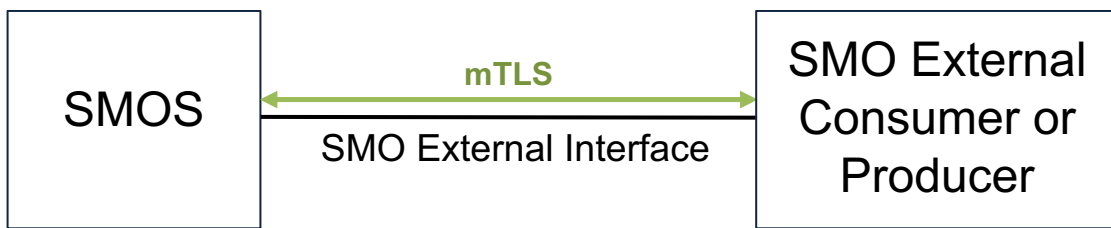


Figure 5.1.1.2.3-1: mTLS with SMO External Consumers and Producers

SEC-CTL-SMO-External-1: SMOS shall support confidentiality and integrity protection of data-in-transit with a SMO External Consumer or Producer using TLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-SMO-External-2: SMOS shall support mutual authentication with a SMO External Consumer or Producer using mTLS with PKI using X.509v3 certificates, as shown in Figure 5.1.1.2.3-1 and specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-SMO-External-3: SMOS shall support OAuth 2.0 resource owner/server, as specified in O-RAN Security Protocols Specifications [3], clause 4.7, for authorization of a SMO External Consumer.

SEC-CTL-SMO-External-4: SMO External Interfaces shall support OAuth 2.0 client functionality, as specified in O-RAN Security Protocols Specifications [3], clause 4.7.

5.1.1.2.4 SMO Logging

SEC-CTL-SMO-Log-1: A SMO External Interface used for SMO log export shall support TLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2, and FTPES, as specified in O-RAN Security Protocols Specifications [3], clause 6.3.

SEC-CTL-SMO-Log-2: SMO log export may support SSH as specified in O-RAN Security Protocols Specifications [3], clause 4.1, and SFTP, as specified in O-RAN Security Protocols Specifications [3], clause 6.2.

SEC-CTL-SMO-Log-3: SMO log export shall support mutual authentication using mTLS with public key infrastructure (PKI) and X.509v3 certificates as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-SMO-Log-4: When SSH is supported for SMO log export, SSH may support authentication using public and private keys in a public key infrastructure (PKI).

SEC-CTL-SMO-Log-5: When SSH is supported for SMO log export, SSH may support authentication using PKI and X.509v3 certificates.

5.1.1.2.5 NFO and FOCOM

SEC-CTL-NFO-FOCOM-1: NFO shall support mutual authentication with O-Cloud DMS using mTLS with PKI X.509v3 certificates, as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-NFO-FOCOM-2: FOCOM shall support mutual authentication with O-Cloud IMS using mTLS with PKI X.509v3 certificates, as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-NFO-FOCOM-3: NFO shall support OAuth 2.0 resource owner/server as specified in O-RAN Security Protocols Specifications [3], clause 4.7, for service requests from O-Cloud resources.

SEC-CTL-NFO-FOCOM-4: FOCOM shall support OAuth 2.0 resource owner/server, as specified in O-RAN Security Protocols Specifications [3], clause 4.7, for service requests from O-Cloud resources.

SEC-CTL-NFO-FOCOM-5: NFO shall support OAuth 2.0 client functionality as specified in O-RAN Security Protocols Specifications [3], clause 4.7, for service requests to O-Cloud resources.

SEC-CTL-NFO-FOCOM-6: FOCOM shall support OAuth 2.0 client functionality, as specified in O-RAN Security Protocols Specifications [3], clause 4.7, for service requests to O-Cloud resources.

SEC-CTL-NFO-FOCOM-7: NFO shall support TLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2, on the O2 interface.

SEC-CTL-NFO-FOCOM-8: FOCOM shall support TLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2, on the O2 interface.

5.1.1.2.6 SME

SEC-CTL-SME-1: SME shall support mutual authentication using mTLS with PKI X.509v3 certificates, as specified in O-RAN Security Protocols Specifications [3], clause 4.2, with SMOS Producers, SMOS Consumers, and SMO External Systems.

SEC-CTL-SME-2: SME shall support OAuth server role as specified in O-RAN Security Protocols Specifications [3], clause 4.7, for service requests from a SMO Consumer and SMO External System.

SEC-CTL-SME-3: SME shall support TLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2 for data-in-transit with SMOS Producers, SMOS Consumers, and SMO External Systems.

5.1.1.2.7 SMOS Producers and SMOS Consumers

SEC-CTL-SMOS-1: SMOS Producers and SMOS Consumers shall support mutual authentication with SME using mTLS with PKI X.509v3 certificates, as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-SMOS-2: SMOS Producers shall support OAuth 2.0 resource owner/server role as specified in O-RAN Security Protocols Specifications [3], clause 4.7, for service requests from the SME.

SEC-CTL-SMOS-3: SMOS Consumers shall support OAuth 2.0 client role as specified in O-RAN Security Protocols Specifications [3], clause 4.7, for service requests to the SME.

SEC-CTL-SMOS-4: SMOS Producers and SMOS Consumers shall support TLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2, for SMOS Communication.

5.1.1.2.8 DME

SEC-CTL-DME-1: For data subscription, DME shall support authentication using TLS with X.509 certificate or pre-shared key (PSK), as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-DME-2: DME shall support OAuth server role as specified in O-RAN Security Protocols Specifications [3], clause 4.7, for service requests from a SMOS Consumer or SMO External System.

SEC-CTL-DME-3: DME shall support TLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2 for data-in-transit with SMOS Producer, SMOS Consumer, and SMO External System.

5.1.2 Non-RT RIC and rApps

5.1.2.1 Requirements

rApp packages shall follow the security requirements and controls in clause 5.3.2.1.

REQ-SEC-NonRTRIC-1: The Non-RT RIC shall support authorization as a resource owner/server and client.

REQ-SEC-NonRTRIC-2: The Non-RT RIC Framework, as a resource owner/server, shall provide authorization to requests from rApps as a client.

REQ-SEC-NonRTRIC-3: rApps shall provide client authorization requests to the Non-RT RIC Framework.

REQ-SEC-NonRTRIC-4: The Non-RT RIC shall be able to recover, without catastrophic failure, from a volumetric DDoS attack across the A1 interface, due to misbehavior or malicious intent.

REQ-SEC-NonRTRIC-5: The Non-RT RIC Framework shall be able to recover, without catastrophic failure, from a volumetric DDoS attack across the R1 interface, due to misbehavior or malicious intent.

REQ-SEC-NonRTRIC-6: rApps shall be able to recover, without catastrophic failure, from a volumetric DDoS attack across the R1 interface, due to misbehavior or malicious intent.

REQ-SEC-NonRTRIC-7: The SMO/Non-RT RIC Framework shall authenticate both API Producer and API Consumer across R1 interface using Kafka based protocol, as specified in [85] for data streaming.

REQ-SEC-NonRTRIC-8: The SMO/Non-RT RIC Framework shall support an authorization mechanism for Kafka based protocol, as specified in [85], for data streaming requests between API Producer and API Consumer across R1 interface.

REQ-SEC-NonRTRIC-9: rAppIDs shall be unique within the Non-RT RIC runtime environment.

REQ-SEC-NonRTRIC-10: rAppIDs shall be generated using strong randomisation methods, as defined in O-RAN Security Protocols Specifications [3], clause 5.

NOTE: Strong randomization methods can help resist brute force attacks.

REQ-SEC-NonRTRIC-11: The SMO or Non-RT RIC Framework shall support limiting of system resource consumption of rApps, including compute, memory, and storage.

REQ-SEC-NonRTRIC-12: The SMO or Non-RT RIC Framework shall support monitoring of system resource consumption of rApps, including compute, memory, and storage.

REQ-SEC-NonRTRIC-13: rApp shall request access tokens for R1 services.

REQ-SEC-NonRTRIC-14: rApps shall support encryption to provide confidentiality and integrity of data at rest.

NOTE: Support for encryption of data at rest can be implemented native to the rApp or with encryption capabilities provided by the platform running the rApp.

5.1.2.2 Security Controls

SEC-CTL-NonRTRIC-1: For A1-EI, Non-RT RIC shall support OAuth 2.0 resource owner/server role, as specified in O-RAN Security Protocols Specifications [3], clause 4.7, for service requests received from one or more Near-RT RICs.

SEC-CTL-NonRTRIC-2: For A1-P, Non-RT RIC shall support OAuth 2.0 client role, as specified in O-RAN Security Protocols Specifications [3], clause 4.7.

SEC-CTL-NonRTRIC-3: For R1, SMO/Non-RT RIC Framework shall support TLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

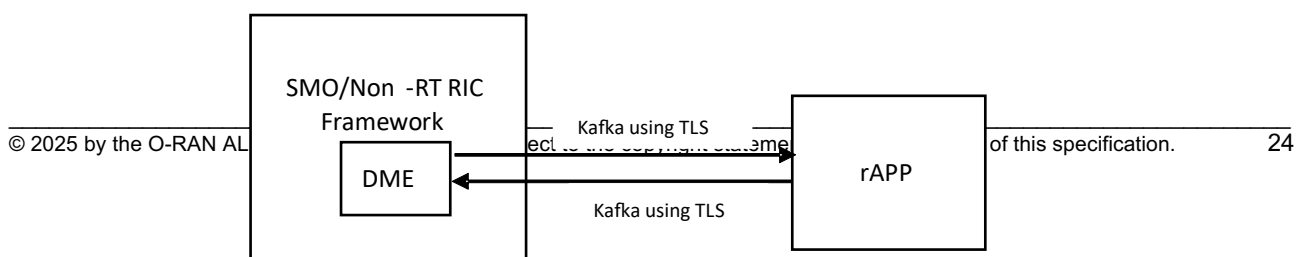


Figure 5.1.2.2-1: TLS for Kafka-based protocol

SEC-CTL-NonRTRIC-4: For R1, SMO/Non-RT RIC Framework shall support authorization using OAuth 2.0, as specified in O-RAN Security Protocols Specifications [3], clause 4.7.

SEC-CTL-NonRTRIC-5: For R1, Non-RT RIC Framework shall support OAuth 2.0 resource owner/server functionality, as specified in O-RAN Security Protocols Specifications [3], clause 4.7.

SEC-CTL-NonRTRIC-6: For R1, rApps shall support OAuth 2.0 client role, as specified in O-RAN Security Protocols Specifications [3], clause 4.7.

5.1.3 Near-RT RIC and xApps

5.1.3.1 Requirements

xApp packages shall follow the security requirements and controls in clause 5.3.2.1.

REQ-SEC-XAPP-1: Void

REQ-SEC-XAPP-2: Void

REQ-SEC-XAPP-3: During the xApp registration procedure the xApp identifier (xApp ID) shall be associated with xApp credentials used for authentication.

REQ-SEC-XAPP-4: xApp IDs shall be created ensuring uniqueness.

REQ-SEC-NEAR-RT-1: The Near-RT RIC shall support authentication and authorization for data access.

REQ-SEC-NEAR-RT-2: The Near-RT RIC shall support enforcement of data access control policies aligned with the principle of least privilege.

REQ-SEC-NEAR-RT-2A: Near-RT RIC shall provide confidentiality and integrity protection for Near-RT RIC database(s).

REQ-SEC-NEAR-RT-3: The communication between xApps and Near-RT RIC platform APIs shall be mutually authenticated.

REQ-SEC-NEAR-RT-4: Near-RT RIC architecture shall provide an authorization framework for the consumption of the services exposed in the platform APIs by the xApps, that takes operator policies into consideration.

NOTE : The framework is used by the specified API procedures in [33].

REQ-SEC-NEAR-RT-5: The Near-RT RIC shall support authorization as a resource owner/server (A1-P) and client (A1-EI).

REQ-SEC-NEAR-RT-6: The Near-RT RIC shall be able to recover, without catastrophic failure, from a volumetric DDoS attack across the A1 interface.

REQ-SEC-NEAR-RT-7: The Near-RT RIC shall be able to detect and defend against content-related attacks across the A1 interface.

NOTE 1: In practice, injection attacks and buffer overflow attacks are the most common classes of content-related attacks.

REQ-SEC-NEAR-RT-8: The Near-RT RIC shall be able to detect and defend against content-related attacks across the Y1 interface.

NOTE 2: In practice, injection attacks and buffer overflow attacks are the most common classes of content-related attacks.

REQ-SEC-NEAR-RT-9: The Near-RT RIC shall be able to detect and defend against content-related attacks across the E2 interface.

NOTE 3: In practice, injection attacks and buffer overflow attacks are the most common classes of content-related attacks.

REQ-SEC-NEAR-RT-10: The Near-RT RIC shall support confidentiality, integrity and replay protection for the A1 interface.

REQ-SEC-NEAR-RT-11: The Near-RT RIC shall support mutual authentication for the A1 interface.

REQ-SEC-NEAR-RT-12: The Near-RT RIC shall support the protection of data in terms of integrity and confidentiality at rest, in use and in transit.

5.1.3.2 Security Controls

5.1.3.2.1 API Security – Authentication

SEC-CTL-NEAR-RT-1: Transactional APIs (REST and gRPC) shall support mutual TLS (mTLS) authentication via X.509v3 certificates as specified in the O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-NEAR-RT-2: Time critical APIs, not supported by TLS protocol, shall support IPsec with IKEv2 certificate-based authentication according to O-RAN Security Protocols Specifications [3].

NOTE: In this case authentication grants authorization and there is no native authorization method for SCTP.

EXAMPLE: E2 related APIs are considered time critical APIs

SEC-CTL-NEAR-RT-2A: The Near-RT RIC shall support mTLS as specified in O-RAN Security Protocols Specifications [3], clause 4.2, in order to provide mutual authentication for the A1 interface.

5.1.3.2.2 API Security – Authorization

SEC-CTL-NEAR-RT-3A: The Near-RT RIC platform as API producer shall support rights/privileges for the platform services as resources to the xApps consumers.

SEC-CTL-NEAR-RT-3B: An xApp should only have the required set of permissions to perform the actions for which they are authorized, and no more.

SEC-CTL-NEAR-RT-3C: The Near-RT RIC platform shall enforce authorization mechanisms in the following key API procedures [33]:

- **Discovery of Near-RT RIC APIs:** The Near-RT RIC platform shall provide means to restrict xApps from discovery of some published APIs based on configuration policies.
- **E2 Subscription API procedure:** The subscription management shall be based on operator's policies. An xApp may be restricted to interface with only a subset of E2 Nodes by such policies. This procedure establishes a set of preconditions that assume authorization processes:
 - xApp has been authorized to issue E2 Subscription API requests
 - xApp has been authorized to request guidance from Conflict mitigation
 - xApp Subscription Management has been configured to permit E2 Subscription API requests only from specific list of xApps.
- **E2 Control API procedure:** Only authorized xApps may initiate RIC control request messages issued by the Near-RT RIC over the E2 interface to the E2 Nodes, for a specific scope.

EXAMPLE 1: E2Nodes include E2 Node list, RAN function

- **E2 Guidance API procedure:** Ensure only authorized xApp obtain guidance from the conflict mitigation platform function prior to initiating an action.
- **SDL API procedures:** xApps shall have been successfully registered and authorized prior to consuming the services exposed by SDL API.

EXAMPLE 2: Services exposed by SDL API may be client registration, fetch data, notification, store

SEC-CTL-NEAR-RT-3: Transactional APIs (REST and gRPC) in Near-RT RIC shall support OAuth 2.0 authorization framework as specified in in O-RAN Security Protocols Specifications [3], clause 4.7.

The roles defined in OAuth 2.0 are assigned as follows:

- Resource owner / Resource server (producer): Near-RT RIC platform modules providing services via APIs
- Client (consumer): xApp

Grants shall be of the type Client Credentials Grant, as described in IETF RFC 6749 [34], clause 4.4. Mutual authentication using mTLS as specified in the O-RAN Security Protocols Specifications [3], clause 4.2 shall be used.

SEC-CTL-NEAR-RT-4: For A1-P, Near-RT RIC shall support OAuth 2.0 resource owner/server, as specified in O-RAN Security Protocols Specifications [3], clause 4.7, for service requests received from a Non-RT RIC.

SEC-CTL-NEAR-RT-5: For A1-EI, Near-RT RIC shall support OAuth 2.0 client, as specified in O-RAN Security Protocols Specifications [3], clause 4.7.

5.1.3.2.3 API Security – Confidentiality and Integrity

SEC-CTL-NEAR-RT-6: Transactional APIs (REST and gRPC) shall support TLS as specified in the O-RAN Security Protocols Specifications [3], clause 4.2 to provide message confidentiality and integrity.

SEC-CTL-NEAR-RT-7: Time critical APIs, not supported by TLS protocol, shall support IPsec as specified in the O-RAN Security Protocols Specifications [3], clause 4.5 to provide message confidentiality and integrity.

Table 5-1 provides a summary of the security controls (SEC-CTL- NEAR-RT-1 to -7) and a mapping of those to the related interface/API transport protocols considered in Near-RT RIC platform.

Table 5-1: Summary of the Security Controls for Near-RT RIC APIs

API protocol	Authentication method	Authorization method	Confidentiality method	Integrity method
gRPC	mTLS	OAuth2	mTLS	mTLS
SCTP	IKEv2	-	IPsec	IPsec
REST/HTTP	mTLS	OAuth2	mTLS	mTLS

SEC-CTL-NEAR-RT-8: The Near-RT RIC shall verify policies received through the A1 interface as follows:

- The policies conform to a pre-defined schema.
- The policy values are valid.
- The policies are being received at or below a pre-defined rate.

The Near-RT RIC shall log security event(s) if any of the policy verification steps fail.

EXAMPLE: In practice, policy value validation verifies that values are within the predefined range

SEC-CTL-NEAR-RT-8A: The Near-RT RIC shall support TLS as specified in O-RAN Security Protocols Specifications [3], clause 4.2, in order to provide confidentiality, integrity and replay protection for the A1 interface.

5.1.3.2.4 Security controls for the Y1 interface protocol structure solution 1

The Y1 interface protocol structure solution 1 is defined in the O-RAN ALLIANCE TS: "Y1 interface: General Aspects and Principles" [66], clause 7.2.

NOTE 0: 'Y1 interface protocol structure solution 1' is the name given to the solution in [66], clause 7.2. No further solutions are defined at the time of publication.

SEC-CTL-NEAR-RT-9: The Near-RT RIC shall support mutual TLS (mTLS) authentication via X.509v3 certificates for the Y1 interface protocol structure solution 1, as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

NOTE 1: In mTLS, both the client (the Y1 consumer) and the server (the Y1 provider) require a certificate, and both sides authenticate each other using their public/private key pair.

SEC-CTL-NEAR-RT-10: The Near-RT RIC shall support the OAuth 2.0 authorization framework for the Y1 interface protocol structure solution 1 as specified in O-RAN Security Protocols Specifications [3], clause 4.7, in the role of a resource owner / resource server (producer).

SEC-CTL-NEAR-RT-11: The Near-RT RIC shall support TLS for the Y1 interface protocol structure solution 1, as specified in O-RAN Security Protocols Specifications [3], clause 4.2, to provide data confidentiality, integrity, and replay-protection.

5.1.3.2.5 xApp Registration – Security procedure

As part of the xApp registration procedure to the Near-RT RIC platform, the platform assigns an identity (ID) to the xApp, so called xApp ID. This xApp ID is used in xApp's API request messages to the Near-RT RIC platform to facilitate the Near-RT RIC platform the identification of the xApp (API service consumer).

SEC-CTL-NEAR-RT-12: The xApp ID shall be embedded into the provided xApp X.509 certificate used for authentication (mTLS) according to the parametrization in [3], issued by operator RA/CA PKI infrastructure.

NOTE 1: The security procedure to become part of the existing xApp registration procedure, specified in O-RAN ALLIANCE TS: "Near-RT RIC Architecture" [33], clause 9.1.4 where xApp ID is assigned, is detailed in the figures 5.1.3.2-1 and 5.1.3.2-2:

```
@startuml
participant xapp as "xApp\n[API service consumer]"
participant nfo as "Provisioning system\n(NFO in SMO)"
participant pf as "Near-RT RIC platform \n(Operator RA functionality)\n[API service producer]"
participant pki as "Operator PKI\nCA"
xapp <- nfo : 1. Registration information\n[Near-RT RIC Platform\n(Address,Root CA Certificate),\n OAuth 2.0 Access token]
xapp -> pf : 2. TLS (Server side certificate based authentication)
note over xapp
    3. Generate the private/public key pair
    and CSR
endnote
xapp -> pf : 4. Registration request (by xApp instance)\n[OAuth 2.0 access token, xApp Instance CSR]
note over pf
    5. Verify OAuth 2.0 access token
    Generate the xApp ID
    POP (Proof of Possession of Private Key)
    RA policy: Add xApp ID to the request to be in the SAN field of the certificate
endnote
pf -> pki : 6. Request of the certificate by the RA
pf <- pki : 7. Issued certificate \n(embedded xApp ID in SAN)
note over pf
    8. Generate xApp MOI
endnote
```

```
xapp <- pf : 9. Registration Response (for xApp instance)\n[xApp ID, xApp Certificate,  
(service API authentication \nand Authorization information)]  
@enduml
```

Figure 5.1.3.2-1: UML code of security procedure for xApp registration

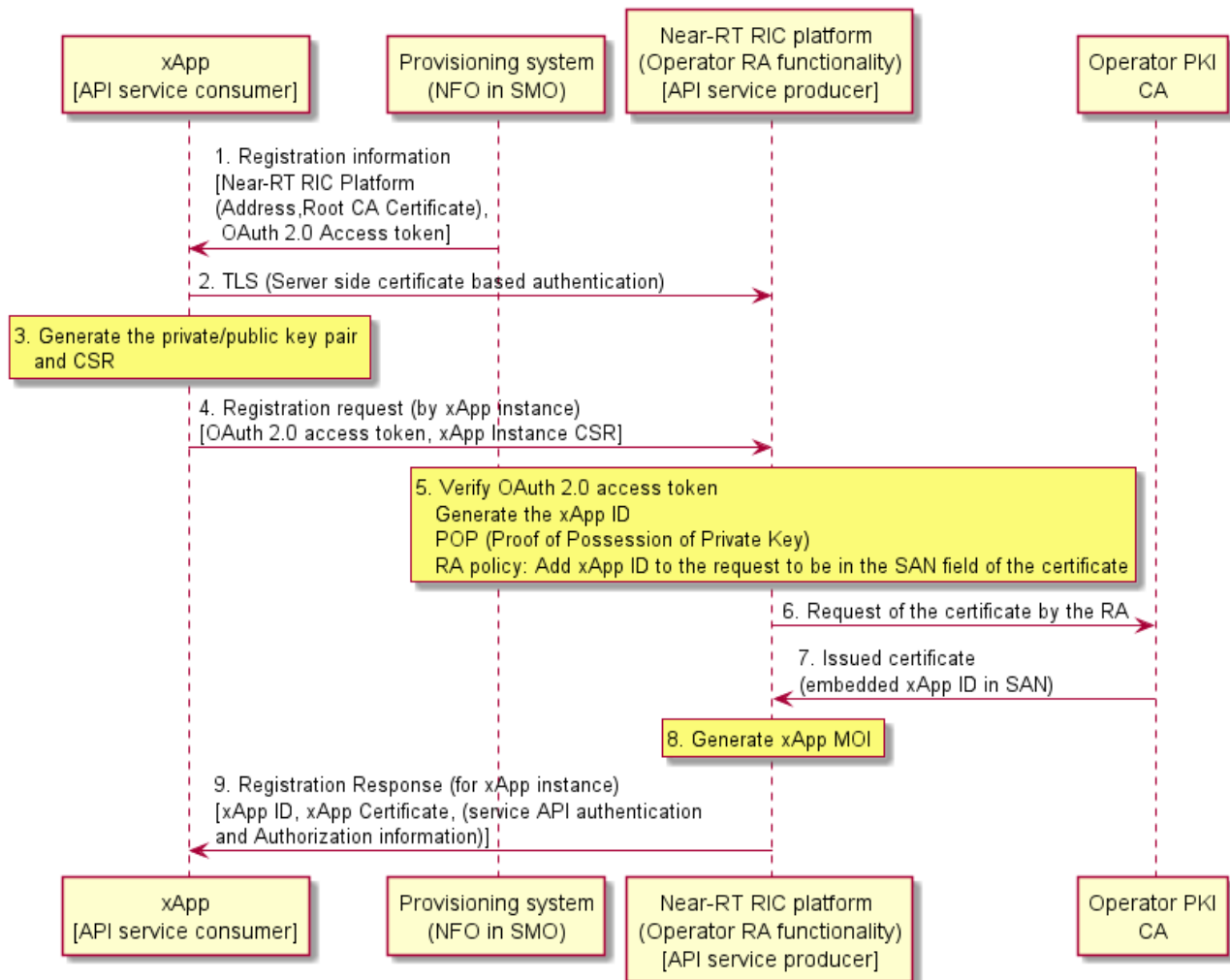


Figure 5.1.3.2-22: Security procedure for xApp registration

1. As a pre-requisite to the registration procedure, the xApp obtains information from a provisioning system (NFO in SMO) during the onboarding/deployment phase in the infrastructure. This information is used to authenticate and establish a secure TLS communication with the Near-RT RIC platform during the registration process. The information includes details of the Near-RT RIC platform (address, Root CA certificate) and includes an initial registration credential.

NOTE 2: An OAuth 2.0 access token is provided as initial registration credential in the example. Other types of credentials in the initial registration can be used.

2. The xApp and Near-RT RIC platform establish a TLS session (server-side certificate authentication) using the information obtained in step 1.

3. The xApp generates the private and public key pair, and CSR (Certificate Signing Request).

NOTE 3: The definition of required and optional fields of the CSR are out of scope of this O-RAN Alliance specification and are determined by vendor implementation in agreement with operator-specific requirements.

4. After successful establishment of the TLS session, the xApp instance sends a registration request message to the Near-RT RIC platform along with the pre-provisioned initial registration credential (OAuth 2.0 token), and the xApp instance CSR message.

5. The Near-RT RIC platform shall validate the initial registration credential, and the Management Function of the platform shall generate an xApp ID for that particular xApp instance. At the reception of the CSR message from the xApp, the Registration Authority (RA), implemented in the Near-RT RIC platform, shall prove that the xApp instance is in possession of the private key. If the proof of possession procedure is positive, the RA shall configure a policy to add the xApp ID in the Subject Alt Name (SAN) field of the certificate request message to be forwarded to the Operator CA to fetch the end entity certificate.

NOTE 3: The RA may use an enrolment protocol to fetch the certificate from the CA. The authentication mechanism between RA and CA are part of the operator PKI implementation.

6. The RA requests the certificate for the xApp instance.

7. Operator CA issues a certificate, embedding the xApp ID in SAN field of the certificate. The issued certificate by the operator CA will be used by the xApp for subsequent authentication and authorization procedures between the xApp and the Near-RT RIC platform when services/resources are consumed by xApps via APIs.

8. The Near-RT RIC platform (Management Function) generates an xApp Managed Object Instance (MOI) as specified in [33], which may contain the mechanism for authentication (mTLS) and authorization (OAuth 2.0) between the xApp and the corresponding module of the Near-RT RIC platform.

9. The Near-RT RIC platform (Management Function) responds with a xApp registration response message. The response shall include the assigned xApp ID, authentication, and authorization mechanism (if provided in step 8) and xApp certificate.

SEC-CTL-NEAR-RT-13: The data type of the xApp ID shall be a string that uniquely identifies the xApp instance. The format of this string shall be a Universally Unique Identifier (UUID) version 4 as described in IETF RFC 9562 [84].

SEC-CTL-NEAR-RT-14: subjectAltName in the xApp instance certificate shall contain a URI-ID with the URI for the xApp ID as an URN; this URI-ID shall contain the xApp ID of the xApp instance using the UUID format as described in IETF RFC 9562 [84].

EXAMPLE 1: urn:uuid:f81d4fae-7dec-11d0-a765-00a0c91e6bf6

SEC-CTL-NEAR-RT-15: The Near-RT RIC shall verify data received through the Y1 interface as follows:

- The data values are valid.
- The data is being received at or below a pre-defined message rate.

EXAMPLE 2: In practice, data value validation verifies that values are within the predefined ranges.

SEC-CTL-NEAR-RT-16: The Near-RT RIC shall log a security event each time an input validation step fails for data received through the Y1 interface.

SEC-CTL-NEAR-RT-17: The Near-RT RIC shall verify data received through the E2 interface as follows:

- The data values are valid.
- The data is being received at or below a pre-defined rate.
- The Near-RT RIC shall log security event(s) if any of the verification steps fail.

EXAMPLE 3: In practice, data value validation verifies that values are within the predefined ranges.

SEC-CTL-NEAR-RT-18: The Near-RT RIC platform shall verify data received from an xApp through E2 related APIs [33] as follows:

- The data values are valid.
- The data is being received at or below a pre-defined rate.
- The Near-RT RIC shall log security event(s) if any of the verification steps fail.

EXAMPLE 4: In practice, data value validation verifies that values are within the predefined ranges.

SEC-CTL-NEAR-RT-19: A Near-Real Time RIC deployed on an O-Cloud shall support the capabilities of the O-Cloud to provide the confidentiality and integrity of data at rest.

SEC-CTL-NEAR-RT-20: A Near-Real Time RIC deployed on an O-Cloud shall support the capabilities of the O-Cloud to provide access control to data.

5.1.4 O-CU-CP/UP

5.1.4.1 Requirements

REQ-SEC-OCU-1: O-CU-CP and O-CU-UP shall meet the security requirements for gNB-CU-CP and gNB-CU-UP respectively, as specified in 3GPP TS 33.501[55].

5.1.4.2 Security Controls

SEC-CTL-OCU-1: O-CU-CP and O-CU-UP shall support the security controls for gNB-CU-CP and gNB-CU-UP respectively, as specified in 3GPP TS 33.501 [55].

5.1.5 O-DU

5.1.5.1 Requirements

REQ-SEC-ODU-1: O-DU shall meet the security requirements for gNB-DU as specified in 3GPP TS 33.501[55].

The security requirements for the Open Fronthaul Interface are specified in clause 5.2.5.

5.1.5.2 Security Controls

SEC-CTL-ODU-1: O-DU shall support the security controls for gNB-DU as specified in 3GPP TS 33.501[55]. The security controls for the Open Fronthaul Interface are specified in clause 5.2.5.

5.1.6 O-RU

5.1.6.1 Requirements

REQ-SEC-ORU-1: O-RU shall meet the security requirements for gNB setup and configuration as specified in 3GPP TS 33.501[55].

REQ-SEC-ORU-2: O-RU shall meet the security requirements for gNB secure environment as specified in 3GPP TS 33.501[55].

The security requirements for the Open Fronthaul Interface are specified in clause 5.2.5.

5.1.6.2 Security Controls

The security controls for the Open Fronthaul Interface are specified in clause 5.2.5.

5.1.7 O-eNB

5.1.7.1 Requirements

REQ-SEC-OeNB-1: O-eNB shall meet the security requirements for eNB as specified in 3GPP TS 33.401[56].

5.1.7.2 Security Controls

SEC-CTL-OeNB-1: O-eNB shall support the security controls for eNB as specified in 3GPP TS 33.401[56].

5.1.8 O-Cloud

5.1.8.1 Generic requirements

5.1.8.1.0 Management Requirements for O-Cloud Platform

Generic requirements for Cloud Platform Management are specified in [8].

5.1.8.1.1 Requirements

REQ-SEC-OCLOUD-1: Management Access to O-Cloud Platform shall be authenticated.

REQ-SEC-OCLOUD-2: Management Access to O-Cloud Platform resources shall be authorized.

REQ-SEC-OCLOUD-3: Means of isolation of control and resources among different subjects accessing the O-Cloud Platform shall be implemented.

REQ-SEC-OCLOUD-4: O-Cloud Platform shall natively support Multi-Factor Authentication (MFA) or a third-party identity provider for secure management access [83].

5.1.8.1.2 Security Controls

SEC-CTL-OCLOUD-1: O-Cloud Platform should support Role-based Access Control (RBAC).

SEC-CTL-OCLOUD-2: Void.

5.1.8.2 Application artifacts verification by the O-Cloud

5.1.8.2.1 Requirements

REQ-SEC-OCLOUD-IMG-1 to 18: Void

REQ-SEC-OCLOUD-PKG-1: Void

REQ-SEC-OCLOUD-PKG-2: The O-Cloud shall support the capability of verifying the signature(s) of any application artifacts.

REQ-SEC-OCLOUD-PKG-3: Void

5.1.8.2.2 Security Controls

SEC-CTL-OCLOUD-IMG-1 to 4: Void

NOTE: For implementation details of REQ-SEC-OCLOUD-PKG-2, refer to SEC-CTL-ALM-PKG-1A.

5.1.8.3 O-Cloud Platform Software Protection

5.1.8.3.0 Introduction

The identified requirements and controls in this clause are enforcing the protection of O-Cloud Platform software during both initial deployment and subsequent updates.

5.1.8.3.1 Requirements

REQ-SEC-OCLOUD-SW-1: The O-Cloud Platform shall have the capability to ensure the integrity and authenticity of O-Cloud software images used during initial deployment and subsequent updates.

REQ-SEC-OCLOUD-SW-2: Void

5.1.8.3.2 Security Controls

SEC-CTL-OCLOUD-SW-1 For all deployments and updates, the O-Cloud shall verify the digital signature associated with the new O-Cloud Platform software before installing the software package. The algorithms, key sizes, and standards used for signature generation and verification shall adhere to the O-RAN Security Protocols Specifications [3], clause 5.

5.1.8.4 O-Cloud Virtualization and Isolation

5.1.8.4.1 Introduction

This clause contains security requirements and controls to mitigate threats to O-Cloud Virtualization layer (Host OS-Hypervisor/Container engine/Cloud platform software components) and provide isolation to the Applications hosted on the O-Cloud.

5.1.8.4.2 Requirements

REQ-SEC-OCLOUD-ISO-1: O-Cloud Platform shall implement means of preventing privilege escalation by VNF/CNFs.

REQ-SEC-OCLOUD-ISO-2: Void

REQ-SEC-OCLOUD-ISO-3: The O-Cloud Platform shall ensure that VNF/CNFs have only the minimum required capabilities and privileges as well as minimum required access to the O-Cloud resources.

REQ-SEC-OCLOUD-ISO-4: The O-Cloud Platform shall ensure strict isolation between VNF/CNFs for data in transit, data in use and data at rest.

REQ-SEC-OCLOUD-ISO-5: Communication between O-Cloud Platform software components shall support confidentiality, integrity, and replay protections for data in transit.

REQ-SEC-OCLOUD-ISO-6: The O-Cloud Platform shall provide the capability to define network policies that restrict ingress and egress traffic and configure rate limiting between VNF/CNFs.

REQ-SEC-OCLOUD-ISO-7: The O-Cloud Platform shall permit only authorized configuration changes for any component of the O-Cloud Platform.

5.1.8.4.3 Security Controls

SEC-CTL-O-CLOUD-ISO-1: For mutual authentication between O-Cloud Platform software components, mTLS with PKI using X.509v3 certificates shall be supported as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-O-CLOUD-ISO-2: For confidentiality and integrity protection of data in transit, O-Cloud Platform software components shall support TLS as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-O-CLOUD-ISO-3: The O-Cloud Platform shall support an access control system to enforce access control policies that align with the principle of least privilege.

5.1.8.5 Secure update

5.1.8.5.0 Introduction

The identified requirements and controls in this clause are enforcing the secure update of O-Cloud Platform software.

5.1.8.5.1 Requirements

REQ-SEC-OCLOUD-SU-1: All software within the O-Cloud Platform shall be kept up to date with the latest security updates for adding additional security protections and correcting vulnerabilities [i.1].

REQ-SEC-OCLOUD-SU-2: Void

REQ-SEC-OCLOUD-SU-3: Void

REQ-SEC-OCLOUD-SU-4: Void

REQ-SEC-OCLOUD-SU-5: In case of an incomplete update, or incident during the installation process, the O-Cloud Platform shall remain in its last working state.

REQ-SEC-OCLOUD-SU-6: The O-Cloud Platform shall prevent the unauthorized rollback of its software to an earlier version.

REQ-SEC-OCLOUD-SU-7: The update of O-Cloud Platform software should be completed with minimal disruption and downtime.

5.1.8.5.2 Security Controls

SEC-CTL-OCLOUD-SU-1: Void

SEC-CTL-OCLOUD-SU-2: Void

SEC-CTL-OCLOUD-SU-3: Void

SEC-CTL-OCLOUD-SU-4: The O-Cloud Platform shall support the capability to detect and retrieve the latest security updates of the O-Cloud Platform software.

NOTE: O-Cloud Platform software components can be consistently updated with the latest security patches for enhanced protection and vulnerability mitigation. The operation of this system can be automated.

SEC-CTL-OCLOUD-SU-5: The O-Cloud Platform shall possess the capability to securely log and control software versions, thereby preventing unauthorized rollbacks to older, less secure software versions.

SEC-CTL-OCLOUD-SU-6: The O-Cloud Platform should possess the capability to revert an O-Cloud Platform software component to its previous stable version in the event of an incomplete update or installation incident, ensuring operational continuity.

SEC-CTL-OCLOUD-SU-7: The O-Cloud Platform should be designed for redundancy and high availability, to maintain uninterrupted service during both the update process and in scenarios of unexpected update failures.

5.1.8.6 Secure Protection of cryptographic keys and sensitive data

5.1.8.6.1 Requirements

REQ-SEC-OCLOUD-SS-1: O-Cloud Platform shall support confidentiality and integrity protection for sensitive data at rest, in use and in transit.

REQ-SEC-OCLOUD-SS-2: The O-Cloud Platform shall support a secure deletion method from both active and backup storage medias during operation.

REQ-SEC-OCLOUD-SS-3: The O-Cloud Platform shall ensure that any data contained in a resource is not available when the resource is de-allocated from one VM/Container and reallocated to a different VM/Container.

NOTE 1: This requirement requires protection for any data contained in a resource that has been logically deleted or released but may still be present within the resource which in turn may be re-allocated to another VM/Container.

REQ-SEC-OCLOUD-SS-4: The O-Cloud Platform shall have the capability that allows an Application to securely erase sensitive data owned by the Application.

EXAMPLE: Sensitive data includes, but is not limited to, cryptographic keys, personally identifiable information (PII), credentials, tokens, and configuration data.

REQ-SEC-OCLOUD-SS-5: The secure deletion method should activate automatically during the boot process after a power outage to prevent unauthorized access to any residual data from all volatile memories, including RAM and cache.

NOTE 2: Data may linger in volatile memory for a short period after power is lost, potentially allowing for data recovery through cold boot attacks if the system is quickly powered back on.

See Annex C for the guidance to implement REQ-SEC-OCLOUD-SS-5.

REQ-SEC-OCLOUD-SS-6: The O-Cloud Platform shall support the capabilities that allow an application to authenticate and authorize access to all data owned by the application.

5.1.8.6.2 Security Controls

SEC-CTL-OCLOUD-SS-1: The O-Cloud Platform shall support encryption of data at rest as specified in O-RAN Security Protocols Specifications [3], clause 5.

SEC-CTL-OCLOUD-SS-2: The O-Cloud Platform shall support the capability for secure deletion of data in addressable memory locations that are no longer in use due to reallocation.

NOTE 1: This includes the ability to overwrite these locations with specific binary patterns, such as zeroes, ones, or a random bit pattern.

See Annex C for the guidance to implement these controls.

SEC-CTL-OCLOUD-SS-3: Media containing sensitive information shall be sanitized using media-specific techniques.

NOTE 2: Sanitization of media containing sensitive information is performed in the following scenarios:

- At decommissioning: When the hardware or media is retired, replaced, or disposed of.
- At reassignment: Before assigning the media to a different tenant or use case, ensuring no residual data is accessible to the new owner or process.
- End of retention period: When the retention period for sensitive information expires, as defined by applicable data retention policies.

- Incident response scenarios: If a security incident requires the immediate destruction or sanitization of sensitive information to prevent compromise or misuse.

5.1.8.7 Chain of Trust

5.1.8.7.1 Requirements

REQ-SEC-OCLOUD-COT-1: The O-Cloud platform shall support a root of trust that verifies the integrity of every relevant component in the O-Cloud platform.

NOTE 1: See [i.1] and [i.2] for more information on the root of trust.

REQ-SEC-OCLOUD-COT-2: It shall be possible to attest an O-RAN Application through the full attestation chain from the hardware layer through the virtualization layer to the O-RAN Application layer.

NOTE 2: See [i.15] and [i.28] for more information on the attestation chain.

REQ-SEC-OCLOUD-COT-3: The O-Cloud shall support X.509v3 certificates issued by the Service Provider CA for the O2 interface [6].

REQ-SEC-OCLOUD-COT-4: The O-Cloud shall support management of the certificates signed by the Service Provider PKI for the O2 interface through a certificate management protocol.

5.1.8.7.2 Security Controls

SEC-CTL-OCLOUD-COT-1: The chain of trust shall be built from measurements stored in a hardware root of trust.

SEC-CTL-OCLOUD-COT-2: The chain of trust shall be built from measurements stored in a software root of trust for scenarios where a hardware root of trust is not feasible or available.

SEC-CTL-OCLOUD-COT-3: A remote attestation service (AS) should be supported for providing additional benefits beside verifying O-Cloud platform integrity by CoT. The remote AS should collect O-Cloud platform configurations and integrity measurements from data center servers at an O-Cloud service provider via a trust agent service running on the O-Cloud platform servers [i.7]. The O-Cloud service provider is responsible for defining allowlisted trust policies. These policies should include information and expected measurements for desired platform CoT technologies. The collected data is compared and verified against the policies, and a report is generated to record the relevant trust information in the AS database [i.7]. The remote AS should be extended to include O-RAN Applications integrity.

See Annex C for the guidance to implement these controls.

5.1.8.8 AAL

There are two different scenarios of deployment of the hardware accelerator manager:

- Scenario 1: the hardware accelerator manager is a SW component part of the O-Cloud platform and outside the hardware accelerator device. It is linked to the hardware accelerator device via a vendor specific interface.
- Scenario 2: The hardware accelerator manager is part of the hardware accelerator device. In this scenario, the vendor specific interface does not exist.

For both scenarios, AALI-C-Mgmt interface is the same between the hardware accelerator manager and the O-Cloud IMS/DMS.

AAL components are parts of the O-Cloud platform, therefore the O-Cloud security requirements and controls on image protection, secure update, isolation, secure storage, and chain of trust shall apply to AAL components, see clause 5.1.8.

5.1.8.8.1 Requirements and Security Controls on AAL interfaces

5.1.8.8.1.1 AALI-C-Mgmt

5.1.8.8.1.1.1 Requirements

REQ-SEC-AALI-C-Mgmt-1: The hardware accelerator manager shall authenticate O-Cloud IMS/DMS when O-Cloud IMS/DMS initiates a communication to the hardware accelerator manager over AALI-C-Mgmt interface.

REQ-SEC-AALI-C-Mgmt-2: The hardware accelerator manager shall check whether O-Cloud IMS/DMS is authorized when O-Cloud IMS/DMS accesses the hardware accelerator manager.

REQ-SEC-AALI-C-Mgmt-3: AALI-C-Mgmt interface shall support confidentiality, integrity, and replay protection between the hardware accelerator manager and O-Cloud IMS/DMS.

5.1.8.8.1.1.2 Security Controls

SEC-CTL-AALI-C-Mgmt-1: AALI-C-Mgmt interface shall support TLS as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-AALI-C-Mgmt-2: For mutual authentication between the hardware accelerator manager and O-Cloud IMS/DMS, AALI-C-Mgmt interface shall support mTLS with PKI using X.509v3 certificates as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-AALI-C-Mgmt-3: AALI-C-Mgmt interface shall support authorization using OAuth 2.0, as specified in O-RAN Security Protocols Specifications [3], clause 4.7.

5.1.8.8.1.2 Vendor specific interface

5.1.8.8.1.2.1 Requirements

The following requirements apply only for Scenario 1.

REQ-SEC-AAL-VS-1: The hardware accelerator device shall authenticate the hardware accelerator manager when the hardware accelerator manager initiates a communication to the hardware accelerator device over the vendor specific interface.

REQ-SEC-AAL-VS-2: The hardware accelerator manager shall check whether the hardware accelerator device is authorized when the hardware accelerator manager accesses the hardware accelerator device.

REQ-SEC-AAL-VS-3: The vendor specific interface shall support integrity between the hardware accelerator manager and the hardware accelerator device.

REQ-SEC-AAL-VS-4: The vendor specific interface may support confidentiality between the hardware accelerator manager and the hardware accelerator device.

REQ-SEC-AAL-VS-5: The vendor specific interface may support replay protection between the hardware accelerator manager and the hardware accelerator device.

5.1.8.8.2 Specific Requirements and Security Controls on AAL components

5.1.8.8.2.1 Requirements

REQ-SEC-AAL-1: The hardware accelerator device shall provide the capability for memory to be cleared securely prior to allocation or when indicated by the AAL Application on returning the memory.

REQ-SEC-AAL-2: The AAL Implementation shall clear memory prior to allocation or when indicated by the AAL Application on returning the memory.

REQ-SEC-AAL-3: The hardware accelerator device shall have a unique identity for a proper identification and tracking of the hardware accelerator device by the hardware acceleration manager.

NOTE: This requirement allows the O-Cloud platform for proper identification and tracking of the accelerator, as well as ensuring that it is not tampered with or replaced without proper authorization.

REQ-SEC-AAL-4: Hardware accelerators should be procured from vendors who can demonstrate the security of their supply chain and manufacturing processes (supply chain security).

REQ-SEC-AAL-5: The hardware accelerator device shall provide the capability for fine grained memory access control. An AAL Application or AAL Profile Instance access shall be restricted to only given buffer(s), and access requests outside that buffer(s) shall fail.

REQ-SEC-AAL-6: The Hardware accelerator manager shall log security events to track and monitor any potential security incidents and to ensure accountability. Such security events include:

- Hardware accelerator failures.
- Hardware accelerator configuration changes.
- Hardware accelerator software update and boot process.
- Hardware accelerator access attempts by unauthorized users/systems, network connectivity issues, successful authentication/authorization events.
- Hardware accelerator performance issues or degradation.

5.1.8.8.2.2 Security Controls

SEC-CTL-AAL-1: The clear memory mechanism should involve overwriting data that was previously stored in the memory with a known pattern, such as all zeros or a random value, to memory buffers.

SEC-CTL-AAL-2: Supply chain audit of hardware accelerator vendors should be performed for establishing trust in vendor's supply chain management based on evidence presented.

NOTE: The evidence can be of different forms and some of them are described below.

- Process to identify and map the hardware accelerator components of each hardware accelerator to the sourcing information.
- A repeatable process of procuring components for building hardware accelerator.
- Ability and procedures to detect counterfeit hardware components.
- Procedures with strict access control measures for hardware accelerator inventory storage, transport, and distribution.

5.1.8.9 O2dms/O2ims/O-Cloud Notification APIs

5.1.8.9.1 Requirements

5.1.8.9.1.1 O2dms

REQ-SEC-OCLOUD-O2dms-1: O-Cloud DMS shall authenticate SMO (NFO or any other entity using O2dms services) when SMO initiates a communication to O-Cloud for the deployment and management of Applications over O2 interface.

REQ-SEC-OCLOUD-O2dms-2: O-Cloud DMS shall be able to establish securely protected connection in terms of confidentiality, integrity, and replay with the SMO (NFO or any other entity using O2dms services) over the O2 interface.

REQ-SEC-OCLOUD-O2dms-3: O-Cloud DMS shall check whether SMO (NFO or any other entity using O2dms services) has been authorized when SMO access O-Cloud for the deployment and management of Applications.

REQ-SEC-OCLOUD-O2dms-4: O-Cloud DMS shall log SMO's management operations for auditing.

5.1.8.9.1.2 O2ims

REQ-SEC-OCLOUD-O2ims-1: O-Cloud IMS shall authenticate SMO (FOCOM or any other entity using O2ims services) when SMO initiates a communication to O-Cloud for the management of infrastructure over O2 interface.

REQ-SEC-OCLOUD-O2ims-2: O-Cloud IMS shall be able to establish securely protected connection in terms of confidentiality, integrity, and replay with the SMO (FOCOM or any other entity using O2ims services) over the O2 interface.

REQ-SEC-OCLOUD-O2ims-3: O-Cloud IMS shall check whether SMO (FOCOM or any other entity using O2ims services) has been authorized when SMO access the O-Cloud infrastructure.

REQ-SEC-OCLOUD-O2ims-4: O-Cloud IMS shall log SMO's management operations for auditing.

5.1.8.9.1.3 O-Cloud Notification API

REQ-SEC-O-CLOUD-NotifAPI-1: The communication between Applications and the O-Cloud platform through the O-Cloud Notification API shall be mutually authenticated.

REQ-SEC-O-CLOUD-NotifAPI-2: The O-Cloud platform shall provide an authorization framework for the consumption of the services exposed in the O-Cloud Notification API by Applications.

5.1.8.9.2 Security Controls

SEC-CTL-O-CLOUD-INTERFACE-1: For the security protection at the transport layer on O2 interface, TLS shall be supported, as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-O-CLOUD-INTERFACE-2: For the authorization of O2 RESTful and O-Cloud Notification APIs requests and notifications, OAuth 2.0 shall be supported, as specified in O-RAN Security Protocols Specifications [3], clause 4.7.

NOTE: In the actual context of O-Cloud, the platform as API producer is responsible to specify those rights/privileges for the platform services as resources to Applications as consumers. As a guideline, an Application should only have the required set of permissions to perform the actions for which they are authorized, and no more.

Authorization mechanisms are enforced by the O-Cloud platform for subscriptions to events/status from the O-Cloud.

SEC-CTL-O-CLOUD-INTERFACE-3: For the mutual authentication between O-Cloud platform and Applications, and between O-Cloud platform and SMO, O2 interface and O-Cloud Notification APIs shall support mutual TLS (mTLS) authentication via X.509v3 certificates, as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

5.1.8.10 O-Cloud secure environment

5.1.8.10.1 Introduction

This clause contains security requirements and controls on the O-Cloud secure environment to protect sensitive data.

5.1.8.10.2 Requirements

REQ-SEC-O-CLOUD-HW-1: Void

REQ-SEC-O-CLOUD-SE-1: O-Cloud secure environment shall include measures to counteract unauthorized extraction or inference of sensitive information using physical methods.

REQ-SEC-O-CLOUD-SE-2: O-Cloud secure environment shall include measures to counteract side-channel attacks and prevent unauthorized inference of sensitive information.

NOTE:

- REQ-SEC-O-CLOUD-SE-1 addresses direct physical attacks that require physical access to the O-Cloud secure environment. This involves tampering, probing, or other forms of physical interference.
- REQ-SEC-O-CLOUD-SE-2 focuses on side-channel attacks, which exploit indirect information leakage without requiring physical access. This involves analysing timing, power consumption, or electromagnetic (EM) emissions.

5.1.8.10.3 Security Controls

SEC-CTL-O-CLOUD-HW-1: Void

5.1.8.11 Identifiers in O-Cloud

5.1.8.11.0 Introduction

The following set of requirements and controls outlines the essential criteria concerning identifiers used in O-Cloud . Identifiers can be used to uniquely identify and manage various components, including VMs, pods, containers, nodes, and compute pools within the O-Cloud platform. Safeguarding its global uniqueness, preserving its confidentiality and integrity, and controlling its accessibility are crucial to prevent conflicts, unauthorized access, and potential system compromises.

5.1.8.11.1 Requirements

REQ-SEC-OCLOUD-INST-ID-1: Identifiers used in O-Cloud shall be unique within the O-Cloud Platform to prevent conflicts and ensure accurate identification.

REQ-SEC-OCLOUD-INST-ID-2: The O-Cloud Platform shall support authentication and authorization with the principle of least privilege to prevent unauthorized exposure of identifiers used on O-Cloud interfaces, APIs, or logs.

REQ-SEC-OCLOUD-INST-ID-3: Identifiers used in O-Cloud shall be protected to ensure confidentiality and integrity, both during storage (at rest) and while being transmitted (in transit).

REQ-SEC-OCLOUD-INST-ID-4: Identifiers used in O-Cloud shall be subject to auditing and monitoring, with detailed logs maintained to track activities related to the instance's creation, usage, modification, and deletion.

REQ-SEC-OCLOUD-INST-ID-5: Identifiers used in O-Cloud shall be associated with a single component, be it a VM, container, pod, node, or compute pool, to ensure clear resource ownership, traceability, and accountability.

5.1.8.11.2 Security Controls

SEC-CTL-OCLOUD-INST-ID-1: Identifiers used in O-Cloud shall be generated using strong randomization methods as defined in O-RAN Security Protocols Specifications [3], Table 5-1 ('RNG' entry).

EXAMPLE: Implementation (Kubernetes-specific)

Kubernetes generates unique instance IDs, called Pod names, by combining factors like pseudorandom number generators (PRNGs) and contextual information. PRNGs use an initial seed and deterministic algorithms to produce random-like numbers. These numbers, along with contextual elements like timestamps and namespace identifiers, form the basis of the Pod names. This approach ensures that generated names are non-guessable, unpredictable, and unlikely to collide within the Kubernetes cluster. The combination of PRNGs, randomization, and context guarantees that instance IDs are secure, unique, and suitable for identifying pods within the system.

SEC-CTL-OCLOUD-INST-ID-2: O-Cloud should validate newly generated identifiers against existing identifiers to guarantee uniqueness before finalizing instance creation.

SEC-CTL-OCLOUD-INST-ID-3: Identifiers used in O-Cloud shall be protected using encryption, as specified in Clause 5 of O-RAN Security Protocols Specifications [3], to ensure confidentiality during storage.

SEC-CTL-OCLOUD-INST-ID-4: Identifiers used in O-Cloud shall be protected during transmission using TLS, as defined in Clause 4.2 of O-RAN Security Protocols Specifications [3].

5.1.8.12 Time Synchronization and Consistency Requirements for O-Cloud

5.1.8.12.0 Introduction

The requirements listed below highlight the O-Cloud's focus on creating a secure time synchronization framework. By ensuring each node of the O-Cloud connects to a trusted and authenticated time source, O-Cloud aims to enhance its defences against threats such as clock manipulation, data inconsistencies and operational disruptions.

5.1.8.12.1 Requirements

REQ-SEC-OCLOUD-TS-1: All O-Cloud Nodes shall be configured to connect to a secure and authenticated time synchronization server for ToD synchronization.

REQ-SEC-OCLOUD-TS-2: The O-Cloud shall be configured such that ToD synchronization is maintained across all nodes in an O-Cloud Node Cluster, there by guaranteeing uniform time references for all applications hosted on these nodes.

REQ-SEC-OCLOUD-TS-3: The O-Cloud shall guarantee that the timestamp consistency is preserved even when applications are relocated across different nodes of the O-Cloud infrastructure.

NOTE 1: Timestamp refers to:

1. **Log/event timestamps:** These are associated with each log entry generated. Examples include application start/stop, application relocation, node failures, network events, change in applications and O-Cloud configuration, resource allocation, deallocation, etc.
2. **Data Transaction timestamps:** For applications that rely on time-sensitive data within O-Cloud, consistent timestamps are crucial. Whenever data is read, written, or modified, a timestamp is generated to ensure both data integrity and consistency across nodes.

REQ-SEC-OCLOUD-TS-4: The O-Cloud shall guarantee that various instances of an identical application, irrespective of their location, generate logs with consistent timestamps.

NOTE 2: Within the O-Cloud infrastructure, a "consistent timestamp" denotes the synchronized and uniform chronological markers generated by various instances of an identical application, irrespective of their location. This uniformity ensures that aggregated or analysed logs from different instances present a coherent chronological sequence, aiding in precise event correlation and analysis. To achieve and maintain this consistency, it's recommended for O-Cloud to synchronize its internal clocks with trusted time sources, such as NTP servers, guaranteeing both the accuracy and trustworthiness of these timestamps.

REQ-SEC-OCLOUD-TS-5: All O-Cloud Nodes within a compute pool, especially those serving a specific geographic region or co-located, shall be configured to operate using a consistent time reference, preferably UTC with a Time Zone (TZ) modifier.

NOTE 3: This requirement ensures:

1. **Uniformity in Time-Related Operations:** Simplifies the process of correlating logs, events, and time-sensitive operations across nodes, aiding in quicker identification of anomalies or malicious activities.
2. **Operational Consistency:** Ensures that scheduled tasks, backups, updates, or maintenance activities are executed consistently across the compute pool.
3. **Data Integrity:** Provides consistency for applications and databases that rely on timestamps for transactions, ensuring no discrepancies due to time differences.

5.1.8.12.2 Security Controls

SEC-CTL-OCLOUD-TS-1: Void

SEC-CTL-OCLOUD-TS-2: Void

SEC-CTL-OCLOUD-TS-3: The O-Cloud should establish multiple time servers for redundancy. This ensures that nodes can switch to an alternative trusted server if the primary server becomes unavailable, thereby maintaining consistent time synchronization.

NOTE: See clause 5.3.8.9.2 for additional security controls.

5.1.8.13 Security policies enforcement

5.1.8.13.1 Introduction

The following security requirements apply to the O-Cloud to enforce security policies that may be defined in deployment descriptors.

The activation or deactivation of these security policies is operator dependent, making their support mandatory but their use optional depending on operational needs.

5.1.8.13.2 Requirements

REQ-SEC-OCLOUD-SECPOL-1: The O-Cloud Platform should verify that the source of any container or VM image is trusted before deployment.

REQ-SEC-OCLOUD-SECPOL-2: The O-Cloud Platform should enforce resource quotas and limits by ensuring that the specified quotas and limits in the deployment descriptor are applied and maintained at each container or VM level.

REQ-SEC-OCLOUD-SECPOL-3: The O-Cloud Platform should ensure that containers and VMs run with restricted privileges, preventing any processes from having elevated privileges unless explicitly required and approved.

REQ-SEC-OCLOUD-SECPOL-4: The O-Cloud Platform should allow only approved storage resource types to be mounted for containers and VMs.

NOTE 1: In the context of containers, storage resources refer to volumes. In the context of VMs, storage resources refer to disks or storage drives.

REQ-SEC-OCLOUD-SECPOL-5: The O-Cloud Platform should enforce that containers and VMs use a read-only root file system, preventing modifications to critical system files during runtime.

REQ-SEC-OCLOUD-SECPOL-6: The O-Cloud Platform should enforce immutability by ensuring that containers and VMs are always deployed using the latest verified images from trusted image repositories, preventing the reuse of cached images on nodes.

REQ-SEC-OCLOUD-SECPOL-7: The O-Cloud Platform should enforce defined network policies to manage and control ingress and egress traffic, ensuring that only authorized traffic is permitted within and across the O-Cloud infrastructure.

REQ-SEC-OCLOUD-SECPOL-8: The O-Cloud Platform should enforce workload placement policies.

NOTE 1:

- For containers, this can be achieved using taint and toleration policies.
- For VMs, this can be enforced through resource scheduling policies or affinity/anti-affinity rules.

EXAMPLE: This requirement could, for instance, ensure that an O-DU is scheduled on a node that supports the required AAL, or that O-DU is deployed on a node equipped with a TPM for secure operations.

NOTE 2: The implementation of security policies depends on the underlying technology, whether it involves containerization or virtualization. Guidance for implementing these security policies using Kubernetes admission controllers is provided in Annex C.1.3, based on Kubernetes and OpenShift documentation [i.21], [i.22].

5.1.9 Shared O-RU

5.1.9.0 Introduction

Shared O-RU security requirements are consistent with O-RU security requirements in clause 5.1.6 and applicable in a Shared O-RU configuration, which introduces additional security requirements.

5.1.9.1 Security Requirements

REQ-SEC-SharedORU-1: The Shared O-RU shall mutually authenticate with an O-RU Controller.

REQ-SEC-SharedORU-2: The Shared O-RU shall provide least privilege access to each SRO based upon its sro-id.

REQ-SEC-SharedORU-3: The Shared O-RU shall provide separate confidentiality and integrity protection of data-at-rest for the SOH and each SRO.

REQ-SEC-SharedORU-4: The Shared O-RU shall provide separate confidentiality, integrity, and replay protection for data-in-transit for the SOH and each SRO.

REQ-SEC-SharedORU-5: Void

REQ-SEC-SharedORU-6: Void

REQ-SEC-SharedORU-7: The Shared O-RU shall be able to recover, without catastrophic failure, from a volumetric DDoS attack due to misbehavior or malicious intent.

REQ-SEC-SharedORU-8: The Shared O-RU shall support event logging with tenant-awareness.

REQ-SEC-SharedORU-9: The Shared O-RU should support confidentiality, integrity, and replay protection for the CUS-Plane data on the Open Fronthaul interface.

5.1.9.2 Security Controls

SEC-CTL-SharedORU-1: The Shared O-RU shall support mTLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2, with PKI using X.509v3 certificates for mutual authentication on the M-Plane interface with an O-RU Controller.

SEC-CTL-SharedORU-2: The Shared Operator Host O-RU Controller shall be able to disable password-based authentication on the Shared O-RU.

SEC-CTL-SharedORU-3: The Shared O-RU shall support NACM for permitting or denying access to an SRO.

SEC-CTL-SharedORU-4: The Shared O-RU shall support TLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2, for confidentiality and integrity protection of data-in-transit on the M-Plane interface with an O-RU Controller.

SEC-CTL-SharedORU-5: The Shared O-RU should support MACsec, as specified in clause 5.2.5.6, for confidentiality, integrity, and replay protection of CUS-Plane data on the Open FH interface.

5.2 Interfaces maintained by O-RAN

5.2.1 A1 Interface

5.2.1.0 Introduction

The A1 Interface is defined in the A1 specifications [5].

5.2.1.1 Requirements

REQ-SEC-A1-1: A1 interface shall support confidentiality, integrity, replay protection.

REQ-SEC-A1-2: A1 interface shall support mutual authentication.

REQ-SEC-A1-3: A1 interface shall support authorization with the principle of least privilege.

5.2.1.2 Security Controls

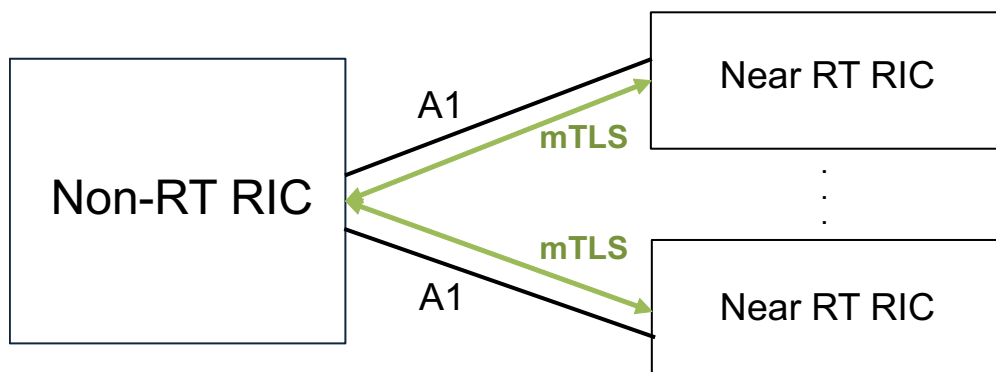


Figure 5.2.1.2-1: mTLS on A1 interface

SEC-CTL-A1-1: For the security protection at the transport layer on A1 interface, TLS shall be supported, as specified in O-RAN Security Protocols Specifications [3] clause 4.2.

SEC-CTL-A1-2: For the mutual authentication of the Non-RT RIC and one or more Near-RT RICs, the A1 interface shall support mTLS with PKI using X.509v3 certificates, as shown in Figure 5.2.1.2-1 and specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-A1-3: The A1 interface shall support authorization using OAuth 2.0, as specified in O-RAN Security Protocols Specifications [3], clause 4.7.

5.2.2 O1 Interface

5.2.2.0 Introduction

O1 interface connects the SMO to each NF.

5.2.2.1 Requirements

REQ-SEC-O1-1: O1 interface shall support confidentiality, integrity, and replay protection.

REQ-SEC-O1-2: O1 interface shall support mutual authentication.

REQ-SEC-O1-3: O1 interface shall support authorization using the principle of least privilege.

REQ-SEC-O1-4: O1 interface shall support secure file transfer.

5.2.2.1.1 Summary

Void

5.2.2.1.2 Confidentiality, Integrity and Authenticity

REQ-TLS-FUN-1: Void

REQ-TLS-FUN-2: Void.

REQ-TLS-FUN-3: Void

REQ-TLS-FUN-4: Void

5.2.2.1.3 Least Privilege Access Control

Void

5.2.2.2 Security Controls

SEC-CTL-O1-1: O1 interface shall support confidentiality and integrity protection using TLS, as specified in O-RAN Security Protocols Specifications [3] clause 4.2.

SEC-CTL-O1-2: O1 interface shall support mutual authentication using mTLS with X.509 certificates, as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-O1-3: O1 producers and consumers that use NETCONF shall support authorization and least privilege using NACM, as specified in clause 5.2.2.3.

SEC-CTL-O1-4: The O1 interface in a Shared O-RU configuration shall support confidentiality and integrity protection using TLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-O1-5: The O1 interface in a Shared O-RU configuration shall support mutual authentication using mTLS , as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-O1-6: O1 interface may support confidentiality and integrity protection using SSH, as specified in O-RAN Security Protocols Specifications [3] clause 4.1.

SEC-CTL-O1-7: O1 interface shall support secure file transfer using FTPES, as specified in O-RAN Security Protocols Specifications [3], clause 6.3.

SEC-CTL-01-8: O1 interface may support secure file transfer using SFTP, as specified in O-RAN Security Protocols Specifications [3], clause 6.2.

SEC-CTL-01-9: O1 interface may support secure file transfer using HTTPS, as specified in O-RAN Security Protocols Specifications [3], clause 6.4.

5.2.2.3 Configuration Requirements for Least Privilege Access

REQ-NAC-FUN-1: O1 producers and consumers that use NETCONF shall support the NETCONF Access Control Model (NACM) as specified in RFC 8341 [10] to restrict NETCONF protocol access for users to a preconfigured subset of available NETCONF protocol operations and content.

REQ-NAC-FUN-2: The NETCONF implementation for O1 shall set the default values of the NACM Global Enforcement Controls as described in Table 5.2.2.3-1

Table 5.2.2.3-1: Default values of the NACM Global Enforcement

Parameter	Value
enable-nacm	true
read-default	deny
write-default	deny
exec-default	deny
enable-external-groups	true

REQ-NAC-FUN-3: Management Service providers that support NETCONF on the O1 interface shall support the following pre-defined groups in NACM to restrict NETCONF protocol access for users.

- **O1_nacm_management:** Allows changes to the /nacm objects which includes the NACM Global Enforcement Controls. Allowing changes to the NACM Global Enforcement Controls configuration is optional.
- **O1_user_management:** Allows assignment and deletion of users and assignment of users to roles on the O1 node.
 - **Mandatory** if the network device supports a local user store.
 - **Not provided** if the network device does not support a local user store and requires all user/role information to be provided by an external authentication/authorization service.

NOTE: Handling of password policies and LDAP attributes are not part of this role.

- **O1_network_management:** Allows read, write, and execute operations on the datastores. All operations on the /nacm objects are prohibited.
- **O1_network_monitoring:** Allows read operations on configuration data in the datastore, except for the /nacm objects.
- **O1_software_management:** Allows installation of new software including new software versions for a PNF.

REQ-NAC-FUN-4: Users assigned to the O1_nacm_management group shall have read and write permission for the /nacm objects and attributes. Allowing changes to the NACM Global Enforcement Controls configuration is optional.

REQ-NAC-FUN-5: Users assigned to the O1_user_management group shall have read and write permissions for the locally defined user store objects and attributes.

REQ-NAC-FUN-6: Users assigned to the O1_network_management group shall have read, write, and execute permissions for the datastores. Users assigned to the O1_network_management group shall not have any permissions for the /nacm objects.

REQ-NAC-FUN-7: Users assigned to the O1_network_monitoring group shall have read permissions for the datastores. Users assigned to the O1_network_monitoring group shall not have read permissions for the /nacm objects.

REQ-NAC-FUN-8: Users assigned to the O1_software_management group shall have permissions to install new software on the PNF.

REQ-NAC-FUN-9: O1 NETCONF endpoints shall support external user-to-group mapping via LDAP with StartTLS.

REQ-NAC-FUN-10: O1 Management Service providers may allow the definition of users in the <groups> NACM object.

REQ-NAC-FUN-11: O1 NETCONF endpoints may support external user to group mapping via OAuth 2.0, RADIUS with EAP, and TACACS+.

5.2.3 O2 Interface

5.2.3.0 Introduction

General Aspects and Principles of O2 Interface between the SMO and the O-Cloud are defined in [6].

5.2.3.1 Requirements

REQ-SEC-O2-1: O2 interface shall support confidentiality, integrity, and replay protection.

REQ-SEC-O2-2: O2 interface shall support mutual authentication.

REQ-SEC-O2-3: O2 interface shall support authorization using the principle of least privilege.

5.2.3.2 Security Controls

SEC-CTL-O2-1: O2 interface shall support confidentiality and integrity protection using TLS, as specified in O-RAN Security Protocols Specifications [3] clause 4.2.

SEC-CTL-O2-2: O2 interface, as shown in Figure 5.2.3.2-1, shall support mutual authentication using mTLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-O2-3: O2 interface, as shown in Figure 5.2.3.2-1, shall support authorization using OAuth 2.0, as specified in O-RAN Security Protocols Specifications [3], clause 4.7.

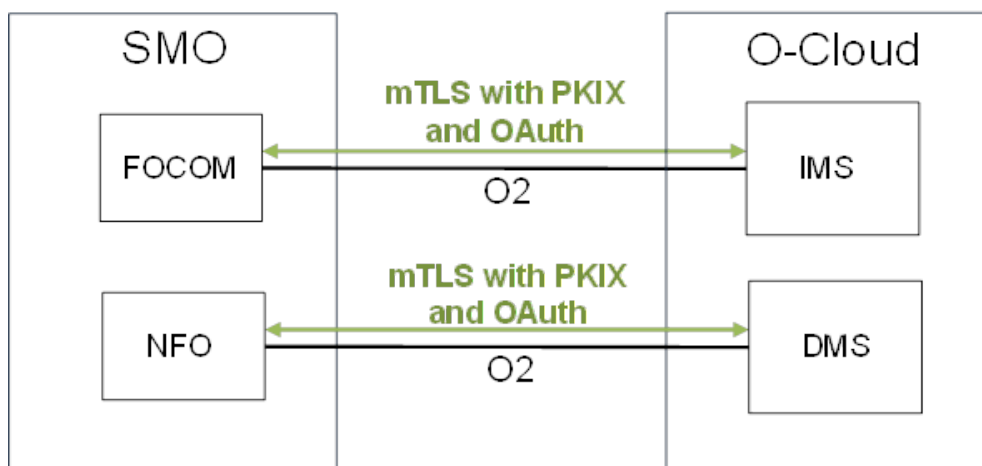


Figure 5.2.3.2-1: O2 interface security

5.2.4 E2 Interface

5.2.4.0 Introduction

General Aspects and Principles of E2 Interface connecting the Near-RT RIC and one or more O-CU-CPs, one or more O-CU-UPs, one or more O-DUs, and one or more O-eNBs are defined in [7].

5.2.4.1 Requirements

REQ-SEC-E2-1: E2 interface shall support confidentiality, integrity, replay protection and data origin authentication.

5.2.4.2 Security Controls

SEC-CTL-E2-1: For the security protection at the IP layer on E2 interface, IPsec shall be supported as specified in O-RAN Security Protocols Specifications [3], clause 4.5.

5.2.5 Open Fronthaul Interface

5.2.5.1 C-plane

5.2.5.1.1 Introduction

The O-DU sends UL C-plane messages and DL C-plane messages to O-RU to trigger transmission and reception of RF signals. The DL C-plane message describing multiple symbols must arrive at O-RU within a certain time window for the O-RU to successfully receive DL I/Q data in U-plane messages from O-DU. Likewise, the UL C-plane message describing multiple symbols must arrive within a certain time window for the O-RU to successfully receive RF signal and send UL I/Q data in U-plane messages to O-DU. Any delay of these messages would cause the O-RU to drop/discard U-plane traffic from O-DU and the UE [31].

An adversary can inject its own DL C-plane or UL C-plane messages by spoofing the associated O-DU. As a result, it would block the O-RU from processing the corresponding U-Plane packets received from the O-DU and O-RU respectively, leading to temporary DoS and, limited cell performance on cells served by the O-RU [4]. Additionally, it may tamper with Downlink (DL) C-Plane messages to exploit possible vulnerabilities in the C-Plane protocol or C-Plane endpoint implementation. This can cause an active cell to become a sleeping cell, leading to cell unavailability and a temporary Denial-of-Service (DoS).

Attackers may overwhelm a target system's network bandwidth or computing resources by flooding it with a massive volume of traffic known as volumetric Denial-of-Service (DoS) attack causing Bandwidth Exhaustion, Network Consumption, and Resource Consumption.

An adversary can engage in passive monitoring to monitor the beamforming information for reconnaissance purposes. The flow indicator (eAxCID) in clear text allows an attacker to target a user at a specific location, potentially planning attacks based on the user's known location.

The clear text nature of the C-Plane messages over the ethernet exposes the open-fronthaul to the threats described above.

5.2.5.1.2 Requirements

REQ-SEC-OFCP-1: The Open FH interface shall support authentication and authorization to ensure that only authenticated Open FH network elements can exchange C-Plane data.

REQ-SEC-OFCP-2: The Open FH interface shall be able to detect and defend against application level attacks across the C-Plane.

REQ-SEC-OFCP-3: The Open FH interface should support integrity and anti-replay protection to ensure that C-Plane data remains unaltered during transmission.

REQ-SEC-OFCP-4: The Open FH interface should support confidentiality protection for the C-Plane.

5.2.5.1.3 Security Controls

5.2.5.1.3.1 Authentication and Authorization of network elements supporting the C-Plane

See clause 5.2.5.5 for security controls for the authentication and authorization of an O-DU and other network elements supporting the C-Plane within Open Fronthaul point-to-point LAN segments.

5.2.5.1.3.2 Securing the C-Plane data using MACsec

This clause provides controls for requirements REQ-SEC-OFCP-3 and REQ-SEC-OFCP-4 based on the use of MACsec [79].

SEC-CTL-OFCP-1: The Open Fronthaul network elements should secure the C-Plane data by encapsulating it inside MACsec [79].

Clause 5.2.5.6 of this document provides the solutions for protection of Open Fronthaul messages and defines the security controls for encryption of the C-Plane data on the Open Fronthaul network segment.

5.2.5.2 U-plane

5.2.5.2.0 Introduction

Open Fronthaul U-plane transports 3GPP Access Stratum (AS) Control Plane and User Plane messages between O-CU-CP and UE, and O-CU-UP and UE. 3GPP AS Control Plane and User Plane messages that are transported via the Open Fronthaul U-Plane (LLS-UP) are confidentiality and integrity protected by Packet Data Convergence Protocol (PDCP) [32][55]. The PDCP [32] security controls remain in place when the message traverses the Open Fronthaul U-Plane.

However, there are certain U-Plane messages containing IQ samples, including PRACH, PUCCH, SSB, as well as O-RAN Application and eCPRI headers, that are transported over Open Fronthaul as encapsulated Ethernet packets without integrity and confidentiality protection.

5.2.5.2.1 Requirements

REQ-SEC-OFUP-1: The Open FH interface should support integrity and anti-replay protection to ensure that U-Plane data remains unaltered during transmission.

REQ-SEC-OFUP-2: The Open FH interface shall support authentication to ensure that only authenticated Open FH network elements can exchange U-Plane data.

REQ-SEC-OFUP-3: The Open FH interface shall support authorization to ensure that only authorized Open FH network elements can exchange U-Plane data.

REQ-SEC-OFUP-4: The Open FH interface may support confidentiality to protect U-Plane data from unauthorized access during transmission.

5.2.5.2.2 Security Controls

5.2.5.2.2.1 Confidentiality protection for U-Plane data using MACsec

Clause 5.2.5.6 of this document provides the solutions for protecting Open Fronthaul messages and defines the security controls for encrypting U-Plane data on the Open Fronthaul network segment using MACsec [79]. The security controls in clause 5.2.5.6 fulfil the requirements REQ-SEC-OFUP-1 and REQ-SEC-OFUP-4.

SEC-CTL-OFUP-1: Void

5.2.5.2.2.2 Authentication and Authorization of network elements supporting the U-Plane

Clause 5.2.5.5 outlines the requirements and security controls for the authentication and authorization of Open Fronthaul (OFH) network elements that support the U-Plane within point-to-point LAN segments using IEEE 802.1X-2020 Port-based Network Access Control [12]. The security requirements and controls in clause 5.2.5.5 fulfil the requirements REQ-SEC-OFUP-2 and REQ-SEC-OFUP-3.

5.2.5.3 S-plane

5.2.5.3.1 Introduction

The Precision Time Protocol (PTP) is a protocol used to synchronize clocks within a PTP network. Within a PTP domain [27], the grandmaster clock is the source of time to which all other PTP clocks in the domain are synchronized.

The IEEE 1588 standard [27] specifies the Best Master Clock Algorithm (BMCA) for electing the best clock from PTP Network and Local PTP Clock. The BMCA runs on PTP instances in the network continuously and is adjusting to changes in that network. PTP ANNOUNCE messages are used to build a timing distribution hierarchy with grandmaster at the top. There can be many grandmasters in PTP Network, but PTP Domain can have only one. The chosen grandmaster clock is responsible for providing timing to the PTP slave nodes.

Following the selection of the new grandmaster, the grandmaster begins transmitting the current time within the SYNC message and FOLLOW_UP messages if applicable. This allows the other clocks to synchronize their time to the grandmaster.

S-Plane attacks include an attacker masquerading as a grandmaster or manipulating PTP to degrade synchronization. An attacker within the PTP network could impersonate the master clock's grandmaster's Identity value and propose himself as a grandmaster candidate by sending fake ANNOUNCE messages declaring him to be the best clock in the network. The malicious GM would provide intentionally inaccurate timing information that results in degradation in the accuracy of time synchronisation and may cause DoS to applications on all the RUs that rely on accurate time synchronisation, potentially bringing down the cell.

Details are covered in [i.14], clause 7.4.1.2.

The two most common deployment models for O-DU in O-RAN are:

- O-DU at the cell site deployment model: the O-DU is collocated with the O-RU with a direct connection between the two (LLS-C1) through a cell site gateway router.
- O-DU at the Data Centre deployment model: the O-DU is at a Data Centre. The O-RU's at the cell site connect to the O-DU via a direct connection between O-RU and O-DU (LLS-C1) or intermediary Ethernet switches (LLS-C2 or LLS-C3).

5.2.5.3.2 Requirements

REQ-SEC-OFSP-1: The S-Plane shall support authentication and authorization of PTP nodes that communicate with other PTP nodes within Configuration LLS-C1, Configuration LLS-C2, or Configuration LLS-C3.

NOTE 1: This ensures least privilege access to the S-Plane where authenticated and authorized PTP nodes communicate over the Open Fronthaul network.

NOTE 2: There is no specific requirement for authentication and authorization mechanism of S-plane PTP messages.

REQ-SEC-OFSP-2: The S-Plane should provide a means to prevent spoofing of master clocks.

REQ-SEC-OFSP-3: For the O-DU at the Data Centre deployment model the S-Plane should protect against MITM attacks that degrade the clock accuracy due to packet delay attacks or selective interception and removal attacks [28].

REQ-SEC-OFSP-4: The O-DU shall be able to detect and defend against application level attacks across the S-Plane interface, due to misbehaviour or malicious intent.

REQ-SEC-OFSP-5: The S-Plane should support a security mechanism to authenticate the sender of the PTP ANNOUNCE messages.

REQ-SEC-OFSP-6: The S-Plane should support a security mechanism for integrity protection of the PTP ANNOUNCE messages.

REQ-SEC-OFSP-7: The S-Plane should support a security mechanism for replay protection of the PTP ANNOUNCE messages.

REQ-SEC-OFSP-8: The S-Plane should support a security mechanism for confidentiality protection of the PTP messages.

5.2.5.3.3 Security Controls

5.2.5.3.3.1 Synchronization Architecture Redundancy

This clause addresses requirement REQ-SEC-OFSP-3 by providing an architectural recommendation to S-plane security based on redundancy in the Open Fronthaul Synchronization architecture.

The following architectural recommendations for security controls build S-Plane redundancy into the Open Fronthaul for increased robustness against security breaches.

SEC-CTL-OFSP-1: The Open Fronthaul Synchronization architecture should support simultaneous Grandmasters.

SEC-CTL-OFSP-2: The Open Fronthaul Synchronization architecture should support the assignment of GMs to physically separated PTP ports. Multiple masters could be connected to offer topology resilience.

O-RAN Synchronization Architecture and Solution Specification [30], clause 8.2.3 Timing/Synchronization Redundancy & Resiliency provides additional details on redundancy for the Open Fronthaul Synchronization architecture.

5.2.5.3.3.2 Authentication and Authorization of PTP nodes

This clause addresses requirements REQ-SEC-OFSP-1 and REQ-SEC-OFSP-2 based on the use of IEEE 802.1X-2020 Port-based Network Access Control [12] for authentication and subsequent authorization of PTP nodes.

Clause 5.2.5.5 provides requirements and security controls for the authentication and authorization of S-Plane PTP nodes within Open Fronthaul point-to-point LAN segments.

5.2.5.3.3.3 Securing PTP ANNOUNCE Messages using IEEE 1588 Authentication TLV

This clause provides security controls for REQ-SEC-OFSP-5, REQ-SEC-OFSP-6, and REQ-SEC-OFSP-7 using IEEE 1588-2019 ([27]) AUTHENTICATION TLV (clause 16.14) to provide source authentication, message integrity, and replay attack protection for PTP ANNOUNCE messages within a PTP domain.

SEC-CTL-OFSP-3: The Open Fronthaul Synchronization architecture may support IEEE 1588-2019 [27] Authentication TLV for securing PTP ANNOUNCE messages.

5.2.5.3.3.4 MACsec for S-Plane

This clause introduces MACsec as a mechanism to provide source authentication, message integrity, and replay attack protection for S-plane.

SEC-CTL-OFSP-4: The Open Fronthaul Synchronization architecture may support MACsec for securing PTP messages.

5.2.5.4 M-plane

5.2.5.4.0 Introduction

The M-Plane interface is defined in the M-Plane specification [14].

5.2.5.4.1 Requirements

REQ-SEC-OFHM-1: Open Fronthaul M-Plane interface shall support confidentiality, integrity, and replay protection.

REQ-SEC-OFHM-2: Open Fronthaul M-Plane interface shall support mutual authentication.

REQ-SEC-OFHM-3: Open Fronthaul M-Plane interface shall support authorization using the principle of least privilege.

REC-SEC-OFHM-4: Open Fronthaul M-Plane interface shall support secure file transfer.

5.2.5.4.2 Security Controls

SEC-CTL-OFHM-1: Open Fronthaul M-Plane interface shall support confidentiality and integrity protection using TLS, as specified in O-RAN Security Protocols Specifications [3] clause 4.2.

SEC-CTL-OFHM-2: Open Fronthaul M-Plane interface shall support mutual authentication using mTLS 1.2 with X.509 certificates, as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-OFHM-3: Open Fronthaul M-Plane interface may support mutual authentication using mTLS 1.3 with X.509 certificates, as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-OFHM-4: Open Fronthaul M-Plane interface shall support authorization and least privilege using NACM, as specified in clause 5.2.5.4.3.

SEC-CTL-OFHM-5: Open Fronthaul M-Plane interface shall support secure file transfer using FTPES, as specified in O-RAN Security Protocols Specifications [3], clause 6.3.

SEC-CTL-OFHM-6: Open Fronthaul M-Plane interface shall support confidentiality and integrity protection using SSH with password-based authentication, as specified in O-RAN Security Protocols Specifications [3] clause 4.1.

SEC-CTL-OFHM-7: Open Fronthaul M-Plane interface shall support confidentiality and integrity protection using SSH with simple public key server authentication by the SSH client, as specified in O-RAN Security Protocols Specifications [3] clause 4.1.

SEC-CTL-OFHM-8: Open Fronthaul M-Plane interface shall support confidentiality and integrity protection using SSH with simple public key client authentication by the SSH server, as specified in O-RAN Security Protocols Specifications [3] clause 4.1.

SEC-CTL-OFHM-9: Open Fronthaul M-Plane interface shall support secure file transfer using SFTP, as specified in O-RAN Security Protocols Specifications [3], clause 6.2.

5.2.5.4.3 Configuration Requirements for Least Privilege Access

REQ-NAC-MPLANE-FUN-1: Open FH M-Plane endpoints that use NETCONF shall support the NETCONF Access Control Model (NACM) as specified in RFC 8341 [10] to restrict NETCONF protocol access for users to a preconfigured subset of available NETCONF protocol operations and content.

REQ-NAC-MPLANE-FUN-2: The NETCONF implementation for Open FH M-Plane shall set the default values of the NACM Global Enforcement Controls as described in Table 5.2.5.4.3-1.

Table 5.2.5.4.3-1: Default values of the NACM Global Enforcement

Parameter	Value
enable-nacm	true
read-default	deny
write-default	deny
exec-default	deny
enable-external-groups	true

REQ-NAC-MPLANE-FUN-3: Open FH M-Plane endpoints shall support the group “sudo” and may support the groups "smo", "hybrid-odu", "carrier", "nms", "fm-pm", and "swm" in their NACM implementation to restrict NETCONF protocol access as defined in [14] clause 6.5.

REQ-NAC-MPLANE-FUN-4: Open FH M-Plane NETCONF endpoints may support external user-to-group mapping via LDAP with StartTLS.

REQ-NAC-MPLANE-FUN-5: Open FH M-Plane Management Service providers may allow the definition of users in the <groups> NACM object.

REQ-NAC-MPLANE-FUN-6: Open FH M-Plane NETCONF endpoints may support external user-to-group mapping via OAuth 2.0, RADIUS with EAP, and TACACS+.

5.2.5.5 Open Fronthaul Point-to-Point LAN Segment

5.2.5.5.1 Introduction

The Open Fronthaul Ethernet L1 physical interface comprises one or more coaxial cables, twisted pairs, or optical fibers. These are also known as point-to-point LAN segments [12]. Each end of the Open Fronthaul point-to-point LAN segment comprises a physical connection (colloquially known as an Ethernet Port) to physical O-RAN network elements, as described in [13] and [14].

EXAMPLE: Physical O-RAN network elements includes O-DU, O-RU.

An Open Fronthaul network element is an entity in a point-to-point LAN segment. Xhaul Transport Network Elements that share a point-to-point LAN segment with Open Fronthaul network elements are also Open Fronthaul network elements. Examples of O-RAN Alliance defined Open Fronthaul network elements include, but are not limited to, O-DU, O-RU, switches, FHM, FHGW, TNE and PRTC-T/GM, see [13],[14],[15] and [26].

5.2.5.5.2 Requirements

REQ-SEC-OFHPLS-1: The Open Fronthaul shall provide a means to authenticate and authorize point-to-point LAN segments between Open Fronthaul network elements.

REQ-SEC-OFHPLS-2: The Open Fronthaul shall provide a means to detect and report when an authorized point-to-point LAN segment is made or broken.

REQ-SEC-OFHPLS-3: The Open Fronthaul shall provide a means to block access to unused Ethernet ports in an Open Fronthaul network element.

5.2.5.5.3 Security Controls

5.2.5.5.3.1 Solution #1: Authentication and Authorization based on 802.1X Port based Network Access Control

IEEE 802.1X-2020 [12] Port-based Network Access Control provides the means to control network access in point-to-point LAN segments within the Open Fronthaul network. Port-based network access control in the O-RAN Alliance Open Fronthaul comprises supplicant, authenticator, and authentication server entities described in IEEE 802.1X-2020 [12] and

as further described in this clause. All other entities and functionality described in IEEE 802.1X [12] are out of scope of this O-RAN Alliance specification and are determined by vendor implementation in agreement with operator-specific requirements.

SEC-CTL-OFHPLS-1: Void.

Suplicants in the Open Fronthaul Network

SEC-CTL-OFHPLS-2: Open Fronthaul network elements shall support IEEE 802.1X-2020 [12] supplicant functionality for each port connection in the Open Fronthaul network element.

Authenticators in the Open Fronthaul Network

In IEEE 802.1X-2020 [12] a supplicant mutually authenticates with an authenticator.

SEC-CTL-OFHPLS-3: Any Open Fronthaul network element may be an authenticator in the Open Fronthaul network.

SEC-CTL-OFHPLS-4: An authenticator in an Open Fronthaul network shall support port-based network access control on each point-to-point LAN segment as defined in IEEE 802.1X-2020 [12].

SEC-CTL-OFHPLS-5: Port-based network access control between a supplicant and authenticator in an Open Fronthaul network shall use EAP-TLS authentication as defined in IEEE 802.1X-2020 [12].

O-DU as an Authenticator

Configuration LLS-C1 [13] and Cascade Mode in the Shared Cell Concept [12] are cases where an O-DU and O-RU are Open Fronthaul network elements in a point-to-point LAN segment.

SEC-CTL-OFHPLS-6: In the case of Configuration LLS-C1, the O-DU shall support the authenticator functionality as defined in IEEE 802.1X-2020 [12].

Authenticator interface to an Authentication Server in the Open Fronthaul Network

IEEE 802.1X describes an EAP-TLS exchange which includes an interface between an authenticator and authentication server [12].

SEC-CTL-OFHPLS-7: The interface between an authenticator and authentication server shall support IETF RADIUS standards, IETF RFC 2865 [22], IETF RFC 2866 [23], IETF RFC 3579 [24].

SEC-CTL-OFHPLS-8: The interface between an authenticator and authentication server should support IETF Diameter standards, IETF RFC 4072 [25].

NOTE : Mechanisms to secure the interface between the authenticator and authentication server are out of scope of the O-RAN Alliance.

5.2.5.5.3.2 Authentication and authorization procedure for 802.1X Port based Network Access Control

General requirements

Only those Open Fronthaul network elements acting as a supplicant that have mutually authenticated with an authenticator are authorized to participate in the Open Fronthaul network. If an authenticator port is to be activated in the Open Fronthaul, then the authenticator places the port into an unauthorized state that allows EAP over LAN (EAPOL) packets for EAP authentication and blocks all other traffic. If the mutual authentication has been successful and the operator authorizes operation for the network element port, then the port is switched to the authorized state whereby non-EAPOL packets can be sent and received.

SEC-CTL-OFHPLS-9: Open Fronthaul network elements acting as an authenticator shall place each of its unauthorized ports into a state that allows EAPOL traffic and block all other Ethernet traffic.

SEC-CTL-OFHPLS-10: Open Fronthaul network elements acting as an authenticator should be able to implement authorization policies that apply to its authorized ports.

NOTE: Authorization policies may include tagging authorized traffic with a particular VLAN-ID as it egresses the Open Fronthaul network element and/or enforcing access control policies that restrict the type of traffic able to be forwarded by the Open Fronthaul network element.

Manufacturer Install Certificates

This clause applies to the Extensible Authentication Protocol as defined in IEEE 802.1X [12] where such an approach is used. A supplicant implements an EAP method according to its supported credentials. Prior to a supplicant enrolling in an operator's PKI, a manufacturer installed certificate shall be used together with an EAP-TLS dialogue to enable certificate-based mutual authentication to be performed between an authenticator and a supplicant.

SEC-CTL-OFHPLS-11: The O-RU shall have installed a Manufacturer Installed X.509 Certificate.

Security Procedure

The following procedure describes the authentication and authorization, based on IEEE 802.1X Port based Network Access Control, of point-to-point LAN segments between a supplicant and another Open Fronthaul network element acting as an authenticator.

SEC-CTL-OFHPLS-12: The normal operation procedure defined in IEEE 802.1X [12] shown in **Error! Reference source not found.** and Figure 5.2.5.5.3.2-2 shall be performed to authenticate and authorize an O-RU within an Open Fronthaul network.

```
@startuml
!pragma teoz true
skinparam defaultTextAlignment center

participant "Authentication\nServer" as AAA
participant "IEEE 802.1x\nAuthenticator" as AUT
participant "IEEE 802.1x\nSupplicant" as SUP

note over AAA
    Manufacturer Trust
    Root Installed
end note

&note over SUP
    Manufacturer Installed
    X.509 Certificate
end note

&note over AUT
    Port in unauthorized
    state - blocks all
    traffic other than
    EAPOL traffic
end note

group Initial limited-access when authenticated using manufacturer certificate
    SUP->>AUT: EAPoL Start
    AUT->>SUP: EAP-Request/Identity
    SUP->>AUT: EAP-Response/Identity (from Manufacturer Installed X.509 Certificate
    Subject DN)

    AUT->>AAA: RADIUS-Access-Request or Diameter-EAP-Request (EAP-Response)
    AAA->>AUT: RADIUS-Access-Challenge or Diameter-EAP-Answer (EAP-Request)
    AUT->>SUP: EAPoL (EAP-Request)
    note over AAA, SUP
        EAP Dialogue Continues using Manufacturer Installed X.509 Certificate
    end note
    AAA->>AAA: Select Security Policy \nfor Manufacturer Installed X.509 Certificate
    AAA->>AUT: RADIUS-Access-Accept or Diameter-EAP-Answer (EAP-Success) \nIncluding
    security policy, e.g., Provisioning/Enrollment VLAN
    AUT->>SUP: EAP-Success
end group
```

```

AUT->AUT: Set port to authorized state.\nAssign port to provided security policy,
\neg., Provisioning/Enrollment VLAN
end

group Enrollment into operator PKI
    note over AUT, SUP
        Certificate Enrollment Completes & Provision of Operator X.509 Certificate
    end note

    SUP->SUP: Install\nOperator X.509\nCertificate
end

group Subsequent full operational access when authenticated using operator installed
certificate

    note over SUP
        re-start of Supplicant
        triggers interface
        re-initialization
    end note

    note over AUT
        Interface re-initialization:
        resets port to unauthorized
        state - blocks all traffic
        other than EAPoL traffic
    end note

    SUP->AUT: EAPoL Start
    AUT->SUP: EAP-Request/Identity
    SUP->AUT: EAP-Response/Identity (from Operator X.509 Certificate Subject DN)

    AUT->AAA: RADIUS-Access-Request or Diameter-EAP-Request (EAP-Response)
    AAA->AUT: RADIUS-Access-Challenge or Diameter-EAP-Answer (EAP-Request)
    AUT->SUP: EAPoL (EAP-Request)
    note over AAA, SUP
        EAP Dialogue Continues using Operator Installed X.509 Certificate
    end note
    AAA->AAA: Select Security Policy\nfor Operator Installed X.509 Cert
    AAA->AUT: RADIUS-Access-Accept or Diameter-EAP-Answer (EAP-Success) \nIncluding
security policy, e.g., Operational VLAN
    AUT->SUP: EAP-Success

    AUT->AUT: Set port to authorized state.\nAssign port to provided security policy,
\neg., Operational VLAN

    note over SUP
        Normal Supplicant
        start up continues
    end note

end
@enduml

```

Figure 5.2.5.3.2-1: UML code of 802.1X Port Based Authentication in the O-RAN Fronthaul architecture

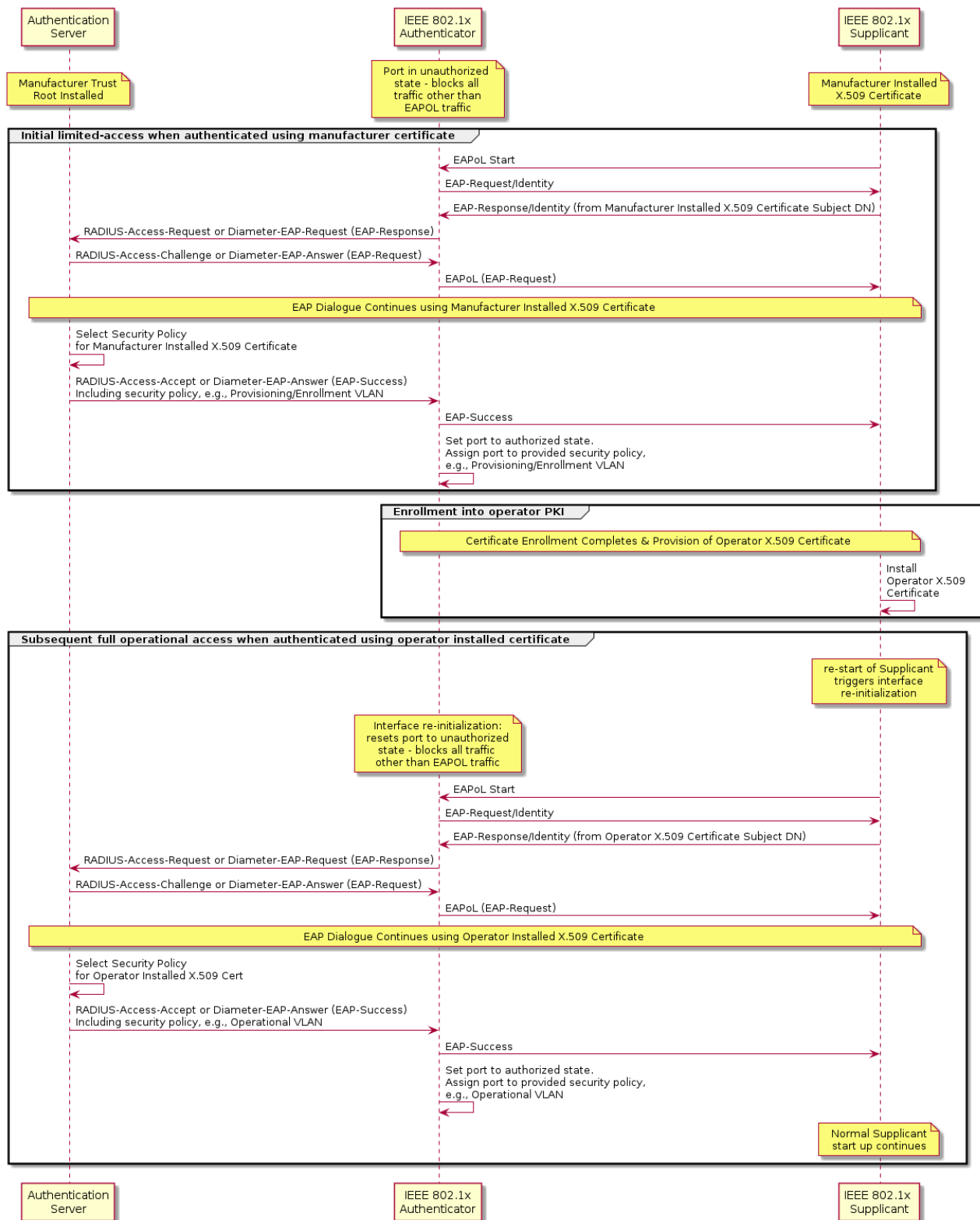


Figure 5.2.5.5.3.2-2: Operation of 802.1X Port Based Authentication in the O-RAN Fronthaul architecture

The authentication and authorization procedure may fail at any moment, for example because of no response from the supplicant after a network request. In that case, the operation procedure as specified in Figure 5.2.5.5.3.2-2 will be terminated as specified in IEEE 802.1X-2020 [12].

5.2.5.6 Protecting Open Fronthaul messages using MACsec

5.2.5.6.1 Introduction

MACsec defined in the standard IEEE 802.1AE -2018[79] is a Layer 2 protocol that provides data confidentiality, frame data integrity, and authenticity of data origin including replay protection for all types of traffic on Ethernet links.

MACsec can be configured in an End-to-End mode or Hop-by-Hop mode. Hop-by-Hop mode requires the intermediate nodes to support MACsec. End-to-End mode does not require the intermediate nodes to support MACsec. MACsec configuration can be applied per VLAN or at the base interface level.

Hop-by-hop mode protects the LAN port and all of its traffic, except a few well-defined protocols that are standardized to be mapped to the Uncontrolled Port, e.g. EAP and MKA. End-to-end mode protects VLAN ports and all of the LAN port traffic, except a few well-defined protocols that are standardized to be mapped to the Uncontrolled Port, e.g. EAP and MKA. End-to-End mode defined in IEEE 802.1AE -2018 [79] does not protect protocols that are operating on the LAN segment level (e.g. with nearest-bridge scope), e.g. PTP.

The following clause describes the supported encryption modes for establishing MACsec.

1. MACsec using EDE-CC
2. WAN mode MACsec
3. LAN mode MACsec

The Open Fronthaul network element can use one of the encryption modes based on the specific Open Fronthaul traffic that requires protection.

The key management solutions required for MACsec is defined in clause 5.2.5.6.5

5.2.5.6.2 MACsec using EDE-CC

5.2.5.6.2.1 Introduction

This clause provides an overview of the EDE-CC operation as it is standardized in IEEE 802.1AE-2018 [79], clause 15.6.

In this mode, MACsec uses EDE-CC, controlled port, uncontrolled port as functional blocks from IEEE 802.1AE-2018 [79]. This solution applies to scenarios where MACsec is applied based on VLAN tags and configured at the VLAN interface.

This mode allows 802.1Q VLAN tags to be encrypted inside the MACsec header and also sent in clear text, outside the MACsec header. The inner VLAN tag is protected by MACsec while the outer VLAN tag is used for VLAN based switching in a network where some transport network elements may not be MACsec capable. This solution enables MACsec to be configured in an end-to end tunnel mode such that the intermediate nodes may be MACsec-unaware.

To prevent intermediary nodes from consuming EAPoL packets, it is recommended to configure an appropriate group destination address as specified in IEEE 802.1AE-2018 [79], Table 15.1.

Figure 5.2.5.6.2-1 depicts the scenario where the O-RU and O-DU are connected via a switched fronthaul network and MACsec is enabled at O-DU and O-RU in an End-to-End tunnel mode. The TNE and intermediary switches may or may not support MACsec capabilities.

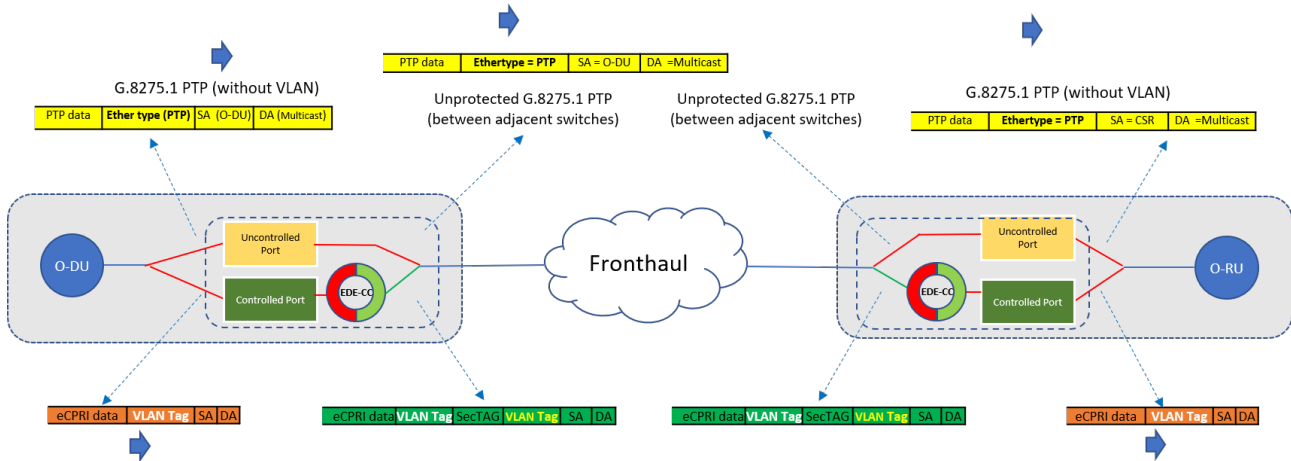


Figure 5.2.5.6.2-1: End-to-End MACsec solution for Fronthaul security protection

The O-DU functional block transmits the Open Fronthaul message that needs encryption to the controlled port, which passes through an EDE functional block. This EDE block secures the Open Fronthaul message using MACsec. The EDE-CC, a variant of EDE, adds a cleartext VLAN header before the MACsec header, which includes VLAN and VLAN PCP bits, that are used for VLAN-based switching and identifying QoS profiles in the MACsec-unaware Fronthaul TNE connected to the O-DU. At the receiving endpoint, the O-RU validates the encrypted traffic received at the EDE using MACsec. Upon successful validation, it forwards the traffic via the controlled port to the O-RU functional block. Communication from the O-RU to the O-DU follows a similar process.

The EDE-CC protects VLAN-tagged traffic, but it does not protect untagged traffic, i.e. protocols that are operating on the LAN level, like PTP. The LAN level protocols pass through the EDE-CC as-is, i.e. without encryption or decryption. Implementations may use the EtherType and VLAN header presence for detecting such LAN-level protocols.

Depending on the chosen network topology, the MACsec tunnel endpoint can be a TNE, and the functionalities of controlled, uncontrolled ports, and EDE can apply to it. Communication between the selected MACsec tunnel endpoints would occur in a similar manner.

NOTE: A TNE that integrates an EDE-CC has to be a CE.

5.2.5.6.2.2 Security Controls

This clause specifies the security controls for configuring MACsec using EDE-CC. The Open Fronthaul network elements include the O-DU, O-RU and TNE.

SEC-CTL-OFHMECC-1: The Open Fronthaul network elements may support the functional blocks of controlled port, uncontrolled port, and Ethernet Data Encryption (EDE), as defined in the standard IEEE 802.1AE -2018 [79] clauses 5.2, 5.3 and 15.6.

SEC-CTL-OFHMECC-2: Void

SEC-CTL-OFHMECC-3: The Open Fronthaul network elements may forward the data that need to be encrypted to the controlled port. The controlled port then sends the data to the EDE functional block that is secured by MACsec.

SEC-CTL-OFHMECC-4: The Open Fronthaul network elements may support the EDE-CC functionality that allows utilization of the frame's VLAN tag for service selection and conveyance of Priority Code Point (PCP) and drop-eligible (DEI) information.

SEC-CTL-OFHMECC-5: If an Open Fronthaul network element supports the EDE-CC functionality, it shall support the cipher suites, as specified in O-RAN Security Protocols Specifications [3], clause 4.9.

5.2.5.6.3 WAN mode MACsec

5.2.5.6.3.1 Introduction

This mode allows the 802.1Q VLAN tag to be unencrypted and sent in clear text, outside the MACsec header. This solution applies to scenarios where MACsec is applied based on VLAN tag and configured at the VLAN interface. This solution enables the intermediary switches that are MACsec-unaware to switch the packets based on the VLAN tag.

To prevent MACsec capable intermediary nodes from consuming EAPoL packets, it is recommended to configure the group destination address to allow the intermediary nodes to tunnel the packets like data packets.

5.2.5.6.3.2 Security Controls

This clause specifies the security controls for configuring MACsec using VLAN in the clear. The Open Fronthaul network elements include the O-DU, O-RU and TNE.

SEC-CTL-OFHWMM-1: The Open Fronthaul network elements may support a MACsec solution allowing the VLAN header to travel in the clear.

SEC-CTL-OFHWMM-2: If an Open Fronthaul network element supports a MACsec solution allowing the VLAN header to travel in the clear, it shall support the cipher suites, as specified in O-RAN Security Protocols Specifications [3], clause 4.9.

5.2.5.6.4 LAN mode MACsec

5.2.5.6.4.1 Introduction

This solution requires that the entire Ethernet frame after the MAC address should be encrypted. The Secure TAG of MACsec encompasses both VLAN-tagged and non-VLAN-tagged frames, securing all traffic that travels through the interface of an Open Fronthaul network element.

In some implementations it may be possible to configure additional policies to bypass MACsec protection based on EtherType, VLAN ID, and destination address. When enabled, this capability allows certain types of Open Fronthaul traffic, such as S-Plane, to remain unencrypted and bypass MACsec protection. This behavior is not standardized in IEEE 802.1AE-2018[79], and interoperability may be limited.

5.2.5.6.4.2 Security Controls

This clause specifies the security controls for configuring MACsec to protect the entire Ethernet frame after the MAC address. The Open Fronthaul network elements include the O-DU, O-RU and TNE.

SEC-CTL-OFHLM-1: The Open Fronthaul network elements may support securing of all Open Fronthaul traffic using MACsec.

SEC-CTL-OFHLM-2: The Open Fronthaul network elements may support the configuration of policies to allow certain type of Open Fronthaul traffic to be sent in clear text.

SEC-CTL-OFHLM-3: If an Open Fronthaul network element supports securing of all Open Fronthaul traffic using MACsec, the Open Fronthaul network element shall support the cipher suites, as specified in O-RAN Security Protocols Specifications [3], clause 4.9.

5.2.5.6.5 Key Management Provisions for MACsec

5.2.5.6.5.1 Introduction

A critical element of MACsec security framework are the hierarchy of keys, as defined in clause 6.2 of IEEE 802.1X-2020 [12], which are fundamental to the secure operation of MACsec [79].

The following clause describes two key management provisions for establishing MACsec keys.

1. Key Management Provision 1: Using EAP and MKA to establish MACsec keys
2. Key Management Provision 2: Using Pre-Shared Keys (PSKs) and MKA for MACsec Configuration

5.2.5.6.5.2 Key Management Provision 1: Using EAP and MKA to establish MACsec keys

5.2.5.6.5.2.1 Introduction

The MACsec Key Agreement (MKA) protocol as specified in IEEE 802.1X Port-Based Network Access Control [12] is used for the secure exchange and distribution of MACsec keys [12] among MACsec-enabled devices. The master session key (MSK) is generated as a by-product of the EAP Authentication process. The Connectivity Association Key (CAK) is then derived from the MSK. The Secure Association Key (SAK) is derived from the CAK through a secure key derivation process managed by the MKA protocol as specified in IEEE 802.1X [12]. The SAK is used to encrypt and verify the integrity of data frames passing over the protected link. The MACsec Key Agreement (MKA) protocol seamlessly discovers peers and distributes SAK keys, ensuring that only authorized devices can engage in the secure exchange of information.

5.2.5.6.5.2.2 Security Controls

This clause specifies the security controls for Key Management of MACsec using MKA.

SEC-CTL-MACsec-KM-1: An Open Fronthaul network element with MACsec capabilities should support the key distribution and management using the MACsec Key Agreement (MKA) protocol based on a previous, successful, EAP-TLS authentication, as defined in clause 6.3.1 and clause 9 of IEEE 802.1X-2020 [12].

5.2.5.6.5.3 Key Management Provision 2: Using pre-shared keys and MKA to establish MACsec keys

5.2.5.6.5.3.1 Introduction

Another option for MACsec key management involves the use of pre-shared keys (PSKs) for authentication as defined in IEEE 802.1X-2020, clause 6.3.3 [12]. PSKs provide a simplified method for key distribution, particularly in scenarios where EAP authentication mechanisms are not required or practical. The PSK approach allows MACsec-enabled devices to configure Connectivity Association Keys (CAKs) directly through administrative setup, bypassing the need for an EAP authentication process.

5.2.5.6.5.3.2 Security Controls

SEC-CTL-MACsec-KM-2: An Open Fronthaul network element with MACsec capabilities may support the key distribution and management using the MACsec Key Agreement (MKA) protocol with pre-shared keys, as defined in clause 6.3.3 and clause 9 of IEEE 802.1X-2020 [12].

NOTE: Use of pre-shared Keys is not recommended.

5.2.6 R1 Interface

5.2.6.0 Introduction

R1 is the interface between rApps and Non-RT RIC Framework via which R1 Services can be produced and consumed. See R1 specification [39].

5.2.6.1 Requirements

REQ-SEC-R1-1: R1 interface shall support confidentiality, integrity, and replay protection.

REQ-SEC-R1-2: R1 interface shall support mutual authentication.

REQ-SEC-R1-3: R1 interface shall support authorization with the principle of least privilege.

5.2.6.2 Security Controls

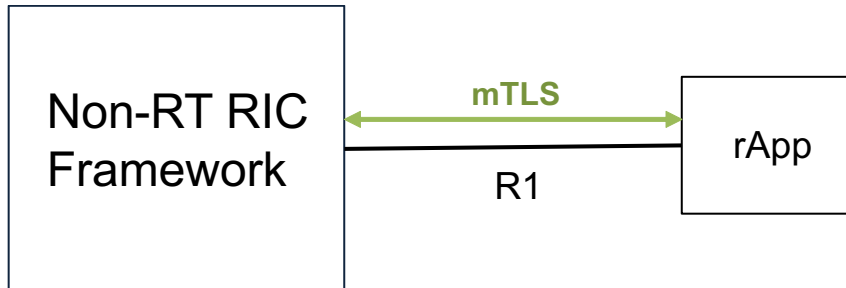


Figure 5.2.6.2-1: mTLS on R1 interface

SEC-CTL-R1-1: For the security protection at the transport layer on R1 interface, TLS shall be supported as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-R1-2: For the mutual authentication of the Non-RT RIC Framework and rApps, the R1 interface shall support mTLS with PKI using X.509v3 certificates, as shown in Figure 5.2.6.2-1 and specified in O-RAN Security Protocols Specifications [3], clause 4.2.

SEC-CTL-R1-3: The R1 interface shall support authorization using OAuth 2.0, as specified in O-RAN Security Protocols Specifications [3], clause 4.7.

5.2.7 Y1 Interface

5.2.7.1 Introduction

The Near-RT RIC provides RAN analytics information services via Y1 service interface. These services can be consumed by Y1 consumers by subscribing to or requesting the RAN analytics information via the Y1 service interface. Y1 consumers may be Application Functions (AFs). The Near-RT RIC serves as Y1 provider.

5.2.7.2 Requirements

REQ-SEC-Y1-1: The Y1 provider shall provide mechanisms to authenticate the Y1 consumer and allow for the Y1 consumer to authenticate the Y1 provider (mutual authentication).

REQ-SEC-Y1-2: The Y1 provider shall authorize the Y1 consumer before allowing access to any service over the Y1 interface.

REQ-SEC-Y1-3: The Y1 interface shall provide confidentiality and integrity protection for all data exchanged.

REQ-SEC-Y1-4: The Y1 interface shall provide replay-protection for all data exchanged.

REQ-SEC-Y1-5: The Y1 interface shall enforce the result of the authentication for the duration of communications.

REQ-SEC-Y1-6: The Near-RT RIC shall hide its topology from the Y1 consumers accessing the Y1 interface.

5.2.7.3 Security Controls

5.2.7.3.1 Y1 interface protocol structure solution 1

The Y1 interface protocol structure solution 1 is defined in the O-RAN ALLIANCE TS: "Y1 interface: General Aspects and Principles" [66], clause 7.2.

SEC-CTL-Y1-1: The Y1 interface protocol structure solution 1 shall support mutual TLS (mTLS) authentication via X.509v3 certificates, as specified in O-RAN Security Protocols Specifications [3], clause 4.2.

NOTE 1: In mTLS, both the client (the Y1 consumer) and the server (the Y1 provider) require a certificate, and both sides authenticate each other using their public/private key pair.

SEC-CTL-Y1-2: The Y1 interface protocol structure solution 1 shall support the OAuth 2.0 authorization framework as specified in O-RAN Security Protocols Specifications [3], clause 4.7.

The roles defined in OAuth 2.0 shall be assigned as follows:

- Resource owner / Resource server (producer): Y1 provider
- Client (consumer): Y1 consumer

SEC-CTL-Y1-3: The Y1 interface protocol structure solution 1 shall support TLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2, to provide data confidentiality, integrity, and replay-protection.

5.3 Transversal requirements

5.3.1 Software Bill of Materials

Void

5.3.1.1 Requirements

Void

5.3.2 Application Lifecycle Management Security

5.3.2.0 Introduction

There are three application lifecycle phases: development, onboarding, and operation. Refer to clause 6 in [16] for further details of application lifecycle management and the lifecycle phases.

5.3.2.1 Package Protection

5.3.2.1.1 Requirements

REQ-SEC-ALM-FUN2-1: Void

REQ-SEC-ALM-FUN3-1: Void

REQ-SEC-ALM-PKG-1: The Solution Provider shall perform a vulnerability assessment of the application package prior to signing and delivery.

EXAMPLE: Refer to Annex C clause C.2.1 for additional information on application testing and scanning throughout the lifecycle of the application.

REQ-SEC-ALM-PKG-2: The application package shall be authenticity and integrity protected by the Solution Provider prior to its delivery.

REQ-SEC-ALM-PKG-2A: The application package sensitive artifacts should be confidentiality protected by the Solution Provider prior to the package delivery.

REQ-SEC-ALM-PKG-3: The application package shall include the signing certificate and signature(s) of Solution Provider.

REQ-SEC-ALM-PKG-4: Each application artifact shall be digitally signed individually by the Solution Provider.

REQ-SEC-ALM-PKG-5: SMO shall verify all application artifacts authenticity and integrity during onboarding.

REQ-SEC-ALM-PKG-6: SMO shall verify application package authenticity and integrity during onboarding.

REQ-SEC-ALM-PKG-7A: Void.

REQ-SEC-ALM-PKG-7B: The Solution Provider shall have a vulnerability management process in place, including mechanisms for external parties to report vulnerabilities and procedures to assess and remediate discovered vulnerabilities.

REQ-SEC-ALM-PKG-7C: Void.

NOTE 1: REQ-SEC-ALM-PKG-7B outlines best practices for effective vulnerability management. It is not directly testable and depends on the agreed processes between Solution and Service Providers.

REQ-SEC-ALM-PKG-8: Application packages or application artifacts should be digitally signed by Service Provider before it is stored in any Service Provider repository

REQ-SEC-ALM-PKG-9: Verification of the digital signature(s) on the application package by an O-RAN architecture element shall support checking the validity period of the certificate associated with the signature(s).

REQ-SEC-ALM-PKG-10: Application packages and application artifacts stored in any Service Provider repository [16] shall be protected in terms of integrity and confidentiality.

REQ-SEC-ALM-PKG-11: Application packages stored in any Service Provider repository [16] shall be accessible to only authorized entities and over networks that enforce authentication, integrity, and confidentiality.

REQ-SEC-ALM-PKG-12: Every Service Provider repository shall contain only application packages and application artifacts with verifiable signature(s).

NOTE 2: Application packages and application artifacts are always signed by Solution Provider (see REQ-SEC-ALM-PKG-2, REQ-SEC-ALM-PKG-4). Additionally, Service Provider has option to sign application packages and application artifacts using its own certificates (see REQ-SEC-ALM-PKG-8). If Service Provider signs as well, there are 2 signatures present.

REQ-SEC-ALM-PKG-13: Sensitive information used during the lifecycle of the application shall be protected in terms of confidentiality at rest and in transit, see [41], [42] and [46]

REQ-SEC-ALM-PKG-14: SMO shall contain a pre-installed root certificate of trusted CA (trusted by the Service Provider) before the onboarding of the application package for verifying its authenticity and integrity. Root certificate shall be delivered via a trusted channel separately from an application package [42].

REQ-SEC-ALM-PKG-15: Application packages shall have a Change Log. All the changes in the application package from its creation and updates by the Solution Provider shall be versioned, tracked, and inventoried in the Change Log [43].

NOTE 3: Change log can also be provided separately as an external artifact.

NOTE 4: The Service Provider is responsible for recording events related to onboarding, deployment, and operational changes that do not modify the application package itself.

REQ-SEC-ALM-PKG-16: During deployment, SMO or O-Cloud shall verify all application artifacts authenticity and integrity.

5.3.2.1.2 Security Controls

SEC-CTL-ALM-PKG-1: During onboarding, SMO shall verify the signature(s) of the application package as well as the signature(s) of application artifacts.

To verify the signature of an application package in the ETSI profile [80] at onboarding, one of the two following options shall be followed as defined in ETSI GS NFV-SOL004 [42], clause 5:

- Option 1: The application package contains a Digest (a.k.a. hash) for each of the artifacts in the manifest of the application package. The manifest is signed with the Solution Provider private key.
- Option 2: The complete application package is signed with the Solution Provider private key.

NOTE 1: The packaging format for container-based applications in the Kubernetes profile is being defined at the time of publishing this specification. The Solution Provider is referred to as VNF Provider in ETSI GS NFV-SOL 004 [42].

The signature verification process of an application package in the ETSI profile [80] at onboarding comprises the following steps:

Responsible: Solution Provider, Service Provider

- (1) Application package shall be delivered to the Service Provider together with a signing Solution Provider certificate and signature.
- (2) The root CA certificate shall be pre-installed within the SMO for the validation of the Solution Provider signing certificate authenticity.
- (3) Upon reception of the signed application package from Solution Provider by the Service Provider:
 - a. In Option 1, SMO shall verify the signature of the manifest. SMO shall recalculate the digests of all artifacts and all digests shall be verified against the ones in the manifest.
 - b. In Option 2, SMO shall verify the application package signature.
- (4) SMO shall verify the Solution Provider digital signature of every application artifact.
- (5) SMO may sign onboarded application package before storing it in any Service Provider repository.
- (6) SMO may sign onboarded application artifacts before storing them in any Service Provider repository.

SEC-CTL-ALM-PKG-1A: Algorithms, key sizes, and standards to be used for digital signing and verification of digital signature shall follow the "O-RAN Security Protocols Specifications" [3], clause 5.

SEC-CTL-ALM-PKG-1B: During deployment, SMO or O-Cloud shall verify the signatures of all the onboarded application artifacts necessary for deployment, both the Service Provider signature created by Service Provider, if applicable by the Service Provider policy, and the Solution Provider signature.

SEC-CTL-ALM-PKG-2: Sensitive artifacts shall be encrypted for confidentiality protection.

SEC-CTL-ALM-PKG-2A: Algorithms, key sizes, and standards to be used for encryption/decryption shall follow the O-RAN Security Protocols Specifications [3], clause 5.

SEC-CTL-ALM-PKG-3: Applications supported in the ETSI profile [80] shall be compliant with ETSI NFV specifications, ETSI GS NFV-SOL004 [42] clause 5, and ETSI GS NFV-SEC 021 [41] clauses 5 and 6, for package formats and signing/verification procedures.

NOTE 2: The packaging format for container-based applications in the Kubernetes profile is being defined at the time of publishing this specification.

SEC-CTL-ALM-PKG-4: Encryption shall be used to secure cryptographic keys used by the cryptographic operations.

EXAMPLE: Cryptographic operations include signature generation/verification, encryption/decryption, and hashing.

5.3.2.2 Secure Update

5.3.2.2.1 Requirements

REQ-SEC-ALM-SU-1: Update to an application package shall follow the same security requirements as an application package.

REQ-SEC-ALM-SU-2: Applications should be updated with their latest security updates.

REQ-SEC-ALM-SU-3: Applications should be protected from downgrade attacks to older, possibly vulnerable, software versions.

REQ-SEC-ALM-SU-4: Void.

5.3.2.3 Security Descriptor

5.3.2.3.1 Requirements

REQ-SEC-LCM-SD-1: The application descriptor shall support a description of the security group rules. Those rules shall be associated to the relevant application interfaces.

EXAMPLE: Security group rules include permissions, access control and filtering rules

REQ-SEC-LCM-SD-2: The application descriptor shall support a description of the Service Availability Level (SAL) requirements for virtual resources on the underlying O-Cloud platform.

REQ-SEC-LCM-SD-3: The O-Cloud platform shall use the security group rules in the application descriptor for controlling the traffic direction, who can access the application, what actions they can perform, and what level of access they have.

REQ-SEC-LCM-SD-4: The SMO shall use the Service Availability Level (SAL) in the application descriptor for governing the status (availability, deployment, and operation) of applications and reacting whenever a SAL requirement is being breached.

REQ-SEC-LCM-SD-5: The NFO shall support the ability to compare the application's current owned resource consumption with the defined resource quotas from the application descriptor.

REQ-SEC-LCM-SD-6: The NFO shall send an alarm to the SMO if the application's current owned resource consumption exceeds the defined resource quotas from the application descriptor.

REQ-SEC-LCM-SD-7: The comparing process between the application's current owned resource consumption and the defined resource quotas from the application descriptor should be triggered periodically by the NFO.

5.3.2.4 Secure Deletion of Sensitive Data

5.3.2.4.1 Introduction

Support for secure deletion of data owned by the Application is included in clause 5.1.8.6 for O-Cloud secure storage requirements and controls. NIST SP 800-88 [75] can provide additional guidance for data sanitization.

5.3.2.4.2 Requirements

REQ-SEC-DEL-1: Void

5.3.2.4.3 Security Controls

SEC-CTL-DEL-1: Void

SEC-CTL-DEL-2: Void

5.3.2.5 Decommissioning of Applications

5.3.2.5.0 Introduction

When an application is decommissioned, it is important to document the entire process. Another crucial task is to archive the legacy data and software for historical purposes.

5.3.2.5.1 Requirements

REQ-SEC-ALM-DECOM-1: A complete post-decommission report documenting the tasks performed during application decommissioning shall be generated.

REQ-SEC-ALM-DECOM-2: Legacy data and software should be archived.

REQ-SEC-ALM-DECOM-3: All trust artifacts associated with an application shall be revoked at the time of decommissioning.

EXAMPLE: Trust artifacts include digital certificates, OAuth tokens, and application identifiers, etc.

5.3.3 Network Protocols and Services

5.3.3.0 Introduction

Each O-RAN component serves important network function(s) based on a list of its necessary network protocols and services supported through its network interface(s). Proper, transparent, and secure network protocols and services enabled on each O-RAN component is essential for its overall security posture with the reduced risk.

5.3.3.1 Requirements

REQ-SEC-NET-1: A list of network protocols and services supported on the O-RAN component shall be clearly documented by its vendor. Unused protocols shall be disabled.

5.3.4 Robustness of Common Protocols

5.3.4.0 Introduction

IP, UDP, TCP, SCTP, SSH, HTTP, HTTP/2, IPsec, and eCPRI are the common protocols widely used by any O-RAN components for network communications and services. Robust implementation of those common protocols can significantly improve the security of each O-RAN component and system overall.

5.3.4.1 Requirements

REQ-SEC-TRAN-1: Common protocols used in an O-RAN system should be able to handle unexpected inputs without functional compromise. These protocols include IP, UDP, TCP, SCTP, TLS, SSH, HTTP, HTTP/2, IPsec, and eCPRI.

NOTE: The unexpected inputs include random mutations of the protocol headers and payloads, as well as targeted fuzzing with state awareness.

5.3.5 Robustness against Volumetric DDoS Attack

5.3.5.0 Introduction

Distributed Denial of Service (DDoS) attack is one of the most common security risks for any O-RAN component. DDoS attack often results in service interruption and even worse system crash and prolonged network outage. A volumetric DDoS attack can come from a bad actor or adversary, or a misconfiguration by the operator.

5.3.5.1 Requirements

REQ-SEC-DOS-1: An O-RAN architecture element with network interface shall be able to withstand network transport protocol based volumetric DDoS attack without system crash and returning to its normal service level after the attack subsides.

5.3.5.2 Security Controls

SEC-CTL-DOS-1: Void

5.3.6 Robustness of O-RAN architecture element software

5.3.6.0 Introduction

The robustness of the software for O-RAN architecture elements is fundamental to the overall security posture.

5.3.6.1 Requirements

REQ-SEC-SYS-1: Known vulnerabilities in the software of an O-RAN architecture element shall be identified.

5.3.7 Password-Based Authentication

5.3.7.0 Introduction

Weak, stolen, and mis-used passwords are some of the common and leading causes of data breaches and methods of gaining access to systems, services, and applications. Password policy and management are applicable to both remote and Web UI login interfaces for user and automated machine password-based authentication on O-RAN components.

5.3.7.1 Requirements

REQ-SEC-PASS-1: If password is used as an authentication attribute, O-RAN architecture elements should follow security best practices, such as [i.26].

NOTE: This allows to mitigate risks resulting from different password-based authentication attacks such as brute-forcing, unauthorized password resets, man-in-the-middle, and dictionary attacks.

5.3.7.2 Security Controls

SEC-CTL-PASS-1: O-RAN architecture elements with default password shall support the ability to change the password.

SEC-CTL-PASS-2: O-RAN architecture elements shall support account lock-out for repeated failed login attempts. The number of failed login attempts shall be configurable.

NOTE: The number of attempts may be guided by the organization's policy.

SEC-CTL-PASS-3: Passwords shall be encrypted when stored and transmitted.

5.3.8 Security Log Management

5.3.8.1 Introduction

Security log management is "the process for generating, transmitting, storing, analyzing, and disposing of computer security log data. Log management is essential to ensuring that computer security records are stored in sufficient detail for an appropriate period of time. Routine log analysis is beneficial for identifying security incidents, policy violations, fraudulent activity, and operational problems. Logs are also useful when performing auditing and forensic analysis, supporting internal investigations, establishing baselines, and identifying operational trends and long-term problems." Defined in NIST SP 800-92 [58], executive summary.

5.3.8.2 Generic Requirements

REQ-SEC-SLM-1: An O-RAN component shall support the generation and transmission of security log data.

5.3.8.3 Requirements for Cluster Node

5.3.8.3.1 Requirements on Security Log Data Storage

REQ-SEC-SLM-TESS-1: The Security Log data shall be persistently stored in a non-volatile memory.

NOTE: This refers to Security Log data at rest and applies to back-up Security Log data as well.

REQ-SEC-SLM-TESS-2: Any anomalies detected in log settings, configurations, and processes shall be logged.

REQ-SEC-SLM-TESS-3: The O-RAN Network Function(s), the O-Cloud platform and infrastructure, and the SMO Framework shall create Security Log data.

REQ-SEC-SLM-TESS-4: Security Log data shall be created and maintained per App, per xApp, or per rApp.

REQ-SEC-SLM-TESS-5: The created and stored Security Log data shall provide all necessary information to deduce the root cause of a system behaviour.

REQ-SEC-SLM-TESS-6: The Security Log data access management shall be protected.

REQ-SEC-SLM-TESS-7: The access to Security Log data shall be authenticated and authorized.

REQ-SEC-SLM-TESS-8: Any change of access rights to Security Log data shall be logged.

REQ-SEC-SLM-TESS-9: Changing the access rights of security log data is only possible with privileged access rights.

REQ-SEC-SLM-TESS-10: The Security Log data process shall support Log data rotation. Log data rotation in this context refers to a closing of a Log-storage and opening a new Log-storage when the first Log-storage is complete.

REQ-SEC-SLM-TESS-11: The Security Log data rotation process shall be configurable at regular time and when the maximum log size is reached.

REQ-SEC-SLM-TESS-12: The Security Log data process shall log any log rotation reconfiguration.

REQ-SEC-SLM-TESS-13: The system shall be capable of creating, processing, transmitting, and always storing all required security log events.

5.3.8.3.2 Requirements on Security Log-data in Motion

REQ-SEC-SLM-TESM-1: The Security Log data in motion shall be protected from unauthorized access.

REQ-SEC-SLM-TESM-2: The Security Log data in motion shall be confidentiality, integrity and replay protected.

REQ-SEC-SLM-TESM-3: A mutual authentication shall be performed for any setup of a secure communication channel.

REQ-SEC-SLM-TESM-4: If a Security Log data integrity verification has failed, the Security Log data and a related failure notification shall be logged.

REQ-SEC-SLM-TESM-5: If a Security Log data appears outside of its expected receiving window, the Security Log data and the related notification shall be logged.

5.3.8.4 Log data Repository

5.3.8.4.1 Requirements on Storage in Log data Repository

REQ-SEC-TESR-1: The Security Log data stored in the repository shall be protected from unauthorized access.

REQ-SEC-TESR-2: The Security Log data which have been created inside the trusted environment of the repository shall be persistently stored in a non-volatile memory.

NOTE: This refers to Log data at rest and applies to back-up Log data.

REQ-SEC-TESR-4: Security Log data from different cluster node(s) shall be stored isolated from each other.

REQ-SEC-TESR-5: The Security Log data repository shall grant write only operation to cluster node(s).

REQ-SEC-TESR-6: Security Log data which are stored in the repository shall be confidentiality and integrity protected.

REQ-SEC-TESR-7: The Security Log data repository shall support attribute-based (ABAC) access management according to NIST SP800-162 [67].

REQ-SEC-TESR-8: The Security Log data access management shall support operations for read, write, edit, delete, copy, execute and modify.

REQ-SEC-TESR-9: The access management ABAC mechanisms shall include the Subject Attributes, the Resource Objects Attributes, the Access Control Rules (policy), and the environmental conditions.

REQ-SEC-TESR-10: The Log data repository shall create and store Security Log data in a non-volatile memory.

REQ-SEC-TESR-11: Security Log data in use shall be protected from unauthorized access.

5.3.8.5 Secure storage of security log data

5.3.8.5.1 Introduction

Security log data storage involves the safekeeping and retention of security log data for a certain period of time. Security log data storage should ensure that all data of security events is retained reliably for a certain time so that no data is lost or altered, and access to the data is restricted to authorized personnel only.

5.3.8.5.2 Requirements

REQ-SEC-SLM-SST-1: O-RAN architecture elements shall support export of security log data to be stored in a centralized location.

REQ-SEC-SLM-SST-2: Security log data shall be stored in a tamper-proof manner to ensure their confidentiality and integrity.

REQ-SEC-SLM-SST-3: Retention policies for security log data shall be established to determine how long logs shall be kept.

REQ-SEC-SLM-SST-4: Access to the log storage shall be restricted to authorized personnel only.

REQ-SEC-SLM-SST-5: Access to the log storage shall be logged.

REQ-SEC-SLM-SST-6: Backup of the log storage shall be performed regularly.

REQ-SEC-SLM-SST-7: O-RAN elements shall be authorized to only send security log data to centralized log storage.

5.3.8.5.3 Security Controls

SEC-CTL-SLM-SST-1: Centralized storage for security log data should be realized using centralized logging servers or cloud-based services.

SEC-CTL-SLM-SST-2: Tamper-proof storage of security log data may be achieved through digital signature, encryption, and hashing techniques.

SEC-CTL-SLM-SST-3: The retention period should be based on legal, regulatory, and compliance requirements, as well as the organization's own policies.

5.3.8.6 Secure Transfer of security log data

5.3.8.6.1 Introduction

Security log transfer involves the movement of security log data from one location to another, such as from a local device to a centralized logging server.

5.3.8.6.2 Requirements

REQ-SEC-SLM-STR-1: Security log data shall be confidentiality- and integrity- protected during transfer to protect them from unauthorized access or tampering.

REQ-SEC-SLM-STR-2: The parties involved in the security log transfer shall mutually authenticate each other to ensure that the logs are coming from a trusted source and going to a trusted destination. Failures detected during the authentication shall be logged.

REQ-SEC-SLM-STR-3: Mechanisms shall be in place to ensure the integrity of the security log data during transfer.

REQ-SEC-SLM-STR-4: The log transfer process shall be auditable to enable the tracking and identification of any unauthorized or suspicious log transfers.

REQ-SEC-SLM-STR-5: An O-RAN component may support log streaming for security log events.

5.3.8.6.3 Security Controls

SEC-CTL-SLM-STR-1: O-RAN architecture elements may support secure transfer of security log data using FTPES, as specified in O-RAN Security Protocols Specifications [3], clause 6.3.

SEC-CTL-SLM-STR-2: An O-RAN component may support the transport of Syslog as defined in RFC 5424 [64] over TLS as defined in RFC 5425 [65] for log streaming of security log events.

SEC-CTL-SLM-STR-3: O-RAN architecture elements may support secure transfer of security log data using SFTP, as specified in O-RAN Security Protocols Specifications [3], clause 6.2.

5.3.8.7 Log Format

5.3.8.7.1 Introduction

Each O-RAN component produces logs in various formats. The logs are collected at a central and trusted location where the logs are unified.

5.3.8.7.2 Requirements

REQ-SEC-SLM-FMT-1: Security logs shall be formatted in a consistent, standard, and machine-readable format that maintains backward compatibility with previous log format versions.

5.3.8.8 Log Fields

5.3.8.8.1 Introduction

To enable effective security analytics, it is important to include additional details in the security logs of the security event. These details help to identify adversarial operations within the O-RAN environment. A typical security log entry consists of two main parts: the log fields and the log message. The log fields provide metadata about the security log entry, while the log message contains the actual content and details of the security event being logged. The requirements specified in this clause pertain to the log fields.

5.3.8.8.2 Requirements

REQ-SEC-SLM-FLD-1: Security logs shall include the date and time of the security event for each log entry, using a consistent and standardized format that logs time to at least the second.

REQ-SEC-SLM-FLD-2: Security logs shall record the location of the security event for each log entry. For network transactions, the location shall incorporate both the source and destination IP addresses. In cases where security events transpire within a single component, the location field shall only contain the source IP address.

REQ-SEC-SLM-FLD-3: Security logs shall include the entity that is the cause of the security event for each log entry.

5.3.8.8.3 Security Controls

SEC-CTL-SLM-FLD-1: Security logs should use the ISO 8601 date and time format [62].

SEC-CTL-SLM-FLD-2: Security logs shall use IP addresses for the location field.

5.3.8.9 Authenticated Time Stamping and Missing Time Source

5.3.8.9.1 Requirements

REQ-SEC-SLM-ATS-1: All network functions shall be synchronised to a common and authenticated time source.

REQ-SEC-SLM-ATS-2: Any successful as well as the unsuccessful synchronization to the common time source shall be logged.

REQ-SEC-SLM-ATS-3: The Security Log-data shall be time-stamped with the system time in case of unsuccessful synchronisation to a common time source.

REQ-SEC-SLM-ATS-4: The Security Log-data recording shall take place in the order in which the (security) log events occur.

REQ-SEC-SLM-ATS-5: The Security Log data shall contain a timestamp that includes a timezone.

5.3.8.9.2 Security Controls

5.3.8.9.2.1 Authenticated Time Stamping

SEC-CTL-SLM-ATS-1: The Network Time Protocol (NTP) version 4 should be supported as specified by RFC5905[60] for the support of authenticated time stamping.

SEC-CTL-SLM-ATS-2: If NTPv4 authentication is in use, then AES-CMAC as specified by RFC4493 [78] shall be supported. In this use case the NTP client can verify the integrity of the received NTP-packet.

SEC-CTL-SLM-ATS-3: If NTP security (as specified by RFC5905 [60]) is in use for the integrity and replay protection of NTP-packets, then NTS (RFC8915 [63]) shall be supported.

NOTE: In this use case the NTP client may verify the authenticity of the NTP packets by use of X.509 PKI infrastructure.

5.3.8.9.2.2 Common Time Source

SEC-CTL-SLM-CTS-1: The Time Stamp representation should be in a standardized format, and the format in use should be logged. For reference to the formatting please refer to RFC 3339 [61] and ISO 8601 [62].

5.3.8.10 Void

5.3.8.11 Security Events to be Logged

5.3.8.11.1 Introduction

During O-RAN operations, components generate many events. Some of these events have security utility and are thus termed security events. Logging these security events is critical to maintaining a secure O-RAN environment. For convenience, security event log requirements are organized by high-level categories. These categories are mapped against the following O-RAN architectural elements: SMO, O-RAN Network Functions (NF), and O-Cloud (see Table 5.3.8.11.1-1).

- The SMO has security events related to management and orchestration.
- O-RAN Network Functions have application security events.
- O-Cloud has both network security events and system security events related to operating systems, hypervisors, and container runtimes.
- The following security event types occur in all O-RAN components (SMO, O-RAN NF, and O-Cloud): account and identity event, data access events, and general security events.

Table 5.3.8.11.1-1: Types of Security Events by O-RAN Component

Types of Security Events	O-RAN Architectural Component		
	SMO	O-RAN NF	O-Cloud
Management and Orchestration Events	X		
Application Events		X	
Network Events			X
System Events			X
Data Access Events	X	X	X
Account and Identity Events	X	X	X
General Security Events	X	X	X

5.3.8.11.2 Network Security Event Log Requirements

REQ-SEC-SLM-NET-EVT-1: O-Cloud shall log all physical and virtual network events related to creating and modifying network configurations, enabling, and disabling ports, network connections, and packets over limit from the firewalls from all host operating systems, hypervisors, and container engines.

5.3.8.11.3 System Security Event Log Requirements

5.3.8.11.3.1 General O-Cloud Security Events

5.3.8.11.3.1.1 Requirements

REQ-SEC-SLM-GEN-EVT-1: O-Cloud shall log the following resource-related events: shortages, system crashes, reboots, shutdowns, resource creation, and deletion from all host operating systems, hypervisors, and container engines.

REQ-SEC-SLM-GEN-EVT-2: O-Cloud shall log when maintenance activity is undertaken for host operating systems, hypervisors, and container engines.

REQ-SEC-SLM-GEN-EVT-3: O-Cloud shall log the creation of scheduled jobs and the particular time the job will run for all host operating systems, hypervisors, and container engines.

REQ-SEC-SLM-GEN-EVT-4: O-Cloud shall log a security event when driver tampering is detected.

NOTE: This includes but is not limited to modifications made to the main driver executable and any associated files, libraries, dependencies, or configuration files.

REQ-SEC-SLM-GEN-EVT-5: O-Cloud shall log a security event when it detects unauthorized changes to the O-Cloud hardware resource configuration.

REQ-SEC-SLM-GEN-EVT-6: O-Cloud shall log a security event when it detects unauthorized changes to the Application configuration.

5.3.8.11.3.1.2 Security Controls

SEC-CTL-SLM-GEN-EVT-1: O-Cloud shall log a security event if driver signature verification fails.

SEC-CTL-SLM-GEN-EVT-2: O-Cloud shall implement a robust File Integrity Monitoring (FIM) system that continuously monitors the integrity of all driver-related files, including executables, libraries, configuration files, and dependencies. The FIM system shall be configured to calculate cryptographic hashes of these files as baseline values and regularly compare the current cryptographic hashes with their baseline hashes stored in the FIM system.

SEC-CTL-SLM-GEN-EVT-3: O-Cloud shall log a security event if any hashes of driver files do not match their baseline values.

SEC-CTL-SLM-GEN-EVT-4: Baseline configurations for the hardware resource shall be established by the SMO, and regularly compared to the current state.

SEC-CTL-SLM-GEN-EVT-5: O-Cloud shall log a security event when it detects unauthorized deviation from the O-Cloud hardware resource configuration baseline.

SEC-CTL-SLM-GEN-EVT-6: Baseline configurations for each Application shall be established by the SMO, and regularly compared to the current state.

SEC-CTL-SLM-GEN-EVT-7: O-Cloud shall log a security event when it detects unauthorized deviation from the Application configuration baseline.

NOTE: Log management systems, such as SIEM, fall beyond the purview of O-RAN and are considered external entities. In the context of O-Cloud, it's recommended to set up these log management systems to dispatch notifications to the administrator when any of the following security events take place:

- Driver signature verification fails.
- Driver file hash verification fails.
- Unauthorized deviations from the O-Cloud hardware resource configuration baseline are detected.
- Unauthorized deviations from the application configuration baseline are detected.

5.3.8.11.3.2 Hypervisor Specific System Security Events

REQ-SEC-SLM-HYP-EVT-1: O-Cloud shall log all changes to operating system configurations, hypervisor configurations, changes to virtualization settings, and changes to resource allocations.

REQ-SEC-SLM-HYP-EVT-2: O-Cloud shall log all hypervisor events related to attaching or detaching virtual disks.

REQ-SEC-SLM-HYP-EVT-3: O-Cloud shall log all hypervisor events related to creating, starting, stopping, restarting, and deleting virtual machines.

5.3.8.11.3.3 Container Engine Specific System Events

REQ-SEC-SLM-CON-EVT-1: O-Cloud shall log all image repository events related to additions, modifications, and removal of images.

REQ-SEC-SLM-CON-EVT-2: O-Cloud shall log all container engine events related to volume creation, deletion, and mounting.

REQ-SEC-SLM-CON-EVT-3: O-Cloud shall log all container engine events related to creating, starting, stopping, restarting, and deleting containers.

5.3.8.11.4 Application Security Event Log Requirements

REQ-SEC-SLM-APP-EVT-1: O-RAN Network Functions shall log any errors or exceptions generated.

REQ-SEC-SLM-APP-EVT-2: O-RAN Network Functions shall log the use of any dynamically loaded libraries, including the name and version information of the library being loaded.

5.3.8.11.5 Data Access Security Event Log Requirements

REQ-SEC-SLM-DAT-EVT-1: O-RAN components shall log successful file additions, deletions, and unsuccessful attempts due to errors and authorization issues.

REQ-SEC-SLM-DAT-EVT-2: O-RAN components should log successful file reads and writes.

REQ-SEC-SLM-DAT-EVT-3: O-RAN components shall log unsuccessful attempts of file reads and writes due to errors and authorization issues.

REQ-SEC-SLM-DAT-EVT-4: O-RAN components shall log successful directory additions, deletions, and unsuccessful attempts due to errors and authorization issues.

REQ-SEC-SLM-DAT-EVT-5: O-RAN components shall log successful database or data store additions, deletions, and unsuccessful attempts due to errors and authorization issues.

REQ-SEC-SLM-DAT-EVT-6: O-RAN components should log successful database or data store reads and writes.

REQ-SEC-SLM-DAT-EVT-7: O-RAN components shall log unsuccessful attempts of database and data store reads and writes.

REQ-SEC-SLM-DAT-EVT-8: O-RAN components shall log permission changes to files, directories, databases, or data stores.

5.3.8.11.6 Account and Identity Security Event Log Requirements

REQ-SEC-SLM-AAI-EVT-1: O-RAN components shall log account creation, modification, deletion, and unsuccessful attempts.

REQ-SEC-SLM-AAI-EVT-2: O-RAN components shall log changes to account privilege levels and unsuccessful attempts.

REQ-SEC-SLM-AAI-EVT-3: O-RAN components shall log successful group membership changes for accounts and unsuccessful change attempts.

REQ-SEC-SLM-AAI-EVT-4: O-RAN components shall log successful and unsuccessful authentication attempts for accounts.

REQ-SEC-SLM-AAI-EVT-5: O-RAN components shall log successful and unsuccessful authorization attempts to create a session or initiate a transaction.

REQ-SEC-SLM-AAI-EVT-6: O-RAN components shall log the termination of sessions or transactions.

REQ-SEC-SLM-AAI-EVT-7: O-RAN components shall log the occurrence of downgraded privileges or elevation of privileges for accounts.

REQ-SEC-SLM-AAI-EVT-8: Void

REQ-SEC-SLM-AAI-EVT-9: O-RAN components shall log transactions successfully executed by accounts and unsuccessful attempts.

REQ-SEC-SLM-AAI-EVT-10: O-RAN components shall log requests that do not require an authenticated account.

5.3.8.11.7 General Security Event Log Requirements

REQ-SEC-SLM-GSE-1: O-RAN components shall log the activation and deactivation of security software related to security logging, firewalls, malware protection, data loss prevention (DLP), and intrusion detection systems (IDS).

REQ-SEC-SLM-GSE-2: O-RAN components shall log the use of administrative privileges.

REQ-SEC-SLM-GSE-3: O-RAN components shall log any change to a security-related configuration item, including a description of the configuration change.

REQ-SEC-SLM-GSE-4: O-RAN components shall log the occurrence of viewing, renewing, exporting, importing, modifying, and deleting of certificates and keys. The logged data for these events shall not include any sensitive information related to the certificates or the keys.

REQ-SEC-SLM-GSE-5: O-RAN components shall log the occurrence of cryptographic operations on resources involved in signatures, encryption, decryption, hashing, key generation, and key destruction. The logged data for these events shall not include any sensitive information related to the cryptographic operations.

REQ-SEC-SLM-GSE-6: O-RAN components shall log security patches submitted but not applied.

5.3.8.12 Log data Lifecycle Management

REQ-SEC-LCSS-2: The Security Log data process shall support Log data rotation.

NOTE: Log data rotation in this context refers to a closing of a Log-storage and opening a new Log-storage when the first Log-storage is complete.

REQ-SEC-LCSS-3: The Security Log data rotation process shall be configurable at regular time intervals and when the maximum log size is reached.

REQ-SEC-LCSS-4: The Security Log data process shall log any log rotation reconfiguration.

REQ-SEC-LCSS-5: The system shall be capable of creating, processing, transmitting, and always storing all required security log events.

5.3.8.13 Requirements on Security Log data Policy

REQ-SEC-POL-5: The archived Security Log data and their storage media shall be checked periodically to determine whether the Security Log data is accessible.

REQ-SEC-POL-6: The archived Log data and their media shall be physically protected.

REQ-SEC-POL-7: The personally identifiable information (PII) shall be removed from archived Security Log data. For details on PII please refer to ([68]).

REQ-SEC-POL-8: The archived Security Log data shall be integrity and confidentiality protected.

REQ-SEC-POL-9: For the Security Log data lifecycle a policy shall be supported for log retention and log preservation. If this provides filter options, then security Log data shall not be filtered out.

REQ-SEC-POL-10: The log policy shall include requirements for log generation, log transmission, storage and disposal, and log analysis.

5.3.8.14 Preventing (D)DoS to Security Log Data

5.3.8.14.1 General

The Requirements below are applicable to the vendors of the log management infrastructure.

5.3.8.14.2 Requirements

REQ-SEC-SLM-DoS-1: The log management infrastructure should be designed to support typical and peak volume of log data to be processed per hour and day [58].

REQ-SEC-SLM-DoS-2: The log management infrastructure should support the handling of peak situations for extreme situations [58].

NOTE 1: Extreme situations in this context refer to widespread malware incidents, vulnerability scanning, and penetration tests that might cause unusual large number of log entries.

REQ-SEC-SLM-DoS-3: The log management infrastructure should provide notifications at different log data volumes.

NOTE 2: This refers to the introduction of escalation levels at different log data volumes.

REQ-SEC-SLM-DoS-4: The log management infrastructure should provide notifications at different log data event rates.

NOTE 3: This refers to the introduction of escalation levels at different log data event rates.

REQ-SEC-SLM-DoS-5: The log management infrastructure should support mechanisms for log data redundancy.

REQ-SEC-SLM-DoS-6: The log management infrastructure should trigger the archiving of log data based on the level of escalation achieved.

NOTE 4: The escalation level may be triggered by increased log data volume or log data event rates.

REQ-SEC-SLM-DoS-7: The log management infrastructure should trigger the retention of log data based on the level of escalation achieved.

NOTE 5: The escalation level may be triggered by increased log data volume or log data event rates.

5.3.8.15 Preventing Tampering of Log Data

5.3.8.15.1 General

The Requirements below are applicable to the vendors of the log management infrastructure.

5.3.8.15.2 Requirements

REQ-SEC-SLM-TLD-1: The log management infrastructure should support access management for log data.

REQ-SEC-SLM-TLD-2: The log management infrastructure should support real time logging (log data streaming).

REQ-SEC-SLM-TLD-3: The log management infrastructure should support replication of log data.

REQ-SEC-SLM-TLD-4: The log management infrastructure should support the derivation of digests of log-data to existing and preceding digests with the aim to keep the cryptographic chain and to attest the completeness and the integrity of the security events.

5.3.9 Certificate Management Framework

5.3.9.1 Requirements

5.3.9.1.1 PNFs

REQ-SEC-CMF-PNF-1: An O-RAN PNF requiring a PKI certificate shall support certificate management protocol.

REQ-SEC-CMF-PNF-2: In order to facilitate vendor certificate-based initial enrolment of PNFs, vendors shall pre-install vendor-signed certificates in PNFs.

REQ-SEC-CMF-PNF-3: In order to facilitate vendor certificate-based initial enrolment of PNFs, operators shall pre-provision the FQDN/IP address of RA/CA to PNFs.

EXAMPLE 1: pre-configurations before deployment

EXAMPLE 2: startup installation procedure as defined in [14], clause 6.1.

REQ-SEC-CMF-PNF-4: PNFs which use vendor-signed certificates for initial certificate enrolment should monitor the expiry of the vendor root CA certificate or any of the sub-CA certificates in the trust chain used to sign the certificate.

REQ-SEC-CMF-PNF-5: When the expiry of the vendor root CA certificate or any of the sub-CA certificates in the trust chain is approaching, PNFs should raise notifications (alarms) with increasing levels of severity as the expiry date gets closer.

REQ-SEC-CMF-PNF-6: In the event the secure storage space has exceeded the configured storage limits, the PNF should raise notifications and/or alarms.

5.3.9.1.2 VNFs/CNFs

REQ-SEC-CMF-VNF_CNF-1: The O-Cloud shall support a certificate management protocol for use by O-RAN VNFs/CNFs that require a PKI certificate.

REQ-SEC-CMF-VNF_CNF-2: An O-RAN VNF/CNF requiring a PKI certificate directly from a CA/RA, without O-Cloud involvement, shall support a certificate management protocol.

REQ-SEC-CMF-VNF_CNF-3: SMO shall configure all the initial information needed for certificate enrolment during NF Deployment of a VNF/CNF.

5.3.9.1.3 Any NF (PNF/VNF/CNF)

REQ-SEC-CMF-ANYNF-1: Any offline or out-of-band (automated or manual) PSK/Refnum generation, distribution and provisioning systems shall provide PSK/Refnum values only to an authorized PNF/CNF/VNF.

REQ-SEC-CMF-ANYNF-2: NFs shall raise alarms/notifications and/or security events alerting about the certificates about to expire in the near future with increasing severity levels as the expiry date approaches.

REQ-SEC-CMF-ANYNF-3: SMO or certificate management systems should instruct NFs to trigger certificate renewal procedures according to operator's policies.

EXAMPLE 1: Policy 1: instruct NFs to trigger certificate renewals in a staggered manner

EXAMPLE 2: Policy 2: instruct NFs to trigger certificate renewals according to resource availability

REQ-SEC-CMF-ANYNF-4: NFs shall provide interfaces to allow configuration of the advance alarms/notifications/security events interval prior to certificate expiry for different severity levels.

EXAMPLE 3: Configuration: Minor alarm N1 days before expiry, Major alarm, and security event N2 days before expiry, Critical alarm, and security events N3 days before expiry of certificates, Critical alarm, and security event every day after expiry.

REQ-SEC-CMF-ANYNF-5: NFs shall trigger certificate renewal procedure before the certificate expiry using policies provided by the operator.

EXAMPLE 4: Policy 1: Trigger renewal N1/N2/N3 days before expiry.

EXAMPLE 5: Policy 2: Trigger renewal when instructed by SMO or certificate management.

REQ-SEC-CMF-ANYNF-6: NFs shall provide interfaces to enable certificate management systems to trigger certificate renewal before the expiry.

REQ-SEC-CMF-ANYNF-7: NFs shall send a notification to the SMO indicating the success or failure state after the certificate renewal completion.

REQ-SEC-CMF-ANYNF-8: NFs shall raise a critical alarm as well as log security events if the certificate for NF(s) has expired.

REQ-SEC-CMF-ANYNF-9: NFs should raise a critical alarm as well as log security events if the certificate renewal has failed.

REQ-SEC-CMF-ANYNF-10: In the event the newly installed/renewed certificate fails, the NF shall continue to use its previous certificate until that certificate expires.

REQ-SEC-CMF-ANYNF-11: CRL servers (either LDAP or HTTP access as stated in clause 6.1.1 of the 3GPP TS 33.310[2]) should be used by NFs to check the revocation status of certificates.

REQ-SEC-CMF-ANYNF-12: In the event of failure to connect with CRL servers, notifications and/or alarms should be raised by NFs.

5.3.9.1.4 O-Cloud

REQ-SEC-CMF-O-CLOUD-1: In the event the secure storage space has exceeded the configured storage limits, the O-Cloud should raise notifications and/or alarms.

REQ-SEC-CMF-O-CLOUD-2: The O-Cloud shall support automated certificate lifecycle management.

REQ-SEC-CMF-O-CLOUD-3: The O-Cloud shall support integration with external CAs for the issuance of certificates.

REQ-SEC-CMF-O-CLOUD-4: The O-Cloud shall implement secure and robust mechanisms for the generation of cryptographic keys.

5.3.9.2 Security Controls

5.3.9.2.1 PNFs

SEC-CTL-CMF-PNF-1: An O-RAN PNF requiring a PKI certificate shall support CMPv2 as specified in O-RAN Security Protocols Specifications [3], clause 4.6.

5.3.9.2.2 VNFs/CNFs

SEC-CTL-CMF-VNF_CNF-1: Void

SEC-CTL-CMF-VNF_CNF-2: An O-RAN VNF/CNF requiring a PKI certificate from a CA/RA shall support CMPv2 as specified in O-RAN Security Protocols Specifications [3], clause 4.6.

5.3.9.2.3 Any NF (PNF/VNF/CNF)

SEC-CTL-CMF-ANYNF-1: NFs may establish TLS connection using renewed certificates before terminating existing TLS connections.

SEC-CTL-CMF-ANYNF-2: NFs may terminate any established TLS connection after the renewed certificates are validated and re-establish TLS connection with new certificate.

SEC-CTL-CMF-ANYNF-3: NFs may wait for already established TLS connections to close before applying the renewed certificate for new TLS connections.

5.3.10 Application Programming Interfaces (APIs)

5.3.10.1 Introduction

An Application Programming Interface (API) is implemented by a software program to be able to interact with other software programs as defined in [i.16]. An API is a set of libraries or specifications which allows interaction with an external artefact or agent from a third party. The APIs which comply with the REST constraints are said to be RESTful and refer to the description of a communication interface that allows interacting with a system based on the REST architecture style.

The specification of RESTful APIs plays its role at given an interface between two components in the system architecture, a RESTful API provides the implementation details for the communication between these two entities, which are then identified as the API Producer (or Server) and the API Consumer (or Client).

The security requirements in this clause provide protections against the vulnerabilities and security risks identified in the OWASP API Security Project Top 10 2023 vulnerabilities and security risks of Application Programming Interfaces (APIs) [i.9]. APIs as referred to in this clause are transactional APIs based on REST or gRPC. The terms client, resource owner, and resource server are defined in IETF RFC 6749 [34].

5.3.10.2 Security Requirements

REQ-SEC-API-1: APIs used in O-RAN to access an internal or external data source should perform object-level authorization checks.

REQ-SEC-API-2: O-RAN endpoints using APIs shall support certificate-based authentication.

REQ-SEC-API-3: O-RAN endpoints using APIs may support password-based authentication that is a factor used in multi-factor authentication (MFA).

REQ-SEC-API-3a: Password-based single-factor authentication should not be used when O-RAN endpoints are using APIs.

REQ-SEC-API-4: O-RAN endpoints using APIs should provide strong authorization with the principle of least privilege.

REQ-SEC-API-5: O-RAN endpoints using APIs shall validate the authenticity of tokens. Unsigned JWT tokens shall not be accepted.

REQ-SEC-API-6: O-RAN endpoints shall validate API client requests prior to returning sensitive data.

REQ-SEC-API-7: APIs used in O-RAN shall have confidentiality and integrity protection for data-in-transit.

REQ-SEC-API-8: APIs used in O-RAN shall implement a schema-based validation mechanism to enforce returned data.

REQ-SEC-API-9: APIs used in O-RAN shall impose a restriction on the size and number of resources that a client requests.

REQ-SEC-API-10: APIs used in O-RAN shall support authorization that denies all access by default and requires explicit grants to specific roles for access to every function.

REQ-SEC-API-11: APIs used in O-RAN shall default-deny properties that should not be accessed by clients.

REQ-SEC-API-12: APIs used in O-RAN shall only be accessed by valid HTTP verbs. All other HTTP verbs should be disabled.

REQ-SEC-API-13: APIs used in O-RAN shall validate, filter, and sanitize client-provided data and other data coming from integrated systems. Data validation shall be performed using a single, trustworthy, and actively maintained library. Special characters shall be escaped using the specific syntax for the target interpreter.

REQ-SEC-API-14: APIs used in O-RAN shall limit the number of returned records to prevent mass disclosure in case of injection.

REQ-SEC-API-15: APIs used in O-RAN shall log all failed authentication attempts, denied access, and input validation errors.

5.3.10.3 Security Controls

SEC-CTL-API-01: API client and server shall support mTLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2, with PKI using X.509v3 certificates for mutual authentication.

SEC-CTL-API-02: API server shall support OAuth 2.0 resource server functionality, as specified in O-RAN Security Protocols Specifications [3], clause 4.7, for service requests received from API clients.

SEC-CTL-API-03: API server shall support OAuth 2.0 resource owner functionality, as specified in O-RAN Security Protocols Specifications [3], clause 4.7, for service requests received from API clients.

SEC-CTL-API-04: API client shall support OAuth 2.0 client functionality, as specified in O-RAN Security Protocols Specifications [3], clause 4.7 for each service request.

SEC-CTL-API-05: API client and server shall support TLS, as specified in O-RAN Security Protocols Specifications [3], clause 4.2, for protection of data-in-transit.

5.3.11 Trust Anchor Provisioning

5.3.11.0 General

Before an O-RAN component can establish a mutual TLS connection with a signaling peer, the O-RAN component needs to be able to trace the peer's certificate path to a valid trust anchor.

5.3.11.1 Requirements

REQ-SEC-TAP-1: An O-RAN PNF using PKIX certificates shall be shipped with one or more pre-provisioned Trust Anchors.

REQ-SEC-TAP-1a: Pre-provisioned Trust Anchors that are used by an O-RAN PNF using PKIX certificates may be vendor-signed certificates or operator-signed certificates.

REQ-SEC-TAP-2: An O-RAN PNF shall support the secure storage of the trust anchors in a secure element or a secure enclave such that they cannot be tampered with or modified.

REQ-SEC-TAP-3: An O-RAN PNF using PKIX certificates shall enable an authorized function to recover the list of provisioned trust anchors and associated public keys.

REQ-SEC-TAP-4: An O-RAN PNF shall be able to be securely provisioned with new trust anchors and have an existing trust anchor replaced, for events such as expiration.

REQ-SEC-TAP-5: An O-RAN PNF shall log an event for each trust anchor provisioning operation.

5.3.11.2 Security Controls

SEC-CTL-TAP-1: An O-RAN PNF shall support CMPv2, as specified in O-RAN Security Protocols Specifications [3], clause 4.6, for trust anchor provisioning.

SEC-CTL-TAP-2: An O-RAN PNF may support voucher-based protocols [69] to enable an O-RAN function to be securely provisioned with a new trust anchor.

SEC-CTL-TAP-3: An O-RAN PNF may support BRSKI [70] for trust anchor provisioning.

SEC-CTL-TAP-4: An O-RAN PNF may support SZTP [71] for trust anchor provisioning.

SEC-CTL-TAP-5: An O-RAN PNF may support 3GPP SCS [72], [73], [74] for download of initial security configuration.

5.3.12 AI/ML Security

5.3.12.1 Introduction

This clause outlines the security requirements and controls for AI/ML in the O-RAN architecture, with the goal of ensuring the confidentiality, integrity, and availability of AI/ML models, data, and decision-making processes. For requirements and security controls on logging of AI/ML related security events see clause 5.1.8 of the present document.

5.3.12.2 Requirements

REQ-SEC-AIML-1: Access to AI/ML models shall be authenticated and authorized.

REQ-SEC-AIML-2: The systems controlling access to AI/ML models shall enforce access control policies that align with the principle of least privilege.

REQ-SEC-AIML-3: AI/ML models shall be protected in terms of integrity and confidentiality at rest, in use and in transit.

REQ-SEC-AIML-4: Input data used for AI/ML model training, testing and inference shall be sourced only from verified sources.

REQ-SEC-AIML-5: Data used for or produced by AI/ML model training, testing and inference shall be protected in terms of integrity and confidentiality at rest, in use and in transit.

REQ-SEC-AIML-6: Access to data used for or produced by AI/ML model training, testing and inference shall be authenticated and authorized.

REQ-SEC-AIML-7: Access control to data used for or produced by AI/ML model training, testing and inference shall enforce access control policies that align with the principle of least privilege.

REQ-SEC-AIML-8: An AI/ML model training process may incorporate differential privacy to prevent the model from memorizing sensitive information, thereby reducing the risk of data leakage.

REQ-SEC-AIML-9: An AI/ML model inference process may apply differential privacy to the outputs of AI/ML models, ensuring that query responses do not reveal sensitive information about individual data points.

REQ-SEC-AIML-10: AI/ML Training service Producer may check that the AI/ML model is not poisoned after the AI/ML Model evaluation.

NOTE 1: Clause 5.1.3.2.4 of [i.17] details the Model evaluation for ML Testing

REQ-SEC-AIML-11: AI/ML Training service Producer may evaluate that the AI/ML model is not poisoned, before notifying the AI/ML training services Consumer about the completion of the training.

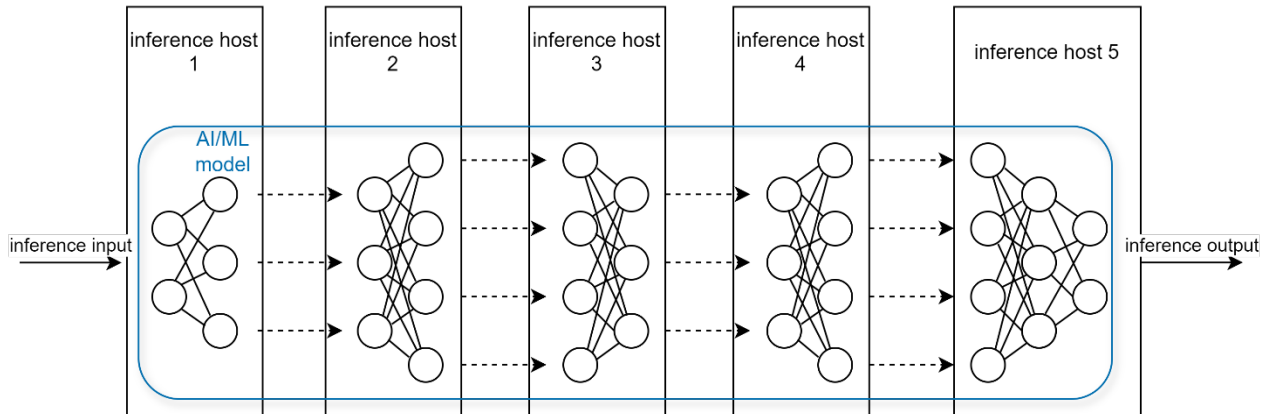


Figure 5.3.12.2-1: EXAMPLE of a deep neural network AI/ML model split across five inference

REQ-SEC-AIML-12: An O-RAN architecture element processing, storing or transferring AI/ML models may support the splitting of AI/ML models to enhance security and privacy.

EXAMPLE: Figure 5.3.12.2-1 shows a drawing of an example inference process with a deep neural network AI/ML model split across five different inference hosts.

REQ-SEC-AIML-13: Sanitization of input data before the data is used for AI/ML models' training shall be supported.

REQ-SEC-AIML-14: Selection of a reduced set of relevant features for the AI/ML model training may be supported, to reduce the likelihood of attacks caused by feature manipulation.

REQ-SEC-AIML-15: Feature scaling of input data such that AI/ML model classifications are less susceptible to small variations in the input data may be supported.

REQ-SEC-AIML-16: The AI/ML training service Producer shall support the application of adversarial training to AI/ML models to enable the Models to be robust.

REQ-SEC-AIML-17: An ML Training/Inference host shall support authentication and authorization of all requests/triggers related to the life-cycle operations of AI/ML models.

REQ-SEC-AIML-18: An ML Training/Inference host shall enforce access control policies that align with the principle of least privilege of all requests/triggers related to the life-cycle operations of AI/ML models.

REQ-SEC-AIML-19: During inference, the AI/ML model should be capable of handling perturbations that are a small fraction of the input scale in model input data without degradation from target performance.

REQ-SEC-AIML-20: Ensemble methods may be supported in AI/ML training and inference to mitigate security weaknesses of individual AI/ML models.

REQ-SEC-AIML-21: AI/ML Model training service shall support retraining of the AI/ML Models with fresh and clean data to reduce potential vulnerabilities of static AI/ML Models and the impact of stale poisoned samples.

NOTE 2: AI/ML Model retraining helps ensure that the models adapt to evolving data and are agile moving targets. This increases the effort required for attackers to keep up with changes and adapt their extraction techniques.

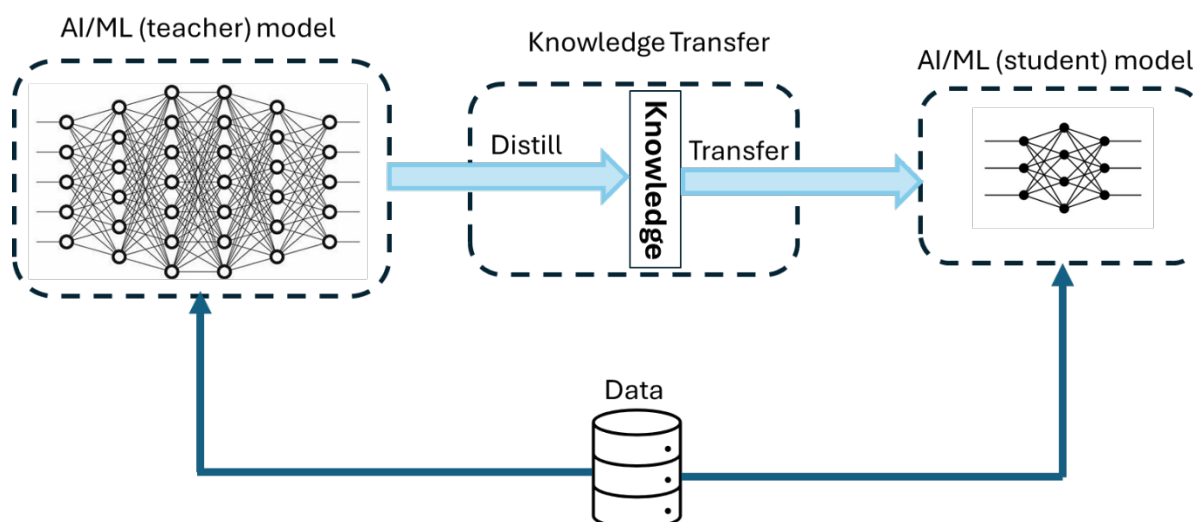


Figure 5.3.12.2-2 : Example of an AI/ML (teacher) model distillation into an AI/ML (student) model [i.25].

REQ-SEC-AIML-22: AI/ML model training may support distillation of AI/ML (teacher) models by training a simpler AI/ML (student) model on their outputs to mitigate information extraction attacks on the AI/ML (teacher) models.

EXAMPLE: Figure 5.3.12.2-2 depicts an example distillation of a AI/ML (teacher) model [i.25]

REQ-SEC-AIML-23: The AI/ML inference service producer should support techniques to obscure the relationship between energy consumption and the computations being performed.

EXAMPLE: Techniques such as power randomization, dynamic voltage and frequency scaling, or spreading energy usage over time can be employed to achieve this requirement.

REQ-SEC-AIML-24: The AI/ML inference service provider should support techniques to equalize computation times across different operations.

EXAMPLE: Techniques such as constant-time algorithms or buffering outputs to ensure uniform response times can be used to fulfill this requirement.

REQ-SEC-AIML-25: The AI/ML inference service provider should support continuous monitoring of energy consumption of AI/ML processes.

EXAMPLE: Machine learning models can be used to baseline normal energy patterns and detect anomalies indicative of potential attacks.

REQ-SEC-AIML-26: The AI/ML inference service provider should support continuous monitoring of processing latencies of AI/ML processes.

EXAMPLE: Machine learning models can be used to baseline normal latency patterns and detect anomalies indicative of potential attacks.

REQ-SEC-AIML-27: Data augmentation for AI/ML Model training may be supported to enhance robustness of AI/ML Models to small perturbations in input features.

REQ-SEC-AIML-28: Explainable AI techniques applied to AI/ML Models may be supported to enhance detection of AI/ML Model anomalous behaviour.

REQ-SEC-AIML-29: AI/ML Model training service may support the embedding of a unique cryptographic watermark into the AI/ML model in training during the training phase.

REQ-SEC-AIML-30: An AI/ML model shall be digitally signed by the Solution Provider prior to onboarding.

REQ-SEC-AIML-31: An AI/ML training service shall support the signing of AI/ML models after training.

REQ-SEC-AIML-32: An AI/ML training, inference or storage host shall support the verification of the digital signature(s) of an AI/ML model.

REQ-SEC-AIML-33: The AI/ML training service producer may support training of AI/ML Models using distributed data and computation to mitigate information extraction and membership inference attacks.

EXAMPLE: Use cases such as Dynamic spectrum sharing, and Energy Savings could use global data spanning distributed cell sites, and create/compute models with distributed data, thereby achieving the intended optimization while enabling information protection.

REQ-SEC-AIML-34: An AI/ML training or inference host shall support isolation mechanisms to ensure computational and resource separation between AI/ML workloads of different tenants, preventing the workloads from interfering with or obtaining information about each other.

REQ-SEC-AIML-35: The AI/ML training service provider may support AI/ML model obfuscation techniques.

6 SBOM Guidelines for O-RAN

6.1 SBOM Overview

This clause provides guidance for generation, delivery, and use of a software bill of materials (SBOM).

SBOM is a fundamental component of a mature Software Development Lifecycle (SDLC) process. SBOM is an industry best practice part of secure software development that enhances the understanding of the upstream software supply chain so that vulnerability notifications and updates can be properly and safely handled across the installed customer base. The U.S. Department of Commerce (DoC) and the National Telecommunications and Information Administration (NTIA) define SBOM as “a formal record containing the details and supply chain relationships of various components used in building software.” The DoC, in coordination with NTIA, published a report “The Minimum Elements for a Software Bill of Materials (SBOM)” [17] that provides guidance on the data fields, automation, and processes to be used by suppliers and customers. The SBOM documents proprietary and third-party software, including commercial and free and open-source software (FOSS), used in software products. The SBOM is maintained and used by the software supplier and stored and viewed by the network operator.

6.2

[Intentionally blank]

6.3 SBOM Requirements for O-RAN

6.3.1 Requirements

REQ-SBOM-001: The producer of O-RAN software shall create an SBOM for every O-RAN software package release.

REQ-SBOM-002: The minimum set of data fields shall include Supplier Name, Component Name, Version of the Component, Other Unique Identifiers as available, Dependency Relationship, Author of the SBOM data, and Timestamp [17].

REQ-SBOM-003: Vulnerabilities shall not be included as an additional data field because it would represent a static view from a specific point in time, while vulnerabilities are constantly evolving.

NOTE 1: The SBOM should be used by vendors and operators to periodically check against known vulnerability databases to identify potential risk.

NOTE 2: The level of risk for a vulnerability should be determined by the software vendor and operator with consideration of the software product, use case, and network environment.

NOTE 3: The SBOM provides visibility into the use of open-source and third-party provided software having known vulnerabilities or contributions from individuals or companies in adversarial nations, but it does not protect against zero-day vulnerabilities that were unintentionally or maliciously inserted, exploited, or discovered and not reported.

REQ-SBOM-004: An SBOM shall contain all primary (top level) components, with top-level dependencies listed with enough detail to seek out the transitive dependencies recursively.

REQ-SBOM-005: Void

REQ-SBOM-006: Void

REQ-SBOM-007: SBOM shall be authenticity and integrity protected.

REQ-SBOM-008: Void

REQ-SBOM-009: Void

REQ-SBOM-010: Void

REQ-SBOM-011: The SBOM shall be provided in Software Package Data eXchange (SPDX) [17], CycloneDX [18], or Software Identification (SWID) [19] format.

NOTE 5: ISO/IEC 5962:2021[21] - Information technology — SPDX® Specification V2.2.1, published August 2021, specifies SPDX as a standard data format for communicating the component and metadata information associated with SBOM.

6.3.2 Security Controls

SEC-CTL-SBOM-001: The SBOM for an O-RAN software package shall use hashing and digital signing as defined in O-RAN Security Protocols Specifications [3], clause 5.

SEC-CTL-SBOM-002: Void

Annex A (informative): Security Principles mapping to Security Requirements

EDITOR'S NOTE: The table needs to be finished.

Table A-1: Security Principles mapping to Security Requirements defined in [i.14].

	Components							Interfaces					
SP	O-R U	O-D U	O-C U	O-CLOUD	Nea r RT RIC	Non RT RI C	SM O	FH M- Plane	FH S- Plane	FH CU- Plane	E2	O1	A1
SP-AUTH				REQ- SEC- OCLOUD -1									
SP-ACC													

SP-CRYPTO													
SP-TCOMM											REQ-SEC-O2-1		REQ-SEC-A1-1
SP-SS													
SP-SB													
SP-UPDT													
SP-RECO													
SP-OPNS													
SP-ASSU													
SP-PRV													
SP-SLC													
SP-ISO				REQ-SEC-O2-1									
SP-PHY													
SP-CLD													
SP-ROB													

Annex B (informative): Security: List of 3GPP security requirements

Table B-1: References for 3GPP Security requirements

Reference	Title
TS 33.501	Security architecture and procedures for 5G system
TS 33.511	Security Assurance Specification (SCAS) for the next generation - Node B (gNodeB) network product class
TS 33.117	Catalogue of general security assurance requirements
TR 33.818	Security Assurance Methodology (SECAM) and Security Assurance Specification (SCAS) for 3GPP virtualized network products
TR 33.848	Study on security impacts of virtualization

Table B-2: 3GPP Security requirements

Item	Title	3GPP Security requirements	3GPP specifications	NESAS/SCAS
gNodeB-specific security functional requirements				
#1	Mitigation of bidding down attacks in Xn handovers	An attacker could attempt a bidding down attack by making the UE and the network entities respectively believe that the other side does not support a security feature, even when both sides in fact support that security feature. It shall be ensured that a bidding down attack, in the above sense, can be prevented. In the Path-Switch message, the target gNB shall send the UE's 5G security capabilities, UP security policy with corresponding PDU session ID received from the source gNB to the AMF.	TS 33.501 §5.1.1 & §6.7.3.1	TS 33.511 §4.2.2.1.14
#2	Authentication and Authorization	Access network authorization: Assurance shall be provided to the UE that it is connected to an access network that is authorized by the serving network to provide services to the UE. This authorization is 'implicit' in the sense that it is implied by a successful establishment of access network security. This access network authorization applies to all types of access networks.	TS 33.501 §5.1.2	
#3	Requirements on gNB related to keys	The gNB shall allow for use of encryption and integrity protection algorithms for AS (Access Stratum) and NAS (Non Access Stratum) protection having keys of length 128 bits. The network interfaces shall support the transport of 256-bit keys. The keys used for UP (User Plane), NAS and AS protection shall be dependent on the algorithm with which they are used.	TS 33.501 §5.1.3	
#4	Subscriber privacy	The SUPI should not be transferred in clear text over gNB except routing information, e.g. Mobile Country Code (MCC) and Mobile Network Code (MNC).	TS 33.501 §5.2.5	
#5	User data and signalling data confidentiality	The gNB shall support ciphering of user data between the UE and the gNB. The gNB shall activate ciphering of user data based on the security policy sent by the SMF. The gNB shall support ciphering of RRC-signalling. The gNB shall implement the following ciphering algorithms: - NEA0, 128-NEA1, 128-NEA2 as defined in Annex D of 3GPP TS 33.501. The gNB may implement the following ciphering algorithm: - 128-NEA3 as defined in Annex D of 3GPP TS 33.501. Confidentiality protection of user data between the UE and the gNB is optional to use. Confidentiality protection of the RRC-signalling is optional to use. Confidentiality protection should be used whenever regulations permit. The PDCP protocol, as specified in TS 38.323 between the UE and the NG-RAN, shall be responsible for user plane data confidentiality protection.	TS 33.501 §5.3.2	TS 33.511 §4.2.2.1.6 & §4.2.2.1.7 & §4.2.2.1.10 & §4.2.2.1.11

#6	User data and signalling data integrity	The gNB shall support integrity protection and replay protection of user data between the UE and the gNB. The gNB shall activate integrity protection of user data based on the security policy sent by the SMF. The gNB shall support integrity protection and replay protection of RRC-signalling. The gNB shall support the following integrity protection algorithms: - NIA0, 128-NIA1, 128-NIA2 as defined in Annex D of 3GPP TS 33.501. The gNB may support the following integrity protection algorithm: - 128-NIA3 as defined in Annex D of 3GPP TS 33.501. Integrity protection of the user data between the UE and the gNB is optional to use, and shall not use NIA0. All RRC signalling messages except those explicitly listed in TS 38.331 as exceptions shall be integrity-protected with an integrity protection algorithm different from NIA0, except for unauthenticated emergency calls. NIA0 shall be disabled in gNB in the deployments where support of unauthenticated emergency session is not a regulatory requirement. The PDCP protocol, as specified in TS 38.323 between the UE and the NG-RAN, shall be responsible for user plane data integrity protection.	TS 33.501 §5.3.3	TS 33.511 §4.2.2.1.1 & §4.2.2.1.2 & §4.2.2.1.8 & §4.2.2.1.9
#7	RRC integrity check failure	The RRC integrity checks shall be performed both in the ME and the gNB. In case failed integrity check (i.e. faulty or missing MAC-I) is detected after the start of integrity protection, the concerned message shall be discarded. This can happen on the gNB side or on the ME side.	TS 33.501 §6.5.1	
#8	UP integrity check failure	If the gNB or the UE receives a PDCP PDU which fails integrity check with faulty or missing MAC-I after the start of integrity protection, the PDU shall be discarded.	TS 33.501 §6.6.4	
#9	Requirements for the gNB setup and configuration	Setting up and configuring gNBs by O&M systems shall be authenticated and authorized by gNB so that attackers shall not be able to modify the gNB settings and software configurations via local or remote access. - The certificate enrolment mechanism specified in TS 33.310 for base station should be supported for gNBs. The decision on whether to use the enrolment mechanism is left to operators. - Communication between the O&M systems and the gNB shall be confidentiality, integrity and replay protected from unauthorized parties. The security associations between the gNB and an entity in the 5G Core or in an O&M domain trusted by the operator shall be supported. These security association establishments shall be mutually authenticated. The security associations shall be realized according to TS 33.210 and TS 33.310. - The gNB shall be able to ensure that software/data change attempts are authorized. - The gNB shall use authorized data/software. - Sensitive parts of the boot-up process shall be executed with the help of the secure environment. - Confidentiality of software transfer towards the gNB shall be ensured. - Integrity protection of software transfer towards the gNB shall be ensured. - The gNB software update shall be verified before its installation (cf. sub-clause 4.2.3.3.5 of TS 33.117).	TS 33.501 §5.3.4	

#10	Requirements for key management inside the gNB	Any part of a gNB deployment that stores or processes keys in cleartext shall be protected from physical attacks. If not, the whole entity is placed in a physically secure location, then keys in cleartext shall be stored and processed in a secure environment. Keys stored inside a secure environment in any part of the gNB shall never leave the secure environment except when done in accordance with 3GPP specifications.	TS 33.501 §5.3.5	
#11	Requirements for handling user plane data for the gNB	Any part of a gNB deployment that stores or processes user plane data in cleartext shall be protected from physical attacks. If not, the whole entity is placed in a physically secure location, then user plane data in cleartext shall be stored and processed in a secure environment.	TS 33.501 §5.3.6	
#12	Requirements for handling control plane data for the gNB	Any part of a gNB deployment that stores or processes control plane data in cleartext shall be protected from physical attacks. If not, the whole entity is placed in a physically secure location, then control plane data in cleartext shall be stored and processed in a secure environment.	TS 33.501 §5.3.7	
#13	Requirements for secure environment of the gNB	The secure environment shall support secure storage of sensitive data, e.g. long-term cryptographic secrets and vital configuration data. The secure environment shall support the execution of sensitive functions, e.g. en-/decryption of user data and the basic steps within protocols which use long term secrets (e.g. in authentication protocols). The secure environment shall support the execution of sensitive parts of the boot process. The secure environment's integrity shall be assured. Only authorised access shall be granted to the secure environment, i.e. to data stored and used within it, and to functions executed within it.	TS 33.501 §5.3.8	
#14	Requirements for the gNB F1 interfaces	F1-C interface shall support confidentiality, integrity, and replay protection. All management traffic carried over the CU-DU link shall be integrity, confidentiality and replay protected. The gNB shall support confidentiality, integrity and replay protection on the gNB DU-CU F1-U interface for user plane. F1-C and management traffic carried over the CU-DU link shall be protected independently from F1-U traffic. <u>Security mechanisms</u> In order to protect the traffic on the F1-U interface, IPsec ESP and IKEv2 certificates-based authentication shall be supported as specified in sub-clause 9.1.2 of 3GPP TS 33.501 with confidentiality, integrity and replay protection. In order to protect the traffic on the F1-C interface, IPsec ESP and IKEv2 certificates-based authentication shall be supported as specified in sub-clause 9.1.2 of 3GPP TS 33.501 with confidentiality, integrity, and replay protection. IPsec is mandatory to implement on the gNB-DU and on the gNB-CU. On the gNB-CU side, a SEG may be used to terminate the IPsec tunnel. In addition to IPsec, for the F1-C interface, DTLS shall be supported as specified in RFC 6083 to provide integrity protection, replay protection and confidentiality protection. Security profiles for DTLS implementation and usage shall follow the provisions given in clause 6.2 of TS 33.210.	TS 33.501 §5.3.9 & §9.8.2	

#15	Requirements for the gNB E1 interfaces	The E1 interface between CU-CP and CU-UP shall be confidentiality, integrity and replay protected. <u>Security mechanisms</u> In order to protect the traffic on the E1 interface, IPsec ESP and IKEv2 certificates-based authentication shall be supported as specified in sub-clause 9.1.2 of 3GPP TS 33.501 with confidentiality, integrity, and replay protection. In addition to IPsec, DTLS shall be supported as specified in RFC 6083 to provide integrity protection, replay protection and confidentiality protection. Security profiles for DTLS implementation and usage shall follow the provisions given in clause 6.2 of TS 33.210. IPsec is mandatory to support on the gNB-CU-UP and the gNB-CU-CP. Observe that on both the gNB-CU-CP and the gNB-CU-UP sides, a SEG may be used to terminate the IPsec tunnel.	TS 33.501 §5.3.10 & §9.8.3	
#16	Security mechanisms for the N2/Xn interface	The transport of control plane data and user data over Xn/N2 shall be integrity, confidentiality and replay-protected. <u>Security mechanisms</u> In order to protect the traffic on the Xn reference point, it is required to implement IPsec ESP and IKEv2 certificate-based authentication as specified in sub-clause 9.1.2 of 3GPP TS 33.501 with confidentiality, integrity, and replay protection. IPsec shall be supported on the gNB. In addition to IPsec, for the Xn-C interface, DTLS shall be supported as specified in RFC 6083 to provide integrity protection, replay protection and confidentiality protection. Security profiles for DTLS implementation and usage shall follow the provisions given in clause 6.2 of TS 33.210.	TS 33.501 §9.2 & §9.4	TS 33.511 §4.2.2.1.16 & §4.2.2.1.17
#17	AS algorithms selection	The serving network shall select the algorithms to use dependent on: the UE security capabilities of the UE, the configured allowed list of security capabilities of the currently serving network entity. Each gNB shall be configured via network management with lists of algorithms which are allowed for usage. There shall be one list for integrity algorithms, and one for ciphering algorithms. These lists shall be ordered according to a priority decided by the operator.	TS 33.501 §6.7.3.0 & §5.11.2	TS 33.511 §4.2.2.1.12
#18	Key refresh at the gNB	Key refresh shall be possible for KgNB, KRRC-enc, KRRC-int, KUP-int, and KUP-enc and shall be initiated by the gNB when a PDCP COUNTs are about to be re-used with the same Radio Bearer identity and with the same KgNB. The network is responsible for avoiding reuse of the COUNT with the same RB identity and with the same key, e.g. due to the transfer of large volumes of data, release and establishment of new RBs, and multiple termination point changes for RLC-UM bearers. In order to avoid such re-use, the network may e.g. use different RB identities for RB establishments, change the AS security key, or an RRC_CONNECTED to RRC_IDLE/RRC_INACTIVE and then to RRC_CONNECTED transition." as specified in TS 38.331 [6], clause 5.3.1.2.	TS 33.501 §6.9.4.1 TS 38.331 §5.3.1.2	TS 33.511 §4.2.2.1.13
#19	AS protection algorithm selection in gNB change	The target gNB shall select the algorithm with highest priority from the UE's 5G security capabilities according to the locally configured prioritized list of algorithms (this applies for both integrity and ciphering algorithms). The chosen algorithms shall be indicated to the UE in the Handover Command message if the target gNB selects different algorithms compared to the source gNB.	TS 33.501 §6.7.3.1 & §6.7.3.2	TS 33.511 §4.2.2.1.15

#20	Key update at the gNB on dual connectivity	When executing the procedure for adding subsequent radio bearer(s) to the same SN, the MN shall, for each new radio bearer, assign a radio bearer identity that has not previously been used since the last KSN change. If the MN cannot allocate an unused radio bearer identity for a new radio bearer in the SN, due to radio bearer identity space exhaustion, the MN shall increment the SN Counter and compute a fresh KSN, and then shall perform a SN Modification procedure to update the KSN. The SN shall request the Master Node to update the KSN over the Xn-C, when uplink and/or downlink PDCP COUNTs are about to wrap around for any of the SCG DRBs or SCG SRB.	TS 33.501 §6.10.2.1 & §6.10.2.2.1	TS 33.511 §4.2.2.1.18
#21	Unauthorized Viewing	When the system is not under maintenance, there shall be no system function that reveals confidential system internal data in the clear to users and administrators. Such functions could be, for example, local or remote OAM CLI or GUI, logging messages, alarms, configuration file exports. Confidential system internal data contains authentication data (i.e. PINs, cryptographic keys, passwords, cookies) as well as system internal data that is not required for systems administration and could be of advantage to attackers (i.e. stack traces in error messages).		TS 33.511 §4.2.3.2.2 TS 33.117 §4.2.3.2.2
#22	Protecting data and information in storage	For sensitive data in (persistent or temporary) storage read access rights shall be restricted. Files of a system that are needed for the functionality shall be protected against manipulation. In addition, the following rules apply for: - Systems that need access to identification and authentication data in the clear, e.g. in order to perform an authentication. Such systems shall not store this data in the clear, but scramble or encrypt it by implementation-specific means. - Systems that do not need access to sensitive data (e.g. user passwords) in the clear. Such systems shall hash this sensitive data. - Stored files on the network product: examples for protection against manipulation are the use of checksum or cryptographic methods.		TS 33.511 §4.2.3.2.3 TS 33.117 §4.2.3.2.3
#23	Protecting data and information in transfer	Usage of cryptographically protected network protocols is required. The transmission of data with a need of protection shall use industry standard network protocols with sufficient security measures and industry accepted algorithms. In particular, a protocol version without known vulnerabilities or a secure alternative shall be used.		TS 33.511 §4.2.3.2.4 TS 33.117 §4.2.3.2.4
#24	System handling during overload situations	The system shall provide security measures to deal with overload situations which may occur as a result of a denial of service attack or during periods of increased traffic or reach the congestion threshold. In particular, partial, or complete impairment of system availability shall be avoided. Potential protective measures include: - Restricting available RAM per application. - Restricting maximum sessions for a Web application. - Defining the maximum size of a dataset. - Restricting CPU resources per process. - Prioritizing processes. - Overload control method, e.g. limiting amount or size of transactions of a user or from an IP address in a specific time range.		TS 33.511 §4.2.3.3 TS 33.117 §4.2.3.3.1
#25	Boot from intended memory devices only	The network product can boot only from the memory devices intended for this purpose.		TS 33.511 §4.2.3.3 TS 33.117 §4.2.3.3.2

#26	System handling during excessive overload situations	The system shall act in a predictable way if an overload situation cannot be prevented. A system shall be built in this way that it can react on an overload situation in a controlled way. However, it is possible that a situation happens where the security measures are no longer sufficient. In such case it shall be ensured that the system cannot reach an undefined and thus potentially insecure state. In an extreme case this means that a controlled system shutdown is preferable to uncontrolled failure of the security functions and thus loss of system protection. The vendor shall provide a technical description of the network product's Over Load Control mechanisms (especially whether these mechanisms rely on cooperation of other network elements e.g. eNode B) and the accompanying test case for this requirement will check that the description provides sufficient detail in order for an evaluator to understand how the mechanism is designed.		TS 33.511 §4.2.3.3 TS 33.117 §4.2.3.3.3
#27	System robustness against unexpected input	During transmission of data to a system it is necessary to validate input to the network product before processing. This includes all data which is sent to the system. Examples of this are user input, values in arrays and content in protocols. The following typical implementation error shall be avoided: - No validation on the lengths of transferred data - Incorrect assumptions about data formats - No validation that received data complies with the specification - Insufficient handling of protocol errors in received data - Insufficient restriction on recursion when parsing complex data formats - White listing or escaping for inputs outside the values margin		TS 33.511 §4.2.3.3 TS 33.117 §4.2.3.3.4
#28	Network product Software integrity validation	1) Software package integrity shall be validated in the installation/upgrade stage. 2) Network product shall support software package integrity validation via cryptographic means, e.g. digital signature. To this end, the network product has a list of public keys or certificates of authorised software sources, and uses the keys to verify that the software update is originated from only these sources. 3) Tampered software shall not be executed or installed if integrity check fails. 4) A security mechanism is required to guarantee that only authorized individuals can initiate and deploy a software update, and modify the list mentioned in bullet 2.		TS 33.511 §4.2.3.3 TS 33.117 §4.2.3.3.5
#29	System functions shall not be used or accessed without successful authentication and authorization	The usage of a system function without successful authentication on basis of the user identity and at least one authentication attribute (e.g. password, certificate) shall be prevented. System functions comprise, for example network services (like SSH, SFTP, Web services), local access via a management console, local usage of operating system and applications. This requirement shall also be applied to accounts that are only used for communication between systems. An exception to the authentication and authorization requirement are functions for public use such as those for a Web server on the Internet, via which information is made available to the public.		TS 33.117 §4.2.3.4.1.1

#30	The network product shall use accounts that allow unambiguous identification of the user	Users shall be identified unambiguously by the network product. The network product shall support assignment of individual accounts per user, where a user could be a person, or, for Machine Accounts, an application, or a system. The network product shall not enable the use of group accounts or group credentials, or sharing of the same account between several users, by default. The network product shall support a minimum number of 50 individual accounts per user data base if not explicitly specified in a SCAS of a particular network product, so that accountability for each user is ensured even in large operator networks. The network product shall not support user access credentials unrelated to an account. NOTE: The network product may support independent user data bases for different access methods, e.g. one data base for command shell access on OS level and another data base for GUI access. User data bases may be stored locally on the network product or on a central AAA system that the network product accesses for user authentication.		TS 33.117 §4.2.3.4.1.2
#31	Account protection by at least one authentication attribute	The various user and machine accounts on a system shall be protected from misuse. To this end, an authentication attribute is typically used, which, when combined with the user name, enables unambiguous authentication and identification of the authorized user. Authentication attributes include: - Cryptographic keys - Token - Passwords This means that authentication based on a parameter that can be spoofed (e.g. phone numbers, public IP addresses or VPN membership) is not permitted. Exceptions are attributes that cannot be faked or spoofed by an attacker.		TS 33.511 §4.2.3.4.1 TS 33.117 §4.2.3.4.2.1
#32	Predefined accounts shall be deleted or disabled	All predefined or default accounts shall be deleted or disabled. Many systems have default accounts (e.g. guest, ctxsys), some of which are preconfigured with or without known passwords. These standard users shall be deleted or disabled. Should this measure not be possible the accounts shall be locked for remote login. In any case disabled or locked accounts shall be configured with a complex password as specified in clause 4.2.3.4.3.1 Password Structure of TS 33.117. This is necessary to prevent unauthorized use of such an account in case of misconfiguration. Exceptions to this requirement to delete or disable accounts are accounts that are used only internally on the system involved and that are required for one or more applications on the system to function. Also, for these accounts remote access or local login shall be forbidden to prevent abusive use by users of the system.		TS 33.511 §4.2.3.4.1 TS 33.117 §4.2.3.4.2.2
#33	Predefined or default authentication attributes shall be deleted or disabled	Normally, authentication attributes such as password or cryptographic keys will be preconfigured from producer, vendor, or developer of a system. Such authentication attributes shall be changed by automatically forcing a user to change it on 1st time login to the system or the vendor provides instructions on how to manually change it.		TS 33.511 §4.2.3.4.1 TS 33.117 §4.2.3.4.2.3

#34	Password Complexity rule	The setting by the vendor shall be such that a network product shall only accept passwords that comply with the following complexity criteria: 1) Absolute minimum length of 8 characters (shorter lengths shall be rejected by the network product). It shall not be possible setting this absolute minimum length to a lower value by configuration. 2) Comprising at least three of the following categories: - at least 1 uppercase character (A-Z) - at least 1 lowercase character (a-z) - at least 1 digit (0-9) - at least 1 special character (e.g. @;!\$.) The network product shall use a default minimum length of 10 characters. The minimum length of characters in the passwords shall be configurable by the operator. The default minimum length is the value configured by the vendor before any operator-specific configuration has been applied. The special characters may be categorized in sets according to their Unicode category. The network product shall at least support passwords of a length of 64 characters or a length greater than 64 characters. If a central system is used for user authentication, password policy is performed on the central system and additional assurance shall be provided that the central system enforces the same password complexity rules as laid down for the local system in this subclause. If a central system is not used for user authentication, the assurance on password complexity rules shall be performed on the Network Product. When a user is changing a password or entering a new password, the system checks and ensures that it meets the password requirements. Above requirements shall be applicable for all passwords used (e.g. application-level, OS-level,.).		TS 33.117 §4.2.3.4.3.1
#35	Password changes	If a password is used as an authentication attribute, then the system shall offer a function that enables a user to change his password at any time. When an external centralized system for user authentication is used it is possible to redirect or implement this function on this system. Password change shall be enforced after initial login. The system shall enforce password change based on password management policy. In particular, the system shall enforce password expiry. Previously used passwords shall not be allowed up to a certain number (Password History). The number of disallowed previously used passwords shall be: - Configurable; - Greater than 0; - And its default value shall be 3. This means that the network product shall store at least the three previously set passwords. The maximum number of passwords that the network product can store for each user is up to the manufacturer. When a password is about to expire a password expiry notification shall be provided to the user. Above requirements shall be applicable for all passwords used (e.g. application-level, OS-level.). An exception to this requirement is machine accounts.		TS 33.117 §4.2.3.4.3.2

#36	Protection against brute force and dictionary attacks	If a password is used as an authentication attribute, a protection against brute force and dictionary attacks that hinder password guessing shall be implemented. Brute force and dictionary attacks aim to use automated guessing to ascertain passwords for user and machine accounts. Various measures or a combination of these measures can be taken to prevent this. The most commonly used protection measures are: 1) Using the timer delay (this delay could be the same or increased depending the operator's policy for each attempt, e.g. double the delay, or 5 minutes delay, or 10 minutes delay) for each newly entered password input following an incorrect entry ("tar pit"). 2) Blocking an account following a specified number of incorrect attempts, refer to 4.2.3.4.5 of TS 33.117. However, it has to be taken into account that this solution needs a process for unlocking and an attacker can force this to deactivate accounts and make them unusable. 3) Using CAPTCHA to prevent automated attempts (often used for Web applications). 4) Using a password blacklist to prevent vulnerable passwords. NOTE: Password management and blacklist configuration may be done in a separate node that is different to the node under test, e.g. a SSO server or any other central credential manager. In order to achieve higher security, it is often meaningful to combine two or more of the measures named here. It is left to the vendor to select appropriate measures. Above requirements shall be applicable for all passwords used (e.g. application-level, OS-level.). An exception to this requirement is machine accounts.		TS 33.117 §4.2.3.4.3.3
#37	Hiding password display	The password shall not be displayed in such a way that it could be seen and misused by a casual local observer. Typically, the individual characters of the password are replaced by a character such as "*". Under certain circumstances it may be permissible for an individual character to be displayed briefly during input. Such a function is used, for ex ample, on smartphones to make input easier. However, the entire password is never output to the display in plaintext. Above requirements shall be applicable for all passwords used (e.g. application-level, OS-level.). An exception to this requirement is machine accounts.		TS 33.117 §4.2.3.4.3.4
#38	Network Product Management and Maintenance interfaces	The network product management shall support mutual authentication mechanisms, the mutual authentication mechanism can rely on the protocol used for the interface itself or other means.		TS 33.117 §4.2.3.4.4.1

#39	Policy regarding consecutive failed login attempts	a) The maximum permissible number of consecutive failed user account login attempts should be configurable by the operator. The definition of the default value set at manufacturing time for maximum number of failed user account login attempts shall be less than or equal to 8, typically 5. After the maximum permissible number of consecutive failed user account login attempts is exceeded by a user there shall be a block delay in allowing the user to attempt login again. This block delay and also the capability to set period of the block delay, e.g. double the delay, or 5 minutes delay, or 10 minutes delay, after each login failure should be configurable by the operator. The default value set at manufacturing time for this delay shall be greater than or equal to 5 sec. b) If supported, infinite (permanent) locking of an account that has exceeded maximum permissible number of consecutive failed user account login attempts should also be possible via configuration, with the exception of administrative accounts which shall get only temporarily locked.		TS 33.117 §4.2.3.4.5
#40	Authorization policy	The authorizations for accounts and applications shall be reduced to the minimum required for the tasks they have to perform. Authorizations to a system shall be restricted to a level in which a user can only access data and use functions that he needs in the course of his work. Suitable authorizations shall also be assigned for access to files that are components of the operating system or of applications or that are generated by the same (e.g. configuration and logging files). Alongside access to data, execution of applications and components shall also take place with rights that are as low as possible. Applications should not be executed with administrator or system rights.		TS 33.117 §4.2.3.4.6.1
#41	Role-based access control	The network product shall support Role Based Access Control (RBAC). A role-based access control system uses a set of controls which determines how users interact with domains and resources. The domains could be Fault Management (FM), Performance Management (PM), System Admin. The RBAC system controls how users or groups of users are allowed access to the various domains and what type of operation they can perform, i.e. the specific operation command or command group (e.g. View, Modify, Execute). The network product supports RBAC, in particular, for OAM privilege management for network product Management and Maintenance, including authorization of the operation for configuration data and software via the network product console interface.		TS 33.117 §4.2.3.4.6.2
#42	Protecting sessions – logout function	The system shall have a function that allows a signed in user to logout at any time. All processes under the logged in user ID shall be terminated on log out. The network product shall be able to continue to operate without interactive sessions. Only for debugging purposes, processes under a logged in user ID may be allowed to continue to run after detaching the interactive session.		TS 33.511 §4.2.3.5 TS 33.117 §4.2.3.5.1
#43	Protecting sessions – inactivity timeout	An OAM user interactive session shall be terminated automatically after a specified period of inactivity. It shall be possible to configure an inactivity time-out period. NOTE: The kind of activity required to reset the timeout timer depends on the type of user session.		TS 33.511 §4.2.3.5 TS 33.117 §4.2.3.5.2

#44	Security event logging	Security events shall be logged together with a unique system reference (e.g. host name, IP or MAC address) and the exact time the incident occurred. For each security event, the log entry shall include user name and/or timestamp and/or performed action and/or result and/or length of session and/or values exceeded and/or value reached. IETF RFC 3871, clause 2.11.10 specifies the minimum set of security events. Each vendor shall document what security events the product logs so that it can be verified by testing.		TS 33.511 §4.2.3.6 TS 33.117 §4.2.3.6.1
#45	Log transfer to centralized storage	a) The Network Product shall support forwarding of security event logging data to an external system. Secure transport protocols in accordance with clause 4.2.3.2.4 of TS 33.117, shall be used. b) Log functions should support secure uploading of log files to a central location or to an external system for the Network Product that is logging.		TS 33.511 §4.2.3.6 TS 33.117 §4.2.3.6.2
#46	Protection of security event log files	The security event log shall be access controlled (file access rights) so only privileged users have access to the log files.		TS 33.511 §4.2.3.6 TS 33.117 §4.2.3.6.3
#47	Growing (dynamic) content shall not influence system functions	Growing or dynamic content (e.g. log files, uploads) shall not influence system functions. A file system that reaches its maximum capacity shall not stop a system from operating properly. Therefore, countermeasures shall be taken such as usage of dedicated filesystems, separated from main system functions, or quotas, or at least a file system monitoring to ensure that this scenario is avoided.		TS 33.511 §4.2.4 TS 33.117 §4.2.4.1.1.1
#48	Processing of ICMPv4 and ICMPv6 packets	Processing of ICMPv4 and ICMPv6 packets which are not required for operation shall be disabled on the network product. In particular, there are certain types of ICMPv4 and ICMPv6 that are not used in most networks, but represent a risk. ICMP message types which on receipt lead to responses or to configuration changes are not mentioned in this requirement, but they may be necessary to support relevant and specified networking features. Those must be documented. Certain ICMP types are generally permitted and do not need to be specifically documented. Those are marked as "Permitted" in below table. The network product shall not send certain ICMP types by default, but it may support the option to enable utilization of these types (e.g. for debugging). Echo Reply can be sent by default. In case of remote base station auto deployment, Router Advertisement can be processed.		TS 33.511 §4.2.4 TS 33.117 §4.2.4.1.1.2
#49	IP packets with unnecessary options or extension headers shall not be processed	IP packets with unnecessary options or extension headers shall not be processed. IP options and extension headers (e.g. source routing) are only required in exceptional cases. So, all packets with enabled IP options or extension headers shall be filtered.		TS 33.511 §4.2.4 TS 33.117 §4.2.4.1.1.3
#50	Authenticated Privilege Escalation only	There shall not be a privilege escalation method in interactive sessions (CLI or GUI) which allows a user to gain administrator/root privileges from another user account without re-authentication. Implementation example: Disable insecure privilege escalation methods so that users are required to (re-)login directly into the account with the required permissions.		TS 33.511 §4.2.4 TS 33.117 §4.2.4.1.2.1
#51	System account identification	Each system account in UNIX® shall have a unique UID.		TS 33.511 §4.2.4 TS 33.117 §4.2.4.2.2

#52	HTTPS	The communication between Web client and Web server shall be protected using TLS. The TLS profile defined in Annex E of TS 33.310 shall be followed with the following modifications: Cipher suites with NULL encryption shall not be supported		TS 33.511 §4.2.5 TS 33.117 §4.2.5.1
#53	Webserver logging	Access to the webserver shall be logged. The web server log shall contain the following information: - Access timestamp - Source (IP address) - (Optional) Account (if known) - (Optional) Attempted login name (if the associated account does not exist) - Relevant fields in http request. The URL should be included whenever possible. - Status code of web server response		TS 33.511 §4.2.5 TS 33.117 §4.2.5.2.1
#54	User sessions	To protect user sessions the Network Product shall support the following session ID and session cookie requirements: 1. The session ID shall uniquely identify the user and distinguish the session from all other active sessions. 2. The session ID shall be unpredictable. 3. The session ID shall not contain sensitive information in clear text (e.g. account number, social security.). 4. In addition to the Session Idle Timeout (see clause 4.2.3.5.2 Protecting sessions – Inactivity timeout of TS 33.117), the Network Product shall automatically terminate sessions after a configurable maximum lifetime This maximum lifetime defines the maximum session span. When the maximum lifetime expires, the session shall be closed, the session ID shall be deleted, and the user shall be forced to (re)authenticate in the web application and to establish a new session. The default value for this maximum lifetime shall be set to 8 hours. 5. Session ID's shall be regenerated for each new session (e.g. each time a user log in). 6. The session ID shall not be reused or renewed in subsequent sessions. 7. The Network Product shall not use persistent cookies to manage sessions but only session cookies. This means that neither the "expire" nor the "max-age" attribute shall be set in the cookies. 8. Where session cookies are used the attribute 'HttpOnly' shall be set to true. 9. Where session cookies are used the 'domain' attribute shall be set to ensure that the cookie can only be sent to the specified domain. 10. Where session cookies are used the 'path' attribute shall be set to ensure that the cookie can only be sent to the specified directory or sub-directory. 11. The Network Product shall not accept session identifiers from GET/POST variables. 12. The Network Product shall be configured to only accept server generated session ID's.		TS 33.511 §4.2.5 TS 33.117 §4.2.5.3
#55	HTTP input validation	The Network Product shall have a mechanism in place to ensure that web application inputs are not vulnerable to command injection or cross-site scripting attacks. The Network Product shall validate, filter, escape, and encode user-controllable input before it is placed in output that is used as a web page that is served to other users.		TS 33.511 §4.2.5 TS 33.117 §4.2.5.4

#56	Packet filtering	The Network Product shall provide a mechanism to filter incoming IP packets on any IP interface (see RFC 3871 for further information). In particular the Network Product shall provide a mechanism: 1) To filter incoming IP packets on any IP interface at Network Layer .and Transport Layer of the stack ISO/OSI. 2) To allow specified actions to be taken when a filter rule matches. In particular at least the following actions should be supported: a. Discard/Drop: the matching message is discarded; no subsequent rules are applied and no answer is sent back. b. Accept: the matching message is accepted. c. Account: the matching message is accounted for i.e. a counter for the rule is incremented. This action can be combined with the previous ones. This feature is useful to monitor traffic before its blocking. 3) To enable/disable for each rule the logging for Dropped packets, i.e. details on messages matching the rule for troubleshooting. 4) To filter on the basis of the value(s) of any portion of the protocol header. 5) To reset the accounting. 6) The Network Product shall provide a mechanism to disable/enable each defined rule.		TS 33.511 §4.2.6.2.1 TS 33.117 §4.2.6.2.1
#57	Manipulated packets that are sent to an address of the network device shall not lead to an impairment of availability	A network device shall be not affected in its availability or robustness by incoming packets, from other network element, that are manipulated or differing the norm. This means that appropriate packets shall be detected as invalid and be discarded. The process shall not be affecting the performance of the network device. This robustness shall be just as effective for a great mass of invalid packets as for individual or a small number of packets. Examples of such packets are: - Mass-produced TCP packets with a set SYN flag to produce half-open TCP connections (SYN flooding attack). - Packets with the same IP sender address and IP recipient address (Land attack). - Mass-produced ICMP packets with the broadcast address of a network as target address (Smurf attack). - Fragmented IP packets with overlapping offset fields (Teardrop attack). - ICMP packets that are larger than the maximum permitted size (65,535 Bytes) of IPv4 packets (Ping-of-death attack). - Uncorrelated reply packets (i.e. packets which cannot be correlated to any request). Sometimes the relevant behaviour of the network device will be configured. In other cases, the behaviour of the network device may only be verified by the relevant tests.		TS 33.511 §4.2.6.2.2 TS 33.117 §4.2.6.2.2

#58	GTP-U Filtering	The following capability is conditionally required: - For each message of a GTP-U-based protocol, it shall be possible to check whether the sender of this message is authorized to send a message pertaining to this protocol. NOTE: The check could be performed e.g. against a whitelist or blacklist of permitted message type / sender identity combinations. - At least the following actions should be supported when the check is satisfied: - Discard: the matching message is discarded. - Accept: the matching message is accepted. - Account: the matching message is accounted for, i.e. a counter for the rule is incremented. This action can be combined with the previous ones. This feature is useful to monitor traffic before its blocking. This requirement is conditional in the following sense: It is required that at least one of the following two statements holds: - The Network Product supports the capability described above and this is stated in the product documentation. - The Network Product's product documentation states that the capability is not supported and that the Network Product needs to be deployed together with a separate entity which provides the capability described above. NOTE : Such a separate entity could e.g. be a GTP Firewall. NOTE: Test cases for this separate entity are not provided in the present document, but are believed to be similar to them. NOTE: The test cases are only applicable to all network product classes utilizing GTP-U based protocol.		TS 33.511 §4.2.6.2.4 TS 33.117 §4.2.6.2.4
gNodeB-specific security hardening requirements				
Technical Baseline				
#59	No unnecessary or insecure services / protocols	The network product shall only run protocol handlers and services which are needed for its operation, and which do not have any known security vulnerabilities.		TS 33.117 §4.3.2.1
#60	Restricted reachability of services	The network product shall restrict the reachability of services so that they can only be reached on interfaces where their usage is required. On interfaces where services are active, the reachability should be limited to legitimate communication peers.		TS 33.117 §4.3.2.2
#61	No unused software	Unused software components or parts of software which are not needed for operation or functionality of the network product shall not be installed or shall be deleted after installation.		TS 33.117 §4.3.2.3
#62	No unused functions	During installation of software and hardware often functions will be activated that are not required for operation or function of the system. Also, hardware functions which are not required for operation or function of the system (e.g. unused interfaces) shall be permanently deactivated. Permanently means that they shall not be reactivated again after network product reboot. EXAMPLE: A debugging function in software which can be used for troubleshooting shall not be activated during normal operation of the network product.		TS 33.117 §4.3.2.4
#63	No unsupported components	The network product shall not contain software and hardware components that are no longer supported by their vendor, producer, or developer, such as components that have reached end-of-life or end-of-support. Excluded are components that have a special support contract. This contract shall guarantee the correction of vulnerabilities over components' lifetime.		TS 33.117 §4.3.2.5

#64	Remote login restrictions for privileged users	Direct login as root or equivalent highest privileged user shall be limited to the system console only. Root user will not be allowed to login to the system remotely.		TS 33.117 §4.3.2.6
#65	Filesystem Authorization privileges	The system shall be designed to ensure that only users that are authorized to modify files, data, directories, or file systems have the necessary privileges to do so. EXAMPLE: On unix® systems a 'sticky' bit may be set on all directories where all users have written permissions. This ensures that only the file's owner, the directory's owner, or root user can rename or delete the file. Without the sticky bit being set, any user that has write and execute permissions for the directory can rename or delete files within the directory, regardless of the file's owner.		TS 33.117 §4.3.2.7
Operating Systems				
#66	IP-Source address spoofing mitigation	Systems shall not process IP packets if their source address is not reachable via the incoming interface. Implementation example: Use of "Reverse Path Filter" (RPF) provides this function.		TS 33.117 §4.3.3.1.1
#67	Minimized kernel network functions	Kernel based network functions not needed for the operation of the network element shall be deactivated. In particular the following ones shall be disabled by default: - IP Packet Forwarding between different interfaces of the network product.		TS 33.117 §4.3.3.1.2
#68	No automatic launch of removable media	The network product shall not automatically launch any application when removable media device such as CD-, DVD-, USB-Sticks or USB-Storage drive is connected. If the operating system supports an automatic launch, it shall be deactivated unless it is required to support availability requirements.		TS 33.117 §4.3.3.1.3
#69	Syn Flood Prevention	The network product shall support a mechanism to prevent Syn Flood attacks (e.g. implement the TCP Syn Cookie technique in the TCP stack by setting net.ipv4.tcp_syncookies = 1 in the linux sysctl.conf file). This feature shall be enabled by default.		TS 33.117 §4.3.3.1.4
#70	Protection mechanisms against buffer overflows	The system shall support mechanisms for buffer overflow protection. Documentation which describes these buffer overflow mechanisms and also how to check that they have been enabled and/or implemented shall be provided.		TS 33.117 §4.3.3.1.5
#71	External file system mount restrictions	If normal users are allowed to mount external file systems (attached locally or via the network), OS-level restrictions shall be set properly in order to prevent privilege escalation or extended access permissions due to the contents of the mounted file systems. Implementation example: In Linux® systems, administrators shall set the options nodev and nosuid in the /etc/fstab for all filesystems, which also have the "user" option.		TS 33.117 §4.3.3.1.6
Web Servers				
#72	No system privileges for web server	No web server processes shall run with system privileges. This is best achieved if the web server runs under an account that has minimum privileges. If a process is started by a user with system privileges, execution shall be transferred to a different user without system privileges after the start.		TS 33.117 §4.3.4.2
#73	Unused HTTP methods shall be deactivated	HTTP methods that are not required shall be deactivated. Standard requests to web servers only use GET, HEAD, and POST. If other methods are required, they shall not introduce security leaks such as TRACK or TRACE.		TS 33.117 §4.3.4.3

#74	Any add-ons and components that are not required shall be deactivated	All optional add-ons and components of the web server shall be deactivated if they are not required. In particular, CGI or other scripting components, Server Side Includes (SSI), and WebDAV shall be deactivated if they are not required.		TS 33.117 §4.3.4.4
#75	No compiler, interpreter, or shell via CGI or other server-side scripting	If CGI (Common Gateway Interface) or other scripting technology is used, the CGI directory - or other corresponding scripting directory - shall not include compilers or interpreters (e.g. PERL interpreter, PHP interpreter/compiler, Tcl interpreter/compiler or operating system shells).		TS 33.117 §4.3.4.5
#76	No CGI or other scripting for uploads	If CGI or other scripting technology is used, the associated CGI/script directory shall not be used for uploads.		TS 33.117 §4.3.4.6
#77	No execution of system commands with SSI	If Server Side Includes (SSI) is active, the execution of system commands shall be deactivated.		TS 33.117 §4.3.4.7
#78	Access rights for web server configuration files shall only be granted to the owner of the web server process or to a user with system privileges	Access rights for web server configuration files shall only be granted to the owner of the web server process or to a user with system privileges. Implementation example: Delete "read" and "write" access rights for "others." Only grant "write" access to the user who configures the web server.		TS 33.117 §4.3.4.8
#79	Default content shall be removed	Default content (examples, help files, documentation, aliases) that is provided with the standard installation of the web server shall be removed.		TS 33.117 §4.3.4.9
#80	No directory listings / Directory Browsing	Directory listings (indexing) / "Directory browsing" shall be deactivated.		TS 33.117 §4.3.4.10
#81	Information about the web server in HTTP headers shall be minimized	The HTTP header shall not include information on the version of the web server and the modules/add-ons used.		TS 33.117 §4.3.4.11
#82	Web server information in error pages shall be deleted	User-defined error pages shall not include version information about the web server and the modules/add-ons used. Error messages shall not include internal information such as internal server names, error codes. Default error pages of the web server shall be replaced by error pages defined by the vendor.		TS 33.117 §4.3.4.12
#83	File type- or script-mappings that are not required shall be deleted	File type- or script-mappings that are not required shall be deleted, e.g. php, phtml, js, sh, csh, bin, exe, pl, vbe, vbs.		TS 33.117 §4.3.4.13
#84	The web server shall only deliver files which are meant to be delivered	Restrictive access rights shall be assigned to all files which are directly or indirectly (e.g. via links or in virtual directories) in the web server's document directory. In particular, the web server shall not be able to access files which are not meant to be delivered.		TS 33.117 §4.3.4.14

#85	Only execute rights in CGI/Scripting directory	If CGI or other scripting technology is used, only the CGI/Scripting directory is configured with execute rights. Other directories used or meant for web content do not have execute rights.		TS 33.117 §4.3.4.15
Network Devices				
#86	Traffic Separation	The network product shall support physical or logical separation of traffic belonging to different network domains. For example, O&M traffic and control plane traffic belong to different network domains. See RFC 3871 for further information.		TS 33.117 §4.3.5.1
Basic vulnerability testing requirements				
#87	Port scanning	It shall be ensured that on all network interfaces, only documented ports on the transport layer respond to requests from outside the system.		TS 33.117 §4.4.2
#88	Vulnerability scanning	The purpose of vulnerability scanning is to ensure that there are no known vulnerabilities (or that relevant vulnerabilities are identified and remediation plans in place to mitigate them) on the Network Product, both in the OS and in the applications installed, that can be detected by means of automatic testing tools via the Internet Protocol enabled network interfaces. Vulnerability scanning tools may also report false positives and they shall be investigated and documented in the test report.		TS 33.117 §4.4.3
#89	Robustness and fuzz testing	It shall be ensured that externally reachable services are reasonably robust when receiving unexpected input.		TS 33.117 §4.4.4
Virtualization				
#90	VNF package and VNF image integrity	1) VNF package and image shall contain integrity validation value (e.g. MAC). 2) VNF package shall be integrity protected during onboarding and its integrity shall be validated by the NFVO.		TR 33.818 §5.2.5.5.3.3.5.1 TR 33.848 §5.18.3
#91	GVNP lifecycle management security	1) VNF shall authenticate VNFM when VNFM initiates a communication to VNF. 2) VNF shall be able to establish securely protected connection with the VNFM. 3) VNF shall check whether VNFM has been authorized when VNFM access VNF's API. 4) VNF shall log VNFM's management operations for auditing.		TR 33.818 §5.2.5.5.7.1
#92	Secure executive environment provision	The VNF shall support to compare the owned resource state with the parsed resource state from VNFD (VNF Description) by the VNFM. The VNF can query the parsed resource state by the VNFM from the OAM. The VNF shall send an alarm to the OAM if the two resource states are inconsistent. This comparing process can be triggered periodically by the VNF, or the administrator can manually trigger the VNF to perform the comparing process.		TR 33.818 §5.2.5.5.7.2
#93	Traffic Separation	The virtualised network product shall support logical separation of traffic belonging to different network domains. For example, O&M traffic and control plane traffic belong to different network domains. See RFC 3871 for further information.		TR 33.818 §5.2.5.5.8.5.1 TS 33.117 §4.3.5.1
#94	Inter-VNF and intra-VNF Traffic Separation	The network used for the communication between the VNFCs of a VNF (intra-VNF traffic) and the network used for the communication between VNFs (inter-VNF traffic) shall be separated to prevent the security threats from the different networks affect each other.		TR 33.818 §5.2.5.5.8.5.2

#95	Instantiating VNF from trusted VNF image	A VNF shall be initiated from a trusted VNF image which includes one or more than one images. The VNF image shall be signed by an authorized party. The authorized party is trusted by the operators.		TR 33.818 §5.2.5.6.6.1 TR 33.848 §5.18.3
#96	Secure virtualisation resource management	To prevent a compromised VIM from changing the assigned virtualised resource, the VNF shall alert to the OAM. For example, when an instantiated VNF is running, a compromised VIM can delete a VM which is running VNFCI, the VNF shall alert to the OAM when the VNF cannot detect a VNFC message. A VNF shall log the access from the VIM. NOTE: The VIM manages the virtualisation resource assignment and synchronization of virtualised resource state information. In the implementation, the VIM and the virtualisation layer are coupled and provided by one vendor, they trust each other. Whether the VIM is trust or not is based on operator's decision.		TR 33.818 §5.2.5.6.7.1
#97	Secure executive environment creation	When an attacker tampers a driver which provided by the hardware and used to create the executive environment, the virtualisation layer shall alert the driver error to the administrator for checking the error and finding the attack at latter. NOTE: Whether the hardware is trust or not is based on operator's decision to ensure the virtualisation layer and the VNF to be run on the trusted hardware.		TR 33.818 §5.2.5.6.7.2
#98	VM escape protection	To defence the attack that an attacker utilizes a vulnerability of a VNF to attack a virtualisation layer and then control the virtualisation layer, the virtualisation layer shall implement the following requirements: The virtualisation shall reject the abnormal access from the VNF (e.g. the VNF accesses the memory which is not allocated to the VNF) and log the attacks.		TR 33.818 §5.2.5.6.7.3
#99	Secure hardware resource management	The VIM manages the hardware resource configuration and state information exchange. When the VIM is compromised to change the hardware resource configuration, an alert shall be triggered by the hardware. The administrator can check the alert and find the attack at latter.		TR 33.818 §5.2.5.7.7.1
#100	Secure hardware resource management information	When a compromised Virtualisation layer tampers the hardware resource configuration which is received from the VIM to result in the configuration error of the hardware, the hardware shall trigger an alert. The administrator can check the alert and find the attack at latter. NOTE: Whether the virtualisation layer is trust or not is based on operator's decision.		TR 33.818 §5.2.5.7.7.2
#101	Trusted platform	The host system shall implement a Hardware-Based Root of Trust (HBRT) ((e.g. TPM, HSM)) as Initial Root of Trust ¹ . The trust state of the platform shall be measured and a trusted chain shall be built ² .		TR 33.818 §5.2.5.7.7.3

¹ ETSI GS NFV-SEC 012: "Network Functions Virtualisation (NFV) Release 3; Security; System architecture specification for execution of sensitive NFV components".

² ETSI GR NFV-SEC 007: "Functions Virtualisation (NFV); Trust; Report on Attestation Technologies and Practices for Secure Deployments".

Annex C (informative): Guidance on Security Requirements & Controls

C.1 O-Cloud

Controls given in this clause are designed as a guidance and non-normative. The implementation of those non-normative controls depends on the security policies within the O-Cloud Service Provider, O-RAN Application Provider and Service Provider.

C.1.1 Secure protection of cryptographic keys and sensitive data

Potential solutions for SEC-CTL-OCLOUD-SS-1

The following potential implementation options for encrypting cryptographic keys and sensitive data within the O-Cloud platform could be used. The appropriate option to be used depends on the sensitivity of the data to be protected and needs to be assessed/determined by the Service provider.

1. Software based:
 - a. Software-based KMS vaults supporting management of keys, including creation, rotation, and revocation, as well as encrypting and decrypting sensitive data with managed keys [51].
 - b. Use a vTPM: A virtual Trusted Platform Module (vTPM) is a software-based representation of a physical Trusted Platform Module 2.0 chip to provide secure storage of credentials or keys [i.27]. A vTPM acts as any other virtual device. It performs the same functions as a TPM, but it performs cryptographic coprocessor capabilities in software. It should comply with the TPM 2.0 specification [53].
2. Hardware based
 - a. Hardware-based key vaults: The use of Key Management Service (KMS) based on an HSM [i.5], [i.6], [52]. The data is encrypted using a data encryption key (DEK); a new DEK is generated for each encryption. The DEKs are encrypted with a key encryption key (KEK) that is stored and managed in the HSM of the KMS provider.
 - b. A hardware TPM [i.8], [53]. For data encryption, an encryption key is stored on disk but encrypted with the TPM master key (the storage root key (SRK)). This encryption key can only be used after it was decrypted by an authenticated TPM. The actual data encryption/decryption is then done by the main CPU, only decryption/encryption of the encryption key is done inside the TPM.

Potential solutions for SEC-CTL-OCLOUD-SS-2

- Overwriting with zero (e.g., /dev/zero) or simple patterns.
- Overwriting with random data using:
 - True random data source (e.g., /dev/random). This solution takes too long to wait for the entropy generation.
 - Pseudorandom data source (e.g., /dev/urandom) can be used as a reasonable source of pseudorandom data.

Potential solutions for SEC-CTL-OCLOUD-SS-3

Each data centre adheres to a strict disposal policy and uses the techniques described to achieve compliance with NIST SP 800-88 Revision 1 "Guidelines for Media Sanitization" [75].

Potential solutions for REQ-SEC-OCLOUD-SS-5

Automatic memory scrubbing on boot:

- Implement a process that automatically clears all volatile memory as early as possible during the boot sequence. This can be achieved through BIOS settings or early-stage boot loader scripts that overwrite memory with zeros or random data to ensure no residual data is left accessible.

Watchdog timers:

- Use timers that watch for unexpected shutdowns or power losses. If something goes wrong, these timers help make sure memory is cleaned properly before the system starts up again.

Work with power backup systems:

- For systems with an uninterruptible power supply (UPS), integrate the memory scrubbing mechanism with UPS software to initiate secure shutdown procedures that include clearing volatile memory when the UPS detects a power outage and is about to run out of battery.

C.1.2 Chain of Trust

Potential solutions for SEC-CTL-OCLOUD-COT-1

There are many ways to measure platform integrity. In many cases, a hardware security module is used to store measurement data such as an HSM and TPM. Various platform integrity technologies build their own CoTs [i.7] and listed here below:

- UEFI Secure Boot (SB)
- Intel Trusted Execution Technology (TXT)
- Intel Boot Guard
- Intel Platform Firmware Resilience (PFR)
- Intel Technology Example Summary
- AMD Platform Secure Boot (AMD PSB)
- Arm TrustZone Trusted Execution Environment (TEE) for Armv8-A
- Arm Secure Boot and the Chain of Trust (CoT)
- Cisco Platform Roots of Trust
- IBM Chain of Trust (CoT)

For more details, see [i.7], clause 3.2.

Potential solutions for SEC-CTL-OCLOUD-COT-2

A vTPM can be considered a software-based implementation of a root of trust. It emulates the behavior and functionalities of a physical TPM through software mechanisms and cryptographic libraries [53] and [i.27]. A vTPM operates within a virtual machine or as a software module within an operating system, leveraging the underlying hardware and security features provided by the host system. It can perform key generation, storage, and cryptographic operations similar to a physical TPM. However, since it is implemented in software, its security relies on the host system's security measures and may be more vulnerable to compromise if the host system is compromised. Therefore, it is crucial to ensure the overall security of the O-Cloud where the vTPM is deployed and to consider additional security measures to protect the software root of trust.

Potential solutions for SEC-CTL-OCLOUD-COT-3

Please refer to the following technology examples in [i.7], clause 6.1 for more information:

- Intel Security Libraries for the Data Center (ISecL-DC)
- Remote AS - Project Veraison (VERificAtIon of atteStatiON)
- IBM Platform Attestation Tooling

Relevant information on the Attestation Server is provided in [i.7], clause 6.1 and [i.15], clause 6.6.

The following figure C.1.2-1 shows an example of remote AS:

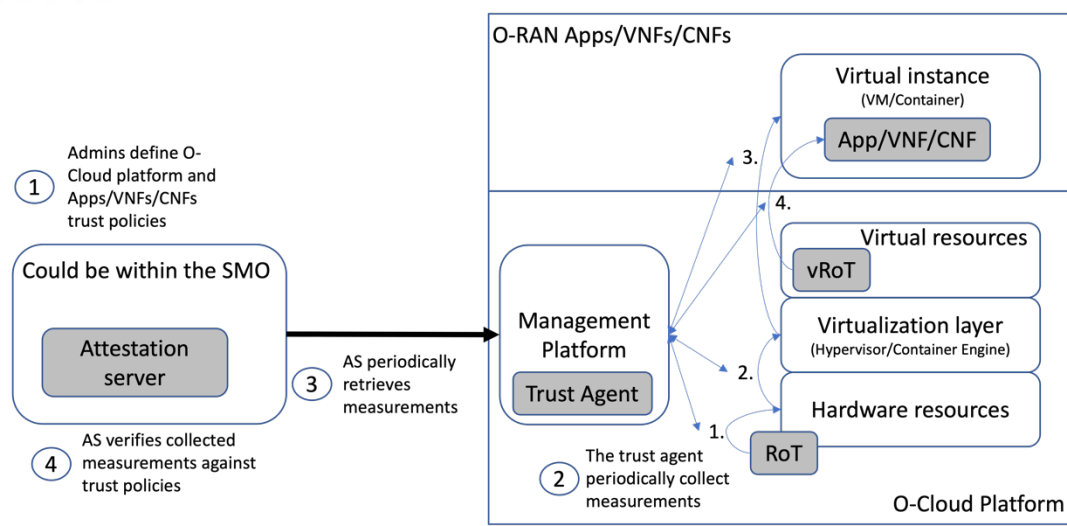


Figure C.1.2-1: Example of Remote AS

The AS from the hardware layer to the O-RAN Application includes the following steps (see figure C.1.2-1):

Attestation of the O-Cloud platform

1. RoT measures and verifies hardware resources (server platform) including firmware/BIOS. It then launches the hardware resources.
2. The server act as the attester of the OS/virtualization layer. It measures, verifies, and launches the OS/virtualization layer.

The attestation results and corresponding measurements are maintained by the management platform (e.g. Kubernetes) acting as the trust agent.

Attestation of Application

The attestation process is initiated by the management platform requesting to instantiate a new Application:

3. The virtualization layer verifies the virtual instance.
4. Virtualized RoT (vRoT) measures the Application. The vRoT is a virtual instance associated to the hardware protected RoT. The virtualization layer provides this virtual resource to the virtual instance.

Corresponding measurements are reported to the trust agent. The trust agent exposes the attestation results to authorized attestation server (could be within the SMO) so that it verifies collected measurements against trust policies already defined by administrators.

C.1.3 Recommended Security Policies

Requirements	Kubernetes admission controllers	Why
REQ-SEC-OCLOUD-SECPOL-1	ImagePolicyWebhook	The ImagePolicyWebhook admission controller allows a backend webhook to make admission decisions based on the images being used. This can be configured to enforce policies regarding which image sources are allowed, ensuring that only images from approved sources can be deployed
REQ-SEC-OCLOUD-SECPOL-2	ResourceQuota	The ResourceQuota admission controller is designed to enforce constraints on the amount of resources that can be consumed by objects in a Kubernetes namespace.
REQ-SEC-OCLOUD-SECPOL-3, REQ-SEC-OCLOUD-SECPOL-4, REQ-SEC-OCLOUD-SECPOL-5	Pod Security Admission (PSA)	The Pod Security Admission (PSA) ensures that Pods meet the required security context and comply with the Pod Security Standards (https://kubernetes.io/docs/concepts/security/pod-security-standards/) defined for the namespace they are in.
REQ-SEC-OCLOUD-SECPOL-6	AlwaysPullImages	AlwaysPullImages forces every new pod to pull the required images every time. In a multi-tenant cluster users can be assured that their private images can only be used by those who have the credentials to pull them. Without this admission control policy, once an image has been pulled to a node, any pod from any user can use it simply by knowing the image's name, without any authorization check against the image ownership. When this plug-in is enabled, images are always pulled prior to starting containers, which means valid credentials are required.

REQ-SEC-OCLOUD-SECPOL-7	DenyServiceExternalIPs, NetworkPolicies	NetworkPolicies allow to define rules governing how pods communicate with each other and with other network endpoints. These rules can specify what ingress (incoming) and egress (outgoing) traffic is allowed to and from a pod. DenyServiceExternalIPs admission controller can be used to prevent services from being exposed to the public internet via external IPs. NetworkPolicies allow to control egress/ingress traffic, ensuring that Pods can only communicate with approved, external IP ranges.
REQ-SEC-OCLOUD-SECPOL-8	PodTolerationRestriction	The PodTolerationRestriction admission controller ensures that pods are scheduled only on nodes that meet specific criteria defined by taints and tolerations. Taints are applied to nodes, and tolerations are set on pods to allow or prevent them from being scheduled on certain nodes.

C.2 Common Application Lifecycle Management

C.2.1 Software Package Protection

Potential controls on REQ-SEC-ALM-PKG-1 and REQ-SEC-ALM-PKG-4

Application packages need to be frequently tested throughout the lifecycle of the Application:

Table C.2.1-1: Application Testing throughout the lifecycle

During Development	During on-boarding and during instantiation	During Runtime
Vulnerability scanning Static Application Security Testing (SAST) Dynamic Application Security testing (DAST) Penetration testing Software composition analysis Testing to be performed frequently for vulnerability scanning or misconfiguration on Application packages. EXAMPLE: To check for malware or secrets stored in package. Responsible: Application Provider	Vulnerability scanning Dynamic Application Security testing (DAST) to be performed for: • Certifying the Application for functionality as well as authenticity, integrity, and packaging compliance. • Blocking deployments if the package doesn't comply with the Service Provider security policies • For scanning and detecting potential vulnerabilities • Checking for malware • Scanning for unnecessary system tools and libraries not required by Application • Software composition analysis Responsible: Application Provider, Service Provider	Perform continuous scanning/monitoring for known vulnerability or misconfiguration on runtime workloads, check for any open ports, VM/Container escape. Responsible: Service Provider

Tools used for static code and dynamic security analysis, analysis of code being released, and penetration test results must be shared with the Service Provider.

C.3 Certificate Management Framework

C.3.1 Certificate enrolment for NF Deployment

Potential solutions for SEC-CTL-CMF-VNF_CNF-1

Table C.3.1-1, Figure C.3.1-1 and Figure C.3.1-2 illustrate the steps performed to configure a certificate for NF Deployment. The certificate is used for secured communication between SMO and Cloudified NF. The below procedure is specified as an addition to the NF Deployment instantiation use case on O-Cloud as specified in clause 3.2.1 of ORAN TS Cloudification and Orchestration Use Cases and Requirements for O-RAN Virtualized RAN [82].

Table C.3.1-1: Certificate enrolment for NF Deployment

Use case stage	Evolution / specification	<<Uses>> Related use
Goal	Initial configuration and certificate enrolment for NF Deployment instance	
Actors and Roles	Network Function Install Project Manager: Operator designing each Network Function instance [82]. SMO: A Service Management and Orchestration framework [2]. NFO: Network Function Orchestration [2]. Operator PKI: Operator Public Key infrastructure. O-Cloud: Cloud platform that provides O-RAN standardized interfaces, hosting O-RAN defined software components [82]. Cloudified NF: A RAN Network Function software that is deployed in the O-Cloud via one or more NF Deployments [82]. NF Deployment: A software deployment on O-Cloud resources that realizes all or part of a Cloudified NF [82]. End Entity: user of PKI certificates and/or end user system that is the subject of a certificate [81];	
Assumptions	NF : O-RAN Cloudified Network Functions (i.e., Near-RT RIC, O-CU-CP, O-CU-UP and O-DU), as specified in [2]; NF instance secrets are shared in secured way before actual NF Deployment starts.	
Pre-conditions	i. Operator PKI is configured to issue a certificate to the NF Deployment instance. ii. All associated trust domains are created in PKI.	
Begins when	NF is ready for deployment.	
Step 1 (M)	Network Function Install Project Manager requests to SMO to instantiate NF Deployment on the O-Cloud.	
Step 2 (M)	NFO requests Operator PKI via the vendor specific PKI interface to create enrolment data for NF Deployment instance.	
Step 3(M)	Operator PKI responds with enrolment data to NFO. Enrolment data consists of: CMP details associated with provisioned End Entity as Cloudified NF, including Initial Authentication Key (IAK) and reference value as defined in clause 4.2.2.2 of RFC 4210 [59]; Root CA certificate.	
Step 4 (M)	NFO incorporates the enrolment data in NF Deployment initial configuration (including PKI server details). NF Deployment uses this data to request certificate and CA trust certs from Operator PKI.	
Step 5 (M)	NFO triggers NF Deployment in O-Cloud over O2 interface using O2-dms services.	
Step 6 (M)	O-Cloud creates NF Deployment instance.	
Step 7(O)	The NFO receives information about the success/failure of the NF Deployment instantiation in the O-Cloud.	
Step 8(M)	If the NF deployment was successful, NF Deployment instance generates key pairs & CSR and issues CMPv2 requests to Operator PKI based on the initial configuration.	
Step 9(M)	Operator PKI responds with certificate to the NF Deployment instance, including the trust anchors of the domains to which the node will communicate.	
Ends when	Initial configuration and certificate are issued for the NF Deployment instance.	
Exceptions	None identified	
Post-conditions	Trust established between the Cloudified NF and SMO.	

```

@startuml

!pragma teoz true
skinparam ParticipantPadding 5
skinparam BoxPadding 10
skinparam defaultFontSize 12
skinparam lifelineStrategy solid
autonumber
box #whitesmoke
box "SMO" #cadetBlue
participant "Network Function Install Project Manager" as operator
participant "NFO" as NFO

end box
participant "Operator PKI" as PKI
participant "O-Cloud" as cloud
box "Cloudified NF" #SkyBlue
participant "NF Deployment" as CNF

operator->>NFO: NF Deployment request
NFO-->>PKI: Create End Entity as Cloudified NF
Note over NFO, PKI
NFO requests Operator PKI via the vendor specific PKI interface
to create enrolment data for NF Deployment instance
end note

PKI-->>NFO: Return Initial Authentication Key (IAK) and PKI server details

Note over NFO, PKI
Operator PKI responds with enrolment data to NFO. Enrolment data
consists of: CMP details associated with provisioned End Entity as Cloudified NF,
including Initial Authentication Key (IAK) and reference value; Root CA trust certificate
end note

NFO->>NFO: Update NF Deployment for initial configuration

NFO->>cloud: NF Deployment in O-Cloud via O2 interface using O2dms services
cloud<-->>CNF: NF Deployment instance
cloud->>NFO: NF Deployment response (success/fail)

CNF-->>PKI: If the NF deployment was successful, NF Deployment instance \n generates key
pairs & CSR and issues CMPv2 requests to\n Operator PKI
Note over CNF, PKI
NF Deployment requests Operator PKI based on the initial configuration
end note

PKI-->>CNF: Process CSR and send certificate
Note over CNF, PKI
Operator PKI responds with certificate to the
NF Deployment instance, including the trust anchors
of the domains to which the node will communicate
end note

@enduml

```

Figure C.3.1-12: UML Code of certificate enrolment for NF Deployment

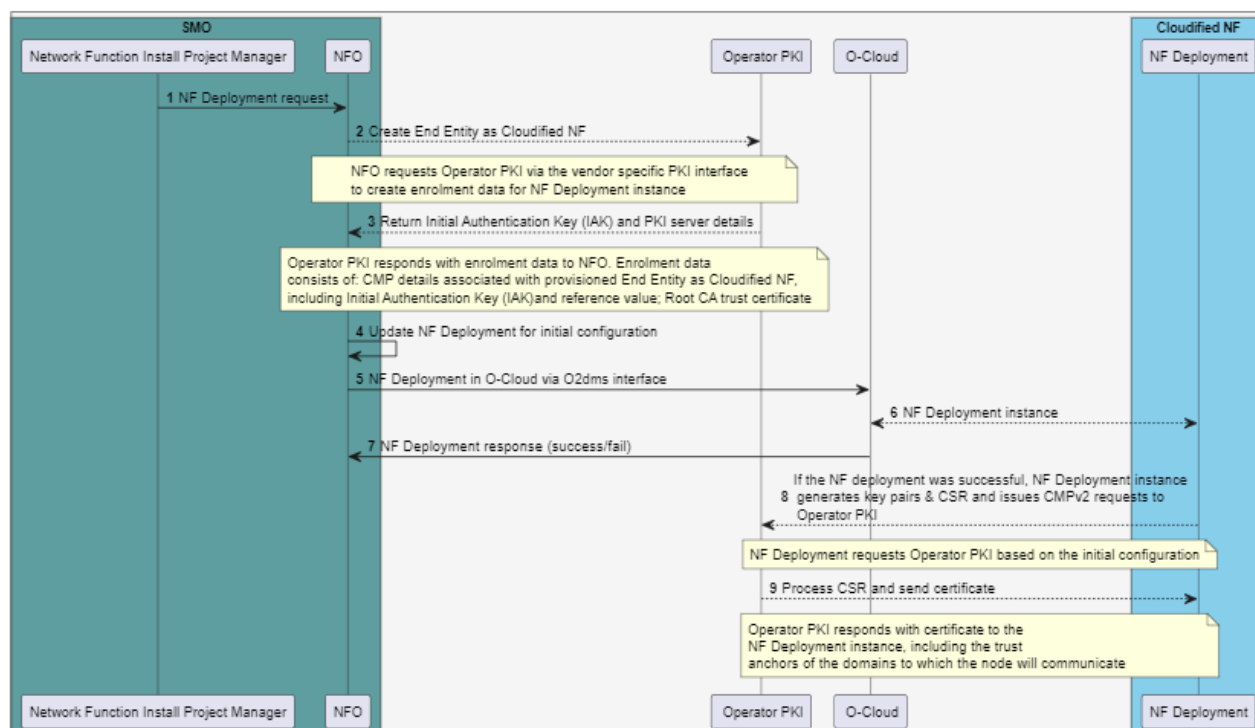


Figure C.3.1-23: Certificate enrolment for NF Deployment

Annex D (informative): Mapping of Threats to Requirements and Requirements to Controls

D.1 Threats to Requirements Mapping

Table D-1: Mapping of Threats defined in [i.14] to Security Requirements

Threat	Threat Title	Security requirements
Common Threats among O-RAN components		
T-O-RAN-01	An attacker exploits insecure designs or lack of adoption in O-RAN components	For further study
T-O-RAN-02	An attacker exploits misconfigured or poorly configured O-RAN components	For further study
T-O-RAN-03	Attacks from the internet exploit weak authentication and access control to penetrate O-RAN network boundary	For further study
T-O-RAN-04	An attacker attempts to jam the airlink signal through IoT devices	For further study
T-O-RAN-05	An attacker penetrates and compromises the O-RAN system through the open O-RAN's Fronthaul, O1, O2, A1, and E2	REQ-SEC-SLM-GSE-5
T-O-RAN-06	An attacker exploits insufficient/improper mechanisms for authentication and authorization to compromise O-RAN components	REQ-SEC-SLM-GSE-5 REQ-SEC-SLM-SST-1..7
T-O-RAN-07	An attacker compromises O-RAN monitoring mechanisms and log files integrity and availability	REQ-SEC-SLM-FLD-2, REQ-SEC-SLM-ATS-1, REQ-SEC-SLM-SST-1..7, REQ-SEC-SLM-STR-1..5, REQ-SEC-SLM-DDA-9
T-O-RAN-08	An attacker compromises O-RAN data integrity, confidentiality and traceability	REQ-SEC-SLM-DAT-EVT-1..8 REQ-SEC-SLM-GSE-5 REQ-SEC-SLM-SST-7, REQ-SEC-SLM-TLD-1..5
T-O-RAN-09	An attacker compromises O-RAN components integrity and availability	REQ-SEC-SLM-DoS-1..7 REQ-SEC-SLM-SST-7, REQ-SEC-SLM-TLD-1..5
T-O-RAN-10	Inconsistent Log Format Impeding Effective Attack Detection	REQ-SEC-SLM-FMT-1, REQ-SEC-SLM-FLD-1..3, REQ-SEC-SLM-FLD-1, REQ-SEC-SLM-FMT-1, REQ-SEC-LCSS-2..5, REQ-SEC-SLM-DDA-1..11
Fronthaul interface and M-S-C-U planes		
T-FRHAUL-01	An attacker penetrates O-DU and beyond through O-RU or the Fronthaul interface	REQ-SEC-OFHM-2 and REQ-SEC-OFHM-3
T-FRHAUL-02	Unauthorized access to Open Front Haul Ethernet L1 physical layer interface(s)	REQ-SEC-OFHM-4
T-MPLANE-01	An attacker attempts to intercept the Fronthaul (MITM) over M Plane	REQ-SEC-OFHM-1, REQ-SEC-OFHM-5 thru SEC-OFHM-9
T-SPLANE-01	DoS attack against a Master clock	REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-ATS-1
T-SPLANE-02	Impersonation of a Master clock (Spoofing) within a PTP network with a fake ANNOUNCE message	REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-ATS-1
T-SPLANE-03	A Rogue PTP Instance wanting to be a Grand Master	REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-ATS-1
T-SPLANE-04	Selective interception and removal of PTP timing packets	REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-ATS-1
T-SPLANE-05	Packet delay manipulation attack	REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-ATS-1
T-CPLANE-01	Spoofing of DL C-plane messages	For further study
T-CPLANE-02	Spoofing of UL C-plane messages	For further study
T-UPLANE-01	An attacker attempts to intercept the Fronthaul (MITM) over U Plane	For further study
O-RU		
T-ORU-01	An attacker stands up a false base station attack by attacking an O-RU	For further study
Near-RT RIC		
T-NEAR-RT-01	Malicious xApps can exploit UE identification, track UE location and change UE priority	REQ-SEC-NEAR-RT-1

T-NEAR-RT-02	Risk of deployment of a malicious xApp on Near-RT RIC	REQ-SEC-OCLOUD-PKG-1..3, REQ-SBOM-001..002, REQ-SBOM-004..006, REQ-SEC-NEAR-RT-1..4, REQ-SEC-XAPP-3..4
T-NEAR-RT-03	Attackers exploit non authenticated, weakly or incorrectly authenticated Near-RT RIC APIs	REQ-SEC-OCLOUD-PKG-1..3, REQ-SBOM-001..002, REQ-SBOM-004..006, REQ-SEC-NEAR-RT-1..4, REQ-SEC-E2-1, SEC-CTL-E2
T-NEAR-RT-04	Attackers exploit non authorized Near-RT RIC APIs to access to resources and services which they are not entitled to use.	REQ-SEC-NEAR-RT-1..4, REQ-SEC-OCLOUD-PKG-1..3
T-NEAR-RT-05	Attackers exploit non uniquely identified xApps using a trusted xAppID to access to resources and services which they are not entitled to use.	REQ-SEC-XAPP-3..4, SEC-CTL-NEAR-RT-13..14
Non-RT RIC		
T-NONRTRIC-01	An attacker gains access to the Non-RT RIC through the SMO to cause a denial of service or degrade the performance of the Non-RT-RIC	For further study
T-NONRTRIC-02	An attacker gains access to the Non-RT RIC through the SMO for UE tracking	For further study
T-NONRTRIC-03	An attacker gains access to the Non-RT RIC through the SMO to cause Data Corruption/Modification	For further study
T-NONRTRIC-04	An attacker exploits non uniquely identified rApp instances using a trusted rAppID to access R1 services and data which they are not entitled to use	For further study
xAPPs		
T-xApp-01	An attacker exploits xApps vulnerabilities and misconfiguration	REQ-SEC-OCLOUD-PKG-1..3, REQ-SBOM-001..002, REQ-SBOM-004..006, REQ-SEC-NEAR-RT-1..4
T-xApp-02	Conflicting xApps unintentionally or maliciously impact O-RAN system functions to degrade performance or trigger a DoS	REQ-SEC-E2-1, SEC-CTL-E2
T-xApp-03	An attacker compromises xApp isolation	REQ-SEC-NEAR-RT-1..4, REQ-SEC-OCLOUD-PKG-1..3, REQ-TLS-FUN-1..10, REQ-SEC-SLM-GEN-EVT-1..6, REQ-SEC-SLM-HYP-EVT-1..3, REQ-SEC-SLM-CON-EVT-1..3, REQ-SEC-SLM-APP-EVT-1..2, REQ-SEC-SLM-DAT-EVT-1..8, REQ-SEC-SLM-AAI-EVT-1..10, REQ-SEC-SLM-GSE-1..6, REQ-SEC-SLM-TESS-4, REQ-SEC-SLM-FLD-3, REQ-SEC-SLM-AAI-EVT-4
T-xApp-04	False or malicious A1 policies modify behavior of xApps	REQ-SEC-NEAR-RT-1..7, REQ-SEC-A1-1..2
rAPPs		
T-rAPP-01	Conflicting rApps impact O-RAN system functions to degrade performance or trigger a DoS	For further study
T-rAPP-02	An attacker exploits rApp vulnerability for data breach or denial of service	For further study
T-rAPP-03	An attacker exploits rApps misconfiguration	For further study
T-rAPP-04	An attacker bypasses authentication and authorization	For further study
T-rAPP-05	An attacker deploys and exploits malicious rApp	For further study
T-rAPP-06	An attacker bypasses authentication and authorization using an injection attack	For further study
T-rAPP-07	rApp exploits services	For further study
PNF		
T-PNF-01	An attacker compromises a PNF to launch reverse attacks and other attacks against VNFs/CNFs	For further study
R1		

T-R1-01	A malicious actor gains unauthorized access to R1 services	For further study
T-R1-02	Attacker modifies Service Heartbeat message to cause Denial of Service	For further study
T-R1-03	Malicious actor bypasses authentication to Request Data	For further study
T-R1-04	Malicious actor bypasses authorization to Discover Data	For further study
T-R1-05	A malicious actor gains unauthorized access to data	For further study
T-R1-06	Malicious actor modifies a Data Request	For further study
T-R1-07	Malicious actor compromises Data Delivery to the Data Consumer	For further study
A1		
T-A1-01	Untrusted peering between Non-RT-RIC and Near-RT-RIC	For further study
T-A1-02	Malicious function or application monitors messaging across A1 interface	For further study
T-A1-03	Malicious function or application modifies messaging across A1 interface	For further study
Application Life Cycle		
T-AppLCM-01	Compromise of App/VNF/CNF update package integrity prior to onboarding	REQ-SEC-ALM-PKG-2 REQ-SEC-ALM-PKG-3 REQ-SEC-ALM-PKG-4 REQ-SEC-ALM-PKG-5 REQ-SEC-ALM-PKG-6
T-AppLCM-02	Compromise of App/VNF/CNF update image integrity during instantiation	REQ-SEC-OCLOUD-PKG-1 REQ-SEC-OCLOUD-PKG-2
T-AppLCM-03	Downgrade attack to vulnerable application version	REQ-SEC-ALM-SU-3
T-AppLCM-04	Attacker exploits missing or improperly defined elements of application's SecurityDescriptor	REQ-SEC-LCM-SD-1 REQ-SEC-LCM-SD-2
T-AppLCM-05	Malicious actor modifies application's SecurityDescriptor	Integrity protection of descriptors during delivery and onboarding: REQ-SEC-ALM-PKG-2, REQ-SEC-ALM-PKG-4, REQ-SEC-ALM-PKG-5, REQ-SEC-ALM-PKG-6 Integrity protection within the catalogue (SMO level): REQ-SEC-ALM-PKG-10, REQ-SEC-ALM-PKG-11 Integrity protection during the life cycle: REQ-SEC-ALM-PKG-13 Integrity protection within the O-Cloud: REQ-SEC-OCLOUD-SS-1
T-AppLCM-06	Improper decommissioning of application	REQ-SEC-ALM-DECOM-1 REQ-SEC-ALM-DECOM-2 REQ-SEC-ALM-DECOM-3
T-AppLCM-07	Improper deletion of application sensitive data	REQ-SEC-OCLOUD-SS-2 REQ-SEC-OCLOUD-SS-3 REQ-SEC-OCLOUD-SS-4 REQ-SEC-OCLOUD-SS-5
E2		
T-E2-01	Untrusted Near-RT-RIC and/or E2 Nodes	REQ-SEC-NEAR-RT-9
T-E2-02	Malicious actor monitors messaging across E2 interface	REQ-SEC-E2-1
T-E2-03	Malicious actor modifies messaging across E2 interface	REQ-SEC-E2-1
Y1		
T-Y1-01	Untrusted Near-RT-RIC and Y1 consumers	REQ-SEC-NEAR-RT-8, REQ-SEC-Y1-1..6
T-Y1-02	Malicious actor monitors messaging across Y1 interface	REQ-SEC-Y1-3

T-Y1-03	Malicious actor modifies messaging across Y1 interface	REQ-SEC-Y1-3
O-Cloud		
T-GEN-01	Software flaw attack	SBOM requirements REQ-SEC-OCLOUD-SU-1 REQ-SEC-OCLOUD-SU-5 REQ-SEC-OCLOUD-SU-6 REQ-SEC-OCLOUD-SU-7 REQ-SEC-SLM-GEN-EVT-1..6, REQ-SEC-SLM-HYP-EVT-1..3, REQ-SEC-SLM-CON-EVT-1..3, REQ-SEC-SLM-APP-EVT-1..2, REQ-SEC-SLM-DAT-EVT-1..8, REQ-SEC-SLM-AAI-EVT-1..10, REQ-SEC-SLM-GSE-1..6, REQ-SEC-SLM-TESS-4, REQ-SEC-SLM-FLD-3, REQ-SEC-SLM-AAI-EVT-4, REQ-SEC-SLM-TESS-3
T-GEN-02	Malicious access to exposed services using valid accounts	REQ-SEC-OCLOUD-1 REQ-SEC-OCLOUD-2 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-GEN-03	Untrust binding between the different O-Cloud layers	REQ-SEC-OCLOUD-COT-1 REQ-SEC-OCLOUD-COT-2 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-GEN-04	Lack of Authentication & Authorization in interfaces between O-Cloud components	REQ-SEC-OCLOUD-ISO-1 REQ-SEC-OCLOUD-ISO-2 REQ-SEC-OCLOUD-ISO-3 REQ-SEC-OCLOUD-ISO-4 REQ-SEC-OCLOUD-ISO-5 REQ-SEC-OCLOUD-ISO-6 REQ-SEC-OCLOUD-ISO-7 REQ-SEC-TESR-1 REQ-SEC-SLM-GEN-EVT-1..6, REQ-SEC-SLM-HYP-EVT-1..3, REQ-SEC-SLM-CON-EVT-1..3, REQ-SEC-SLM-APP-EVT-1..2, REQ-SEC-SLM-DAT-EVT-1..8, REQ-SEC-SLM-AAI-EVT-1..10, REQ-SEC-SLM-GSE-1..6, REQ-SEC-SLM-TESS-4, REQ-SEC-SLM-FLD-3, REQ-SEC-SLM-AAI-EVT-4, REQ-SEC-SLM-TESS-3
T-GEN-05	Unsecured credentials and keys	REQ-SEC-OCLOUD-SS-1 REQ-SEC-OCLOUD-SS-2 REQ-SEC-OCLOUD-SS-3 REQ-SEC-OCLOUD-SS-4 REQ-SEC-SLM-GEN-EVT-1..6, REQ-SEC-SLM-HYP-EVT-1..3, REQ-SEC-SLM-CON-EVT-1..3, REQ-SEC-SLM-APP-EVT-1..2, REQ-SEC-SLM-DAT-EVT-1..8, REQ-SEC-SLM-AAI-EVT-1..10, REQ-SEC-SLM-GSE-1..6, REQ-SEC-SLM-TESS-4, REQ-SEC-SLM-FLD-3, REQ-SEC-SLM-AAI-EVT-4, REQ-SEC-SLM-TESS-3
T-GEN-06	Sensitive application data cache exploitation	REQ-SEC-OCLOUD-SS-1 REQ-SEC-OCLOUD-SS-2 REQ-SEC-OCLOUD-SS-3 REQ-SEC-OCLOUD-SS-4 REQ-SEC-OCLOUD-SS-5

T-VM-C-01	Abuse of a privileged VM/Container	REQ-SEC-OCLOUD-ISO-1 REQ-SEC-OCLOUD-ISO-2 REQ-SEC-OCLOUD-ISO-3 REQ-SEC-OCLOUD-ISO-4 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-VM-C-02	VM/Container escape attack	REQ-SEC-OCLOUD-ISO-1 REQ-SEC-OCLOUD-ISO-3 REQ-SEC-SLM-GEN-EVT-1..6, REQ-SEC-SLM-HYP-EVT-1..3, REQ-SEC-SLM-CON-EVT-1..3, REQ-SEC-SLM-APP-EVT-1..2, REQ-SEC-SLM-DAT-EVT-1..8, REQ-SEC-SLM-AAI-EVT-1..10, REQ-SEC-SLM-GSE-1..6, REQ-SEC-SLM-TESS-4, REQ-SEC-SLM-FLD-3, REQ-SEC-SLM-AAI-EVT-4, REQ-SEC-SLM-TESS-3
T-VM-C-03	VM/Container data theft	REQ-SEC-O-CLOUD-ISO-4 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-VM-C-04	VM/Container migration attacks	REQ-SEC-LCM-SD-6 REQ-SEC-ALM-PKG-13 REQ-SEC-ALM-PKG-15 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-VM-C-05	Changing virtualization resource without authorization	REQ-SEC-OCLOUD-ISO-1 REQ-SEC-OCLOUD-ISO-3 REQ-SEC-O-CLOUD-ISO-4 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-VM-C-06	Failed or incomplete VNF/CNF termination or releasing of resources	REQ-SEC-ALM-PKG-13 REQ-SEC-ALM-DECOM-3 REQ-SEC-ALM-PKG-15 REQ-SEC-OCLOUD-SS-2 REQ-SEC-OCLOUD-SS-3 REQ-SEC-OCLOUD-SS-4 REQ-SEC-OCLOUD-SS-5 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-IMG-01	VM/Container images tampering	REQ-SEC-OCLOUD-PKG-1 REQ-SEC-OCLOUD-PKG-2 REQ-SEC-OCLOUD-PKG-3 REQ-SEC-ALM-PKG-1 to REQ-SEC-ALM-PKG-15 REQ-SEC-SLM-GEN-EVT-1..6, REQ-SEC-SLM-HYP-EVT-1..3, REQ-SEC-SLM-CON-EVT-1..3, REQ-SEC-SLM-APP-EVT-1..2, REQ-SEC-SLM-DAT-EVT-1..8, REQ-SEC-SLM-AAI-EVT-1..10, REQ-SEC-SLM-GSE-1..6, REQ-SEC-SLM-TESS-4, REQ-SEC-SLM-FLD-3, REQ-SEC-SLM-AAI-EVT-4, REQ-SEC-SLM-TESS-3
T-IMG-02	Insecure channels with images repository	
T-IMG-03	Secrets disclosure in VM/Container images	
T-IMG-04	Build image on VL	
T-VL-01	VM/Container hyperjacking attack	REQ-SEC-OCLOUD-SU-1 REQ-SEC-OCLOUD-SU-5 REQ-SEC-OCLOUD-SU-6 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-VL-02	Boot tampering	REQ-SEC-OCLOUD-COT-1 REQ-SEC-OCLOUD-COT-2 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6

T-VL-03	Attack internal network services	REQ-SEC-OCLOUD-ISO-1 REQ-SEC-OCLOUD-ISO-2 REQ-SEC-OCLOUD-ISO-3 REQ-SEC-OCLOUD-ISO-4 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-O2-01	MitM attacks on O2 interface between O-Cloud and SMO	REQ-SEC-OCLOUD-O2dms-1 REQ-SEC-OCLOUD-O2dms-2 REQ-SEC-OCLOUD-O2dms-3 REQ-SEC-OCLOUD-O2dms-4 REQ-SEC-OCLOUD-O2ims-1 REQ-SEC-OCLOUD-O2ims-2 REQ-SEC-OCLOUD-O2ims-3 REQ-SEC-OCLOUD-O2ims-4 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-OCAPI-01	MitM attacks on O-Cloud interface between VNFs/CNFs and the virtualization layer	REQ-SEC-O-CLOUD-NotifAPI-1 REQ-SEC-O-CLOUD-NotifAPI-2 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-HW-01	Cross VM/Container side channel attacks	REQ-SEC-O-CLOUD-HW-1 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-HW-02	MitM attacks on the interface between virtualization layer and hardware	To be addressed in a future version REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-ADMIN-01	Denial of service against NFO/FOCOM	REQ-SEC-DOS-1 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-ADMIN-02	Abuse a O-Cloud administration service	To be addressed in a future version REQ-SEC-SLM-GEN-EVT-1..6, REQ-SEC-SLM-HYP-EVT-1..3, REQ-SEC-SLM-CON-EVT-1..3, REQ-SEC-SLM-APP-EVT-1..2, REQ-SEC-SLM-DAT-EVT-1..8, REQ-SEC-SLM-AAI-EVT-1..10, REQ-SEC-SLM-GSE-1..6, REQ-SEC-SLM-TESS-4, REQ-SEC-SLM-FLD-3, REQ-SEC-SLM-AAI-EVT-4, , REQ-SEC-SLM-TESS-3
T-AAL-01	Attacker exploits insecure API to gain access to hardware accelerator resources	REQ-SEC-AALI-C-Mgmt-1 REQ-SEC-AALI-C-Mgmt-2 REQ-SEC-AALI-C-Mgmt-3 REQ-SEC-AAL-VS-1 REQ-SEC-AAL-VS-2 REQ-SEC-AAL-VS-3 REQ-SEC-AAL-VS-4 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-AAL-02	Internal Overload DoS attack targeting AAL services	REQ-SEC-DOS-1 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-AAL-03	Fail to clear resources	REQ-SEC-AAL-1 REQ-SEC-AAL-2 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-AAL-04	HAM compromise	REQ-SEC-AAL-4 REQ-SEC-AAL-6 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-AAL-05	Malicious memory accesses	REQ-SEC-AAL-4 REQ-SEC-AAL-5 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6

T-AAL-06	Firmware attacks	REQ-SEC-AAL-3 REQ-SEC-AAL-4 REQ-SEC-SLM-TESS-3, REQ-SEC-SLM-NET-EVT-1, REQ-SEC-SLM-GEN-EVT-1..6
T-O-CLOUD-ID-01	ID reuse in O-Cloud's object lifecycle	REQ-SEC-OCLOUD-INST-ID-1 REQ-SEC-OCLOUD-INST-ID-2 REQ-SEC-OCLOUD-INST-ID-3 REQ-SEC-OCLOUD-INST-ID-4 REQ-SEC-OCLOUD-INST-ID-5
T-O-CLOUD-ID-02	Node redundancy in O-Cloud deployments	
T-O-CLOUD-ID-03	O-Cloud ID mismanagement	
T-TS-01	Time synchronization disruption in O-Cloud	REQ-SEC-OCLOUD-TS-1 REQ-SEC-OCLOUD-TS-2 REQ-SEC-OCLOUD-TS-3 REQ-SEC-OCLOUD-TS-4 REQ-SEC-OCLOUD-TS-5
Open source		
T-OPENSRC-01	Developers use SW components with known vulnerabilities and untrusted libraries that can be exploited by an attacker through a backdoor attack	REQ-SEC-SLM-APP-EVT-2
T-OPENSRC-02	A trusted developer intentionally inserts a backdoor into an open source code O-RAN component	For further study
Physical		
T-PHYS-01	An intruder into a site gains physical access to O-RAN components to cause damage or access sensitive data	For further study
T-PHYS-02	An intruder into the exchange over the Fronthaul cable network attempts to gain electronic access to cause damage or access sensitive data	For further study
Radio networks		
T-RADIO-01	Disruption through radio jamming, sniffing and spoofing	For further study
T-RADIO-02	DoS attacks on cognitive radio networks	For further study
AI/ML		
T-AIML-DP-01	Black box data poisoning attacks	For further study
T-AIML-DP-02	Grey box data poisoning attacks	For further study
T-AIML-DP-03	White box data poisoning attacks	For further study
T-AIML-MEI-01	Information access-based membership inference attack	For further study
T-AIML-MEI-02	Inference technique-based membership inference attack	For further study
T-AIML-MEI-03	Target based membership inference attack	For further study
T-AIML-ME-01	Intellectual Property Theft	For further study
T-AIML-ME-02	Data Privacy Violations	For further study
T-AIML-ME-03	Adversarial Attacks	For further study
T-AIML-IM-1	Training Data Control	For further study
T-AIML-IM-3	Testing Data Control	For further study
T-AIML-IM-4	Label Manipulation	For further study
T-AIML-IM-5	AI/ML Query Exploitation	For further study
T-AIML-MOI-01	Black-box model inversion attack	For further study
T-AIML-MOI-02	White-box model inversion attack	For further study
T-AIML-SC-01	Data poisoning	For further study
T-AIML-SC-02	Model tampering	For further study
T-AIML-SC-03	Backdoor attacks	For further study
T-AIML-SC-04	Hardware tampering	For further study
T-AIML-SC-05	Insecure maintenance APIs	For further study
T-AIML-SC-06	Third-party libraries and dependencies	For further study
T-AIML-OI-01	Denial of service	For further study
T-AIML-OI-02	Subscriber QoE change	For further study

T-AIML-MP-01	Model Parameter Poisoning	For further study
T-AIML-MP-02	Inference Algorithm Poisoning	For further study
T-AIML-MP-03	Learning Algorithm Poisoning	For further study
T-AIML-MP-04	Model Control	For further study
T-AIML-MS-01	Data manipulation-based Model skewing attacks	For further study
T-AIML-MS-02	Feedback manipulation-based Model Skewing attacks	For further study
T-AIML-TL-01	Data poisoning	For further study
T-AIML-TL-02	Model stealing	For further study
T-AIML-TL-03	Adversarial examples	For further study
T-AIML-TL-04	Backdoor attacks	For further study
T-AIML-EV-01	Grey-box based data evasion attacks	For further study
T-AIML-EL-01	Model Extraction	For further study
T-AIML-EL-02	Data Inference	For further study
T-AIML-EL-03	Denial of Service	For further study
Protocol Stack		
T-ProtocolStack-01	REST API Exploits	For further study
T-ProtocolStack-02	REST API – Broken Object Level Authorization	For further study
T-ProtocolStack-03	JSON Exploits	For further study
T-ProtocolStack-04	HTTP Exploits	For further study
T-ProtocolStack-05	TCP Volumetric DDoS	For further study
SMO		
T-SMO-01	External attacker exploits authentication weakness on SMO	REQ-SEC-SMO-2, REQ-SEC-SMO-External-2, REQ-SEC-SME-2, REQ-SEC-DME-2
T-SMO-02	External attacker exploits authorization weakness on SMO	REQ-SEC-SMO-4, REQ-SEC-SMO-External-3, REQ-SEC-SME-5, REQ-SEC-DME-4
T-SMO-03	External Overload DoS attack targeted at SMO	REQ-SEC-SMO-6, REQ-SEC-SME-8, REQ-SEC-DME-7
T-SMO-04	Internal attacker exploits authentication weakness on a SMO function	REQ-SEC-SMO-1, REQ-SEC-SMO-Internal-2, REQ-SEC-NFO-FOCOM-3, REQ-SEC-NFO-FOCOM-4, REQ-SEC-SME-1, REQ-SEC-SME-3, REQ-SEC-DME-1, REQ-SEC-SMOS-1
T-SMO-05	Internal attacker exploits authorization weakness on a SMO function	REQ-SEC-SMO-3, REQ-SEC-SME-4, REQ-SEC-SME-9, REQ-SEC-DME-3, REQ-SEC-SMOS-2
T-SMO-06	Internal Overload DoS attack targeted at SMO functions	REQ-SEC-SMO-5, REQ-SEC-SMO-7, REQ-SEC-SME-7, REQ-SEC-DME-6
T-SMO-07	Internal DoS attack disables internal SMO function(s) or process(es)	REQ-SEC-NFO-FOCOM-5
T-SMO-08	Attacker exploits insecure API to gain access to SMO	REQ-SEC-SMO-External-1, REQ-SEC-SME-6
T-SMO-09	Sensitive data in transit is exposed to an internal attacker	REQ-SEC-SMO-Internal-1, REQ-SEC-SMOS-3, REQ-SEC-SME-6, REQ-SEC-DME-5
T-SMO-10	Sensitive data at rest is exposed to an internal attacker	For further study
T-SMO-11	AI/ML poisoning by internal attacker	For further study
T-SMO-12	AI/ML exposure on external entity	For further study
T-SMO-13	Malicious actor views local logs	REQ-SEC-SMO-Log-5, REQ-SEC-SMO-Log-10

T-SMO-14	Malicious actor modifies local log entries	REQ-SEC-SMO-Log-6
T-SMO-15	Malicious actor deletes local logs	REQ-SEC-SMO-Log-6
T-SMO-16	Malicious actor intercepts exports of local logs	REQ-SEC-SMO-Log-1, REQ-SEC-SMO-Log-2, REQ-SEC-SMO-Log-3
T-SMO-17	Malicious external actor gains unauthorized access to logs	REQ-SEC-SMO-Log-7, REQ-SEC-SMO-Log-8, REQ-SEC-SMO-Log-11, REQ-SEC-SMO-Log-12
T-SMO-18	Malicious internal actor gains authorized access to logs	REQ-SEC-SMO-Log-11, REQ-SEC-SMO-Log-12
T-SMO-19	Internal attacker exploits O2 interface to view data in transit between SMO and O-Cloud	REQ-SEC-NFO-FOCOM-1
T-SMO-20	Internal attacker exploits O2 interface to modify data in transit between SMO and O-Cloud	REQ-SEC-NFO-FOCOM-1
T-SMO-21	Internal attacker uses O2 interface via SMO to exploit API vulnerability to gain access to O-Cloud infrastructure	REQ-SEC-NFO-FOCOM-1
T-SMO-22	Internal attacker floods O2 interface via SMO to cause DDoS on O-Cloud infrastructure	REQ-SEC-NFO-FOCOM-6, REQ-SEC-NFO-FOCOM-8
T-SMO-23	External attacker uses O2 interface via O-Cloud to exploit API vulnerability to gain access to SMO	REQ-SEC-NFO-FOCOM-1
T-SMO-24	External attacker floods O2 interface via O-Cloud to cause DDoS on SMO	REQ-SEC-NFO-FOCOM-6, REQ-SEC-NFO-FOCOM-8
T-SMO-25	External attacker uses O2 interface via O-Cloud to gain authorized access to sensitive data-at-rest at the SMO	REQ-SEC-NFO-FOCOM-5
T-SMO-26	External attacker exploits External interface to view data in transit between SMO and external service	REQ-SEC-SMO-External-1
T-SMO-27	External attacker exploits External interface to modify data in transit between SMO and external service	REQ-SEC-SMO-External-1
T-SMO-28	External attacker uses External interface to exploit API vulnerability to gain access to SMO	REQ-SEC-SMO-External-1
T-SMO-29	External attacker floods External interface to cause DDoS at SMO	REQ-SEC-SMO-6
T-SMO-30	External attacker uses External interface to gain access to sensitive data-at-rest at the SMO	REQ-SEC-SMO-External-2, REQ-SEC-SMO-External-3
T-SMO-31	External attacker poisons External AI/ML data to corrupt SMO	For further study
T-SMO-32	External attacker poisons External Enrichment Information data sources to corrupt SMO	Not in O-RAN scope for specification
T-SMO-33	rApp floods SME	REQ-SEC-SME-7
T-SMO-34	External Consumer floods SME	REQ-SEC-SME-8
Shared O-RU		
T-SharedORU-01	O-DU Tenant accesses O-DU Host	For further study
T-SharedORU-02	O-DU Host accesses O-DU Tenant	For further study
T-SharedORU-03	O-DU Tenant accesses O-DU Tenant	For further study
T-SharedORU-04	Password Attack on OFH M-Plane	For further study
T-SharedORU-05	Untrusted peering to O-DU	For further study
T-SharedORU-06	Untrusted peering to the Shared O-RU	For further study
T-SharedORU-07	Untrusted peering to the SMO	For further study
T-SharedORU-08	SMO Tenant accesses SMO Host	For further study

T-SharedORU-09	SMO Host accesses SMO Tenant	For further study
T-SharedORU-10	O-DU Host accesses O-CU Tenant	For further study
T-SharedORU-11	O-DU Tenant accesses O-CU Host	For further study
T-SharedORU-12	O-DU Tenant accesses O-CU Tenant	For further study
T-SharedORU-13	SMO Host accesses O-CU Tenant	For further study
T-SharedORU-14	SMO Tenant accesses O-CU Host	For further study
T-SharedORU-15	Physical port access to Shared O-RU Host/Tenant	For further study
T-SharedORU-16	Physical port access to O-DU Host/Tenant	For further study
T-SharedORU-17	Physical port access to O-CU Host/Tenant	For further study
T-SharedORU-18	Malicious User Login Attempt to SMO Host/Tenant	For further study
T-SharedORU-19	Malicious User Login Attempt to O-CU Host/Tenant	For further study
T-SharedORU-20	Malicious User Login Attempt to O-DU Host/Tenant	For further study
T-SharedORU-21	Malicious User Login Attempt to Shared O-RU Host/Tenant	For further study
T-SharedORU-22	Unauthorized internal threat actor gains access to data in Shared O-RU	For further study
T-SharedORU-23	Unauthorized external threat actor gains access to data in Shared O-RU	For further study
T-SharedORU-24	Data exposure at Shared O-RU	For further study
T-SharedORU-25	Shared O-RU data exposure at SMO	For further study
T-SharedORU-26	Shared O-RU data exposure at O-DU	For further study
T-SharedORU-27	Exposed data in transit between Shared O-RU and O-DU Host/Tenant	For further study
T-SharedORU-28	Exposed data in transit between Shared O-RU and SMO Host/Tenant	For further study
T-SharedORU-29	Modify/Delete OFH C-Plane messages	For further study
T-SharedORU-30	Clock hijacking on OFH S-Plane	For further study
T-SharedORU-31	Parameter conflicts at Shared O-RU	For further study
T-SharedORU-32	Volumetric DDoS attack from O-DU targeting Shared O-RU	For further study
T-SharedORU-33	Volumetric DDoS attack from SMO targeting Shared O-RU	For further study
T-SharedORU-34	Volumetric DDoS attack targeting O-DU	For further study
T-SharedORU-35	Shared O-RU initialization hijacking by DHCP compromise	For further study
T-SharedORU-36	Shared O-RU M-plane hijacking by DNS compromise	For further study
T-SharedORU-37	Misconfiguration of MNO Host Role	For further study
T-SharedORU-38	Incorrect Assignment of Spectrum Resources	For further study

T-SharedORU-39	Chain of Trust in a Multi-Tenant Environment	For further study
T-SharedORU-40	Hijack of MNO Host Role	For further study
T-SharedORU-41	Not Released Host Role (Host Role resume)	For further study
T-SharedORU-42	Misuse of “sudo” privileges	For further study
T-SharedORU-43	Eavesdropping of unprotected CUSM-plane data within shared O-RU	For further study
T-SharedORU-52	Thrashing O-DU Failovers	For further study
T-SharedORU-53	Dual (Dueling) Active O-DUs	For further study
T-SharedORU-54	Modify/Inject O1 messages at the SMO	For further study
T-SharedORU-55	Set Incorrect Array-Carrier configuration on O-DU (Standby)	For further study
T-SharedORU-56	Modify Array-Carrier pre-configuration on Shared O-RU	For further study
T-SharedORU-57	Modify/Inject M-Plane messages with Array-Carrier configuration	For further study
OAuth 2.0		
T-OAuth-G-01	Obtaining client secrets	For further study
T-OAuth-G-02	Obtaining refresh tokens	For further study
T-OAuth-G-03	Obtaining access tokens	For further study
T-OAuth-G-04	Eavesdropping access tokens	For further study
T-OAuth-G-05	Disclosure of client credentials during transmission	For further study
T-OAuth-G-06	Open redirectors on client	For further study
T-OAuth-G-07	Obtain a deployment specific secret	For further study
T-OAuth-G-08	Obtaining authorization by code substitution (OAuth Login)	For further study
T-OAuth-G-09	Access token leak in transport/endpoints	For further study
T-OAuth-G-10	Malicious client obtains existing authorization by fraud	For further study
T-OAuth-G-11	Malicious client obtains authorization	For further study
T-OAuth-G-12	Accidental exposure of passwords at client site	For further study
T-OAuth-G-13	Client obtains scopes without end-user authorization and possible misconfigurations	For further study
T-OAuth-G-14	Client obtains refresh token through automatic authorization	For further study
T-OAuth-G-15	Eavesdropping refresh tokens from authorization server	For further study
T-OAuth-G-16	Obtaining refresh token by online guessing	For further study
T-OAuth-G-17	Refresh token phishing by counterfeit authorization server	For further study
T-OAuth-G-18	Guessing access tokens	For further study
T-OAuth-G-19	Access token phishing by counterfeit resource server	For further study
T-OAuth-G-20	Abuse of token by legitimate resource server or client	For further study
T-OAuth-G-21	Token leakage via log files and http referrers	For further study
T-OAuth-G-22	User unintentionally grants too much access scope	For further study
T-OAuth-G-23	Leak of confidential data in HTTP proxies	For further study
T-OAuth-G-24	Replay of authorized resource server requests	For further study

D.2 Requirements to Controls Mapping

Table D-2 reflects the relationship between the defined Security Requirements in this document, and the Security Controls.

For *Support* column in Table D-2, the values mean the following:

- MS: The requirement is Mandatory to Support
EXAMPLE: "shall support", "shall be capable", "shall have the capability", "shall provide the capability", "shall be possible", "shall provide a means to"; "shall provide mechanisms"; "shall be configurable"
- M: The requirement is Mandatory
EXAMPLE: "shall be able to", "shall provide", "shall", "shall be in place"
- OS: The requirement is Optional to Support
EXAMPLE: "may support"; "should support"
- O: The requirement is Optional
EXAMPLE: "should"

For *Control/s covering the requirement* column, the different values in the Table D-2 mean the following:

- SEC-CTL ID(s) present – one or several controls are existing and defined by the spec
- Not defining a control, to enable the many implementations that are existing.: Intentionally the control is not defined
- Control not needed: The requirement is enough specific to not need a control

Table D-2: Map between Security Requirements and Security Controls

Requirements	Support	Control/s covering the requirement
SMO		
REQ-SEC-SMO-1	MS	SEC-CTL-SMO-5 SEC-CTL-SMO-6
REQ-SEC-SMO-2	MS	SEC-CTL-SMO-5 SEC-CTL-SMO-6
REQ-SEC-SMO-3	MS	SEC-CTL-SMO-1 SEC-CTL-SMO-3 SEC-CTL-SMO-4
REQ-SEC-SMO-4	MS	SEC-CTL-SMO-1 SEC-CTL-SMO-3
REQ-SEC-SMO-5	M	Control not needed.
REQ-SEC-SMO-6	M	Control not needed.
REQ-SEC-SMO-7	M	Control not needed.
REQ-SEC-SMO-8	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SMO-Internal-1	MS	SEC-CTL-SMO-Internal-1
REQ-SEC-SMO-Internal-2	MS	SEC-CTL-SMO-Internal-2 SEC-CTL-SMO-Internal-3
REQ-SEC-SMO-External-1	MS	SEC-CTL-SMO-External-1
REQ-SEC-SMO-External-2	MS	SEC-CTL-SMO-External-2 SEC-CTL-SMO-External-3 SEC-CTL-SMO-External-4
REQ-SEC-SMO-External-3	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SMO-Log-1	MS	SEC-CTL-SMO-Log-3 SEC-CTL-SMO-Log-4 SEC-CTL-SMO-Log-5
REQ-SEC-SMO-Log-2	M	SEC-CTL-SMO-Log-1 SEC-CTL-SMO-Log-2
REQ-SEC-SMO-Log-3	OS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SMO-Log-4	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SMO-Log-5	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SMO-Log-6	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SMO-Log-7	MS	Not defining a control, to enable the many implementations that are existing.

REQ-SEC-SMO-Log-8	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SMO-Log-9	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SMO-Log-10	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SMO-Log-11	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SMO-Log-12	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-NFO-FOCOM-1	MS	SEC-CTL-NFO-FOCOM-7 SEC-CTL-NFO-FOCOM-8
REQ-SEC-NFO-FOCOM-3	MS	SEC-CTL-NFO-FOCOM-1
REQ-SEC-NFO-FOCOM-4	MS	SEC-CTL-NFO-FOCOM-2
REQ-SEC-NFO-FOCOM-5	MS	SEC-CTL-NFO-FOCOM-3 SEC-CTL-NFO-FOCOM-4 SEC-CTL-NFO-FOCOM-5 SEC-CTL-NFO-FOCOM-6
REQ-SEC-NFO-FOCOM-6	M	Control not needed.
REQ-SEC-NFO-FOCOM-8	M	Control not needed.
REQ-SEC-SME-1	MS	SEC-CTL-SME-1
REQ-SEC-SME-2	MS	SEC-CTL-SME-1
REQ-SEC-SME-3	MS	SEC-CTL-SME-1
REQ-SEC-SME-4	MS	SEC-CTL-SME-2, SEC-CTL-SME-3
REQ-SEC-SME-5	MS	SEC-CTL-SME-2, SEC-CTL-SME-3
REQ-SEC-SME-6	MS	SEC-CTL-SME-4
REQ-SEC-SME-7	MS	None
REQ-SEC-SME-8	MS	None
REQ-SEC-SME-9	MS	SEC-CTL-NonRTRIC-6

REQ-SEC-SMOS-1	MS	SEC-CTL-SMOS-1
REQ-SEC-SMOS-2	MS	SEC-CTL-SMOS-2, SEC-CTL-SMOS-3
REQ-SEC-SMOS-3	MS	SEC-CTL-SMOS-4
REQ-SEC-SMOS-4	MS	None
REQ-SEC-SMOS-5	MS	Not defining a control, to enable the many implementations that are existing.
Non-RT RIC		
REQ-SEC-NonRTRIC-1	MS	SEC-CTL- NonRTRIC-1
REQ-SEC-NonRTRIC-2	M	SEC-CTL- NonRTRIC-1 SEC-CTL- NonRTRIC-3 SEC-CTL- NonRTRIC-6
REQ-SEC-NonRTRIC-3	M	SEC-CTL- NonRTRIC-6
REQ-SEC-NonRTRIC-4	M	Control not needed.
REQ-SEC-NonRTRIC-5	M	Control not needed.
REQ-SEC-NonRTRIC-6	M	Control not needed.
REQ-SEC-NonRTRIC-7	M	SEC-CTL- NonRTRIC-3
REQ-SEC-NonRTRIC-8	MS	SEC-CTL- NonRTRIC-4 SEC-CTL- NonRTRIC-5 SEC-CTL- NonRTRIC-6
REQ-SEC-NonRTRIC-9	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-NonRTRIC-10	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-NonRTRIC-11	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-NonRTRIC-12	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-NonRTRIC-14	MS	Not defining a control, to enable the many implementations that are existing.
Near-RT RIC		
REQ-SEC-XAPP-3	M	SEC-CTL-NEAR-RT-12 SEC-CTL-NEAR-RT-14
REQ-SEC-XAPP-4	M	SEC-CTL-NEAR-RT-13 SEC-CTL-NEAR-RT-14
REQ-SEC-NEAR-RT-1	M	SEC-CTL-NEAR-RT-1 SEC-CTL-NEAR-RT-2 SEC-CTL-NEAR-RT-20

REQ-SEC-NEAR-RT-2	M	SEC-CTL-NEAR-RT-3 SEC-CTL-NEAR-RT-20
REQ-SEC-NEAR-RT-2A	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-NEAR-RT-3	M	SEC-CTL-NEAR-RT-1 SEC-CTL-NEAR-RT-2
REQ-SEC-NEAR-RT-4	M	SEC-CTL-NEAR-RT-3 SEC-CTL-NEAR-RT-3A SEC-CTL-NEAR-RT-3B SEC-CTL-NEAR-RT-3C
REQ-SEC-NEAR-RT-5	MS	SEC-CTL-NEAR-RT-4 SEC-CTL-NEAR-RT-5
REQ-SEC-NEAR-RT-6	M	Control not needed.
REQ-SEC-NEAR-RT-7	M	SEC-CTL-NEAR-RT-8
REQ-SEC-NEAR-RT-8	M	SEC-CTL-NEAR-RT-15 SEC-CTL-NEAR-RT-16
REQ-SEC-NEAR-RT-9	M	SEC-CTL-NEAR-RT-17
REQ-SEC-NEAR-RT-10	MS	SEC-CTL-NEAR-RT-8A
REQ-SEC-NEAR-RT-11	MS	SEC-CTL-NEAR-RT-2A
REQ-SEC-NEAR-RT-12	MS	SEC-CTL-NEAR-RT-19, SEC-CTL-NEAR-RT-6, SEC-CTL-NEAR-RT-7
O-CU, O-CU, O-RU, O-eNB		
REQ-SEC-OCU-1		SEC-CTL-OCU-1
REQ-SEC-ODU-1		SEC-CTL-ODU-1
REQ-SEC-ORU-1		All security controls in clause 5.2.5
REQ-SEC-ORU-2		All security controls in clause 5.2.5
REQ-SEC-OeNB-1		SEC-CTL-OeNB-1
O-Cloud		
REQ-SEC-OCLOUD-1	M	SEC-CTL-OCLOUD-2
REQ-SEC-OCLOUD-2	M	SEC-CTL-OCLOUD-1
REQ-SEC-OCLOUD-3	M	SEC-CTL-OCLOUD-1
REQ-SEC-OCLOUD-4	MS	Not defining a control, to enable the many implementations that are existing.

REQ-SEC-OCLOUD-PKG-2	M	SEC-CTL-ALM-PKG-1 SEC-CTL-ALM-PKG-3
REQ-SEC-OCLOUD-SW-1	M	SEC-CTL-OCLOUD-SW-1
REQ-SEC-OCLOUD-ISO-1	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-ISO-3	M	SEC-CTL-O-CLOUD-ISO-3
REQ-SEC-OCLOUD-ISO-4	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-ISO-5	M	SEC-CTL-O-CLOUD-ISO-2
REQ-SEC-OCLOUD-ISO-6	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-ISO-7	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-SU-1	M	SEC-CTL-OCLOUD-SU-4
REQ-SEC-OCLOUD-SU-5	M	SEC-CTL-OCLOUD-SU-6
REQ-SEC-OCLOUD-SU-6	M	SEC-CTL-OCLOUD-SU-5
REQ-SEC-OCLOUD-SU-7	O	SEC-CTL-OCLOUD-SU-7
REQ-SEC-OCLOUD-SS-1	M	SEC-CTL-OCLOUD-SS-1 See Annex C for the guidance
REQ-SEC-OCLOUD-SS-2	MS	SEC-CTL-OCLOUD-SS-2 See Annex C for the guidance SEC-CTL-OCLOUD-SS-3 See Annex C for the guidance
REQ-SEC-OCLOUD-SS-3	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-SS-4	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-SS-5	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-SS-6	MS	SEC-CTL-OCLOUD-1 SEC-CTL-O-CLOUD-ISO-3
REQ-SEC-OCLOUD-COT-1	MS	SEC-CTL-OCLOUD-COT-1 See Annex C for the guidance SEC-CTL-OCLOUD-COT-2 See Annex C for the guidance

REQ-SEC-OCLOUD-COT-2	MS	SEC-CTL-OCLOUD-COT-3 See Annex C for the guidance
REQ-SEC-OCLOUD-COT-3	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-COT-4	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AALI-C-Mgmt-1	M	SEC-CTL-AALI-C-Mgmt-2
REQ-SEC-AALI-C-Mgmt-2	M	SEC-CTL-AALI-C-Mgmt-3
REQ-SEC-AALI-C-Mgmt-3	MS	SEC-CTL-AALI-C-Mgmt-1
REQ-SEC-AAL-VS-1	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AAL-VS-2	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AAL-VS-3	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AAL-VS-4	OS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AAL-VS-5	OS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AAL-1	MS	SEC-CTL-AAL-1
REQ-SEC-AAL-2	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AAL-3	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AAL-4	O	SEC-CTL-AAL-2
REQ-SEC-AAL-5	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AAL-6	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-O2dms-1	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-O2dms-2	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-O2dms-3	M	Not defining a control, to enable the many implementations that are existing.

REQ-SEC-OCLOUD-O2dms-4	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-O2ims-1	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-O2ims-2	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-O2ims-3	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-O2ims-4	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-O-CLOUD-NotifAPI-1	M	SEC-CTL-O-CLOUD-INTERFACE-1 SEC-CTL-O-CLOUD-INTERFACE-3
REQ-SEC-O-CLOUD-NotifAPI-2	M	SEC-CTL-O-CLOUD-INTERFACE-2
REQ-SEC-O-CLOUD-SE-1	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-O-CLOUD-SE-2	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-INST-ID-1	M	SEC-CTL-OCLOUD-INST-ID-1 SEC-CTL-OCLOUD-INST-ID-2
REQ-SEC-OCLOUD-INST-ID-2	M	SEC-CTL-O-CLOUD-ISO-3 SEC-CTL-OCLOUD-1
REQ-SEC-OCLOUD-INST-ID-3	M	SEC-CTL-OCLOUD-INST-ID-3 SEC-CTL-OCLOUD-INST-ID-4
REQ-SEC-OCLOUD-INST-ID-4	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-INST-ID-5	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-TS-1	M	SEC-CTL-SLM-ATS-1 SEC-CTL-SLM-ATS-2 SEC-CTL-SLM-ATS-3
REQ-SEC-OCLOUD-TS-2	M	SEC-CTL-OCLOUD-TS-3
REQ-SEC-OCLOUD-TS-3	M	Not defining a control, to enable the many implementations that are existing. NOTE: See Clause 5.3.8.9.2 for additional security controls.
REQ-SEC-OCLOUD-TS-4	M	Not defining a control, to enable the many implementations that are existing. NOTE: See Clause 5.3.8.9.2 for additional security controls.

REQ-SEC-OCLOUD-TS-5	M	SEC-CTL-OCLOUD-TS-3 NOTE: See Clause 5.3.8.9.2 for additional security controls.
REQ-SEC-OCLOUD-SECPOL-1	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-SECPOL-2	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-SECPOL-3	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-SECPOL-4	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-SECPOL-5	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-SECPOL-6	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-SECPOL-7	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OCLOUD-SECPOL-8	O	Not defining a control, to enable the many implementations that are existing.
Shared O-RU		
REQ-SEC-SharedORU-1	M	SEC-CTL-SharedORU-1 SEC-CTL-SharedORU-2
REQ-SEC-SharedORU-2	M	SEC-CTL-SharedORU-3
REQ-SEC-SharedORU-3	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SharedORU-4	M	SEC-CTL-SharedORU-4
REQ-SEC-SharedORU-7	M	SEC-CTL-DOS-1 (DDoS)
REQ-SEC-SharedORU-8	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SharedORU-9	OS	SEC-CTL-SharedORU-5
A1 Interface		
REQ-SEC-A1-1	MS	SEC-CTL-A1-1
REQ-SEC-A1-2	MS	SEC-CTL-A1-2 SEC-CTL-A1-3
REQ-SEC-A1-3	MS	Not defining a control, to enable the many implementations that are existing.
O1 interface		

REQ-SEC-O1-1	MS	SEC-CTL-O1-1 SEC-CTL-O1-4
REQ-SEC-O1-2	MS	SEC-CTL-O1-2 SEC-CTL-O1-5
REQ-SEC-O1-3	MS	SEC-CTL-O1-3
REQ-SEC-O1-4	MS	SEC-CTL-O1-6 SEC-CTL-O1-7 SEC-CTL-O1-8 SEC-CTL-O1-9
REQ-NAC-FUN-1	MS	Not defining a control, to enable the many implementations that are existing.
REQ-NAC-FUN-2	M	Not defining a control, to enable the many implementations that are existing.
REQ-NAC-FUN-3	MS	Not defining a control, to enable the many implementations that are existing.
REQ-NAC-FUN-4	M	Not defining a control, to enable the many implementations that are existing.
REQ-NAC-FUN-5	M	Not defining a control, to enable the many implementations that are existing.
REQ-NAC-FUN-6	M	Not defining a control, to enable the many implementations that are existing.
REQ-NAC-FUN-7	M	Not defining a control, to enable the many implementations that are existing.
REQ-NAC-FUN-8	M	Not defining a control, to enable the many implementations that are existing.
REQ-NAC-FUN-9	MS	Not defining a control, to enable the many implementations that are existing.
REQ-NAC-FUN-10	O (may)	Not defining a control, to enable the many implementations that are existing.
REQ-NAC-FUN-11	O (may)	Not defining a control, to enable the many implementations that are existing.
O2 interface		
REQ-SEC-O2-1	MS	SEC-CTL-O2-1
REQ-SEC-O2-2	MS	SEC-CTL-O2-2
REQ-SEC-O2-3	MS	SEC-CTL-O2-3
E2 interface		
REQ-SEC-E2-1	MS	SEC-CTL-E2-1
Open Fronthaul Interface		
REQ-SEC-OFCP-1	MS	Clause 5.2.5.5 Open Fronthaul Point-to-Point LAN Segment
REQ-SEC-OFCP-2	M	Clause 5.2.5.5 Open Fronthaul Point-to-Point LAN Segment

REQ-SEC-OFCP-3	O	SEC-CTL-OFCP-1
REQ-SEC-OFCP-4	O	SEC-CTL-OFCP-1
REQ-SEC-OFUP-1	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OFUP-2	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OFUP-3	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OFUP-4	OS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OFSP-1	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OFSP-2	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OFSP-3	O	SEC-CTL-OFSP-1 SEC-CTL-OFSP-2 O-RAN Synchronization Architecture and Solution Specification [30] Clause 8.2.3 Timing/Synchronization Redundancy & Resiliency provides additional details on redundancy for the Open Fronthaul Synchronization architecture.
REQ-SEC-OFSP-4	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OFSP-5	OS	SEC-CTL-OFSP-3
REQ-SEC-OFSP-6	OS	SEC-CTL-OFSP-3
REQ-SEC-OFSP-7	OS	SEC-CTL-OFSP-3
REQ-SEC-OFSP-8	OS	SEC-CTL-OFSP-4
REQ-SEC-OFHPLS-1	MS	SEC-CTL-OFHPLS-2 SEC-CTL-OFHPLS-3 SEC-CTL-OFHPLS-4 SEC-CTL-OFHPLS-5 SEC-CTL-OFHPLS-6 SEC-CTL-OFHPLS-7 SEC-CTL-OFHPLS-8
REQ-SEC-OFHPLS-2	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-OFHPLS-3	MS	SEC-CTL-OFHPLS-9 SEC-CTL-OFHPLS-10 SEC-CTL-OFHPLS-11 SEC-CTL-OFHPLS-12
R1 interface		
REQ-SEC-R1-1	MS	SEC-CTL-R1-1

REQ-SEC-R1-2	MS	SEC-CTL-R1-2 SEC-CTL-R1-3
REQ-SEC-R1-3	MS	Not defining a control, to enable the many implementations that are existing.
Y1 interface		
REQ-SEC-Y1-1	MS	SEC-CTL-NEAR-RT-9 SEC-CTL-Y1-1
REQ-SEC-Y1-2	M	SEC-CTL-NEAR-RT-10 SEC-CTL-Y1-2
REQ-SEC-Y1-3	MS	SEC-CTL-NEAR-RT-11 SEC-CTL-Y1-3
REQ-SEC-Y1-4	M	SEC-CTL-NEAR-RT-11 SEC-CTL-Y1-3
REQ-SEC-Y1-5	M	SEC-CTL-NEAR-RT-11 SEC-CTL-Y1-3
REQ-SEC-Y1-6	M	SEC-CTL-NEAR-RT-11 (partly)
Common Application Lifecycle Management		
REQ-SEC-ALM-PKG-1	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-PKG-2	M	SEC-CTL-ALM-PKG-1 SEC-CTL-ALM-PKG-1A
REQ-SEC-ALM-PKG-2A	O	SEC-CTL-ALM-PKG-2 SEC-CTL-ALM-PKG-2A
REQ-SEC-ALM-PKG-3	M	SEC-CTL-ALM-PKG-3
REQ-SEC-ALM-PKG-4	M	SEC-CTL-ALM-PKG-1 SEC-CTL-ALM-PKG-1A
REQ-SEC-ALM-PKG-5	M	SEC-CTL-ALM-PKG-1
REQ-SEC-ALM-PKG-6	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-PKG-7a	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-PKG-7b	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-PKG-7c	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-PKG-8	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-PKG-9	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-PKG-10	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-PKG-11	M	Not defining a control, to enable the many implementations that are existing.

REQ-SEC-ALM-PKG-12	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-PKG-13	M	SEC-CTL-ALM-PKG-2 SEC-CTL-ALM-PKG-2A SEC-CTL-ALM-PKG-4
REQ-SEC-ALM-PKG-14	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-PKG-15	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-PKG-16	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-SU-1	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-SU-2	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-SU-3	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-SU-4	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-LCM-SD-1	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-LCM-SD-2	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-LCM-SD-3	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-LCM-SD-4	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-LCM-SD-5	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-LCM-SD-6	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-LCM-SD-7	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-ALM-DECOM-1	M	Control not needed.
REQ-SEC-ALM-DECOM-2	O	Control not needed.
REQ-SEC-ALM-DECOM-3	M	Control not needed.
Network Protocols and Services		
REQ-SEC-NET-1	M	Not defining a control, to enable the many implementations that are existing.
Robustness of Common Transport Protocols		
REQ-SEC-TRAN-1	O	Not defining a control, to enable the many implementations that are existing.
Robustness against Volumetric DDoS Attack		

REQ-SEC-DOS-1	M	Control not needed.
Robustness of OS and Applications		
REQ-SEC-SYS-1	M	Not defining a control, to enable the many implementations that are existing.
Password-Based Authentication		
REQ-SEC-PASS-1	O	SEC-CTL-PASS-1 SEC-CTL-PASS-2 SEC-CTL-PASS-3
Security Log Management		
REQ-SEC-SLM-1	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-TESS-1 to 13	1 to 9: M 10 to 11: MS 12: M 13: MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-TESM-1 to 5	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-TESR-1 to 11	1 to 6: M 7 to 8: MS 9 to 11: M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-SST-1	M	SEC-CTL-SLM-SST-1
REQ-SEC-SLM-SST-2	M	SEC-CTL-SLM-SST-2
REQ-SEC-SLM-SST-3	M	SEC-CTL-SLM-SST-3
REQ-SEC-SLM-SST-4 to 8	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-STR-1 to 5	1 to 4: M 5: OS	SEC-CTL-SLM-STR-1 SEC-CTL-SLM-STR-2
REQ-SEC-SLM-FMT-1	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-FLD-1	M	SEC-CTL-SLM-FLD-1
REQ-SEC-SLM-FLD-2	M	SEC-CTL-SLM-FLD-2
REQ-SEC-SLM-FLD-3	M	SEC-CTL-SLM-FLD-2
REQ-SEC-SLM-ATS-1	M	SEC-CTL-SLM-ATS-1 SEC-CTL-SLM-ATS-2 SEC-CTL-SLM-ATS-3

REQ-SEC-SLM-ATS-2 to 4	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-ATS-5	M	SEC-CTL-SLM-CTS-1
REQ-SEC-SLM-DDA-1	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-DDA-2	O	SEC-CTL-SLM-DDA-1
REQ-SEC-SLM-DDA-3 to 6	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-DDA-7	O	SEC-CTL-SLM-DDA-2
REQ-SEC-SLM-DDA-8	O	SEC-CTL-SLM-DDA-3
REQ-SEC-SLM-DDA-9 to 11	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-NET-EVT-1	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-GEN-EVT-1	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-GEN-EVT-2	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-GEN-EVT-3	M	SEC-CTL-SLM-GEN-EVT-6 SEC-CTL-SLM-GEN-EVT-7
REQ-SEC-SLM-GEN-EVT-4	M	SEC-CTL-SLM-GEN-EVT-1 SEC-CTL-SLM-GEN-EVT-2
REQ-SEC-SLM-GEN-EVT-5	M	SEC-CTL-SLM-GEN-EVT-4 SEC-CTL-SLM-GEN-EVT-5
REQ-SEC-SLM-GEN-EVT-6	M	SEC-CTL-SLM-GEN-EVT-6 SEC-CTL-SLM-GEN-EVT-7
REQ-SEC-SLM-HYP-EVT-1 to 3	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-CON-EVT-1 to 3	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-APP-EVT-1 to 2	M	Not defining a control, to enable the many implementations that are existing.

REQ-SEC-SLM-DAT-EVT-1 to 8	1: M 2: O 3 to 5: M 6: O 7 to 8: M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-AAI-EVT-1 to 10	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-GSE-1 to 6	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-LCSS-2 to 5	2 to 3: MS 4: M 5: MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-POL-5 to 10	5 to 8: M 9: MS 10: M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-DoS-1 to 7	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-SLM-TLD-1 to 4	OS	Not defining a control, to enable the many implementations that are existing.
Certificate Management Framework		
REQ-SEC-CMF-PNF-1	MS	SEC-CTL-CMF-PNF-1
REQ-SEC-CMF-PNF-2	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-PNF-3	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-PNF-4	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-PNF-5	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-PNF-6	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-VNF_CNF-1	MS	SEC-CTL-CMF-VNF_CNF-1
REQ-SEC-CMF-VNF_CNF-2	MS	SEC-CTL-CMF-VNF_CNF-2
REQ-SEC-CMF-VNF_CNF-3	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-ANYNF-1	M	Not defining a control, to enable the many implementations that are existing.

REQ-SEC-CMF-ANYNF-2	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-ANYNF-3	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-ANYNF-4	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-ANYNF-5	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-ANYNF-6	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-ANYNF-7	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-ANYNF-8	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-ANYNF-9	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-ANYNF-10	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-ANYNF-11	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-ANYNF-12	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-CMF-ANYNF-13	O	Not defining a control, to enable the many implementations that are existing.
Application Programming Interfaces (APIs)		
REQ-SEC-API-1	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-API-2	MS	SEC-CTL-API-01
REQ-SEC-API-3	OS	SEC-CTL-API-02
REQ-SEC-API-4	O	SEC-CTL-API-03
REQ-SEC-API-5	M	SEC-CTL-API-04
REQ-SEC-API-6	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-API-7	M	SEC-CTL-API-05
REQ-SEC-API-8	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-API-9	M	Not defining a control, to enable the many implementations that are existing.

REQ-SEC-API-10	MS	SEC-CTL-API-02 SEC-CTL-API-03 SEC-CTL-API-04
REQ-SEC-API-11	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-API-12	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-API-13	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-API-14	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-API-15	M	Not defining a control, to enable the many implementations that are existing.
Trust Anchor Provisioning		
REQ-SEC-TAP-1	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-TAP-1a	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-TAP-2	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-TAP-3	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-TAP-4	MS	SEC-CTL-TAP-1 SEC-CTL-TAP-2 SEC-CTL-TAP-3 SEC-CTL-TAP-4 SEC-CTL-TAP-5
REQ-SEC-TAP-5	M	Not defining a control, to enable the many implementations that are existing.
AI/ML Security		
REQ-SEC-AIML-1	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-2	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-3	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-4	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-5	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-6	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-7	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-8	O	Not defining a control, to enable the many implementations that are existing.

REQ-SEC-AIML-9	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-10	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-11	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-12	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-13	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-14	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-15	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-16	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-17	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-18	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-19	OS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-20	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-21	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-22	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-23	OS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-24	OS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-25	OS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-26	OS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-27	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-28	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-29	OS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-30	M	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-31	MS	Not defining a control, to enable the many implementations that are existing.

REQ-SEC-AIML-32	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-33	O	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-34	MS	Not defining a control, to enable the many implementations that are existing.
REQ-SEC-AIML-35	OS	Not defining a control, to enable the many implementations that are existing.
SBOM		
REQ-SBOM-001	M	Control not needed.
REQ-SBOM-002	M	Control not needed.
REQ-SBOM-003	M	Control not needed.
REQ-SBOM-004	M	Control not needed.
REQ-SBOM-007	M	SEC-CTL-SBOM-001
REQ-SBOM-011	M	Control not needed.

Annex E (informative): Summary of O-RAN Security Controls

Table E-1. Summary of O-RAN Security Controls

Clauses [in this document]	Security Principle ->	Confidentiality	Integrity	Availability	Authentication	Authorization	Additional security requirements
5	Security Requirements						
5.1	Architectural Elements						
5.1.1	SMO	TLS 1.2 and 1.3	TLS 1.2 and 1.3	Withstand and recover without system crash	mTLS 1.2 and 1.3, with X.509 certificates or PSK	OAuth 2.0	Secure logging and Security event logs
5.1.2	Non-RT RIC and rApps	TLS 1.2 and 1.3	TLS 1.2 and 1.3	Withstand and recover without system crash	mTLS 1.2 and 1.3, with X.509 certificates or PSK	OAuth 2.0	Secure logging and Security event logs
5.1.3	Near-RT RIC and xApps	TLS 1.2 and 1.3, IPsec	TLS 1.2 and 1.3, IPsec	Withstand and recover without system crash	mTLS 1.2 and 1.3, IPsec	OAuth 2.0, IPsec	
5.1.4	O-CU-CP/UP**	IPsec or DTLS on F1 interface as specified in 3GPP TS 33.501	IPsec or DTLS on F1 interface as specified in 3GPP TS 33.501	Withstand and recover without system crash	3GPP TS 33.501 (5.3.4) for mutual authentication with OAM	3GPP TS 33.501 (5.3.4) for authorization with OAM	Secure logging and Security event logs
5.1.5	O-DU**	IPsec or DTLS on F1 interface as specified in 3GPP TS 33.501	IPsec or DTLS on F1 interface as specified in 3GPP TS 33.501	Withstand and recover without system crash	3GPP TS 33.501 (5.3.4) for mutual authentication with OAM	3GPP TS 33.501 (5.3.4) for authorization with OAM	Secure logging and Security event logs
5.1.6	O-RU***	3GPP TS 33.501	3GPP TS 33.501	Withstand and recover without system crash	3GPP TS 33.501 (5.3.4) for mutual authentication with OAM	3GPP TS 33.501 (5.3.4) for authorization with OAM	Secure logging and Security event logs
5.1.7	O-eNB	3GPP TS 33.401	3GPP TS 33.401		3GPP TS 33.401		

5.1.8	O-Cloud	TLS 1.2 and 1.3	TLS 1.2 and 1.3, Digital signature verification	Withstand and recover without system crash	MFA, mTLS 1.2 and 1.3	RBAC, Principle of Least Privilege	Hardware root of trust, Secure boot/Secure runtime, Secure logging and Security event logs
5.1.9	Shared O-RU	TLS 1.2 and 1.3	TLS 1.2 and 1.3		mTLS 1.2 and 1.3	NACM with NETCONF	
5.2	Interfaces						
5.2.1	A1	TLS 1.2 and 1.3	TLS 1.2 and 1.3		mTLS 1.2 and 1.3	OAuth 2.0	
5.2.2	O1	TLS 1.2 and 1.3	TLS 1.2 and 1.3		mTLS 1.2 and 1.3	NACM with NETCONF	
5.2.3	O2	TLS 1.2 and 1.3	TLS 1.2 and 1.3		mTLS 1.2 and 1.3	OAuth 2.0	
5.2.4	E2	IPsec	IPsec		IPsec	IPsec	
5.2.5	Open Fronthaul	Open Fronthaul CUS-Plane and M-Plane have varying security requirements, as shown below					
5.2.5.1	C-Plane	MACsec	MACsec		IEEE 802.1X	IEEE 802.1X	
5.2.5.2	U-Plane	PDCP*, MACsec	PDCP*, MACsec		IEEE 802.1X	IEEE 802.1X	
5.2.5.3	S-Plane				IEEE 802.1X	IEEE 802.1X	
5.2.5.4	M-Plane	TLS 1.2 and 1.3, or SSHv2	TLS 1.2 and 1.3, or SSHv2		IEEE 802.1X, mTLS 1.2 and 1.3 with PKI X.509 certificates or SSHv2 with Password	IEEE 802.1X, NACM with NETCONF	
5.2.5.5	Open Fronthaul Point-to-Point LAN Segment				IEEE 802.1X	IEEE 802.1X	
5.2.6	R1	TLS 1.2 and 1.3	TLS 1.2 and 1.3		mTLS 1.2 and 1.3	OAuth 2.0	
5.2.7	Y1	TLS 1.2 and 1.3	TLS 1.2 and 1.3		mTLS 1.2 and 1.3	OAuth 2.0	
5.3	Additional Requirements						

5.3.2	App LCM		ETSI GS NFV-SEC 021 and ETSI GS NFV-SOL004		ETSI GS NFV-SEC 021 and ETSI GS NFV-SOL004		
5.3.3	Network Protocols and Services						Unused protocols are disabled
5.3.4	Robustness of Transport Protocols						Handle unexpected inputs
5.3.5	Robustness against Volumetric DDoS			Withstand and recover without system crash			
5.3.6	Robustness of OS and Applications						Identify known vulnerabilities
5.3.7	Password-based Authentication						Password hygiene
5.3.8	Security Log Management						Accountability
5.3.9	Certificate Management Framework						CMPv2, PKI
5.3.10	API Security	TLS 1.2 and 1.3	TLS 1.2 and 1.3		mTLS 1.2 and 1.3	OAuth 2.0	OWASP best practices
5.3.11	Trust Anchor (TA) Provisioning						CMPv2, 3GPP SCS, Security event logs
6.3	SBOM Requirements for O-RAN						US NTIA [17]

*The Packet Data Convergence Protocol (PDCP) provides confidentiality and integrity protection of 5G System Control Plane and User Plane between O-CU-CP and UE.

** Security requirements and controls specified in 3GPP TS 33.501 are partially represented in this table for O-CU and O-DU.

*** 3GPP TS 33.501 specifies security requirements without controls.

Annex F (informative): Change history

Date	Revision	Description
2025.07.09	13.00	AKALAYA: Correct HTTP2 Abbreviation
2025.07.09	13.00	ATT.AO: SmoDataAtRestEncryption
2025.07.09	13.00	ATT.AO: Add M-Plane NACM Requirements to SRCS
2025.07.09	13.00	ATT.AO: rApp Encryption of Data at Rest
2025.07.03	13.00	DTAG: Adding explanatory text in the References as per the TS template
2025.07.09	13.00	Ericsson: Mapping for M-Plane Requirements to Threats
2025.07.09	13.00	Ericsson: Application descriptor definition
2025.07.09	13.00	Ericsson: SMO External Systems
2025.07.03	13.00	Ericsson: CR to Annex D.1 OAuth Threats to Requirements Mapping in SRS
2025.07.03	13.00	Ericsson: SMO Requirements to Threats Mapping
2025.07.03	13.00	Ericsson.AO: Add DME Security Requirements and Controls
2025.07.09	13.00	Ericsson.AO: M-Plane security requirements and controls
2025.07.09	13.00	Ericsson.AO: Security Terms for O-Cloud
2025.07.04	13.00	MITRE.AO: Addition of WG10 application terms
2025.07.04	13.00	NEC.AO: Security requirements for Secure Multi-party Computation to AI/ML Models
2025.07.04	13.00	NEC.AO: Security requirements for Obfuscation to AI/ML Models
2025.07.04	13.00	NEC.AO: Update to Security Requirements and Security Controls mapping related to AI/ML
2025.07.09	13.00	Nokia: Security requirements for AIML Multi-Tenancy
2025.07.09	13.00	Nokia: SRCS note on IPsec-based authorization
2025.07.03	13.00	Nokia: Security requirements for AIML model signing
2025.07.03	13.00	Nokia: Adding Certificate Management framework related requirements for O-Cloud
2025.07.03	13.00	Nokia: Security requirements for AIML model watermarking
2025.05.26	13.00	Nokia: Security requirements for Near-RT RIC and xApps confidentiality
2025.05.26	13.00	Nokia: Security requirements for Near-RT RIC sensitive data access
2025.07.03	13.00	Nokia.AO: Security requirements for MACsec with PSK
2025.07.09	13.00	Rakuten Mobile: Adding O-Cloud Instance ID security requirement for least privilege access
2025.06.27	13.00	Rakuten Mobile: Update to REQ-SEC-OCLOUD-SU-1 and REQ-SEC-OCLOUD-SU-5
2025.06.27	13.00	Rakuten Mobile:Update to REQ-SEC-OCLOUD-SW-1
2025.07.03	13.00	Rakuten Symphony.AO: Security requirement for MACsec Key Management using MKA
2025.03.19	12.00	ATT.AO: Add eCPRI to REQ-SEC-TRAN-1
2025.03.19	12.00	DTAG: Additional rewording of O2ims/dms interface mentions to clearly state O2 interface
2025.03.19	12.00	Ericsson: Add SME Security Requirements and Controls
2025.03.19	12.00	Ericsson: Add SMOS Security Requirements for SMO
2025.03.19	12.00	Ericsson: Adding Security Requirements for OAuth2.0 based on discussion and agreed in OAuth 2.0 WI
2025.03.19	12.00	Ericsson: Resolution for ETSI comments BI #16
2025.03.19	12.00	Ericsson: Resolution for ETSI comments BI #4, BI #6, BSI #7, BSI #12, and BSI #17
2025.03.19	12.00	Ericsson: Resolution for ETSI comments BSI #2, #4, and #5
2025.03.19	12.00	Ericsson: Resolution for ETSI comments Huawei #35
2025.03.19	12.00	Ericsson: Resolution for ETSI comments BSI #56, 57, and 58
2025.03.19	12.00	Ericsson: Resolution for ETSI comments BSI #33
2025.03.19	12.00	Ericsson: The proposed CR is to update the text in clause 3.1 Terms related for O1 term
2025.03.19	12.00	Ericsson: Resolution for ETSI comments Huawei #27 and #28
2025.03.19	12.00	Ericsson: Updates to Mapping Table D.2 in Appendix D
2025.03.19	12.00	Ericsson: Resolution for ETSI MSG comments BSI #4
2025.03.19	12.00	Ericsson: Updating the REQ-SECs to CTL-SECs mapping
2025.03.19	12.00	Ericsson.AO: SRCS Clarifications on 802.1AE
2025.03.19	12.00	Ericsson.AO: Update O1 Security Requirements
2025.03.19	12.00	Ericsson.AO: Clarifications on the use of EDE-CC
2025.03.19	12.00	Ericsson.AO: Resolution for ETSI comments Huawei #36 and #37

2025.03.19	12.00	Ericsson.AO: Update to SRCS for ETSI comments Huawei #13 and #14
2025.03.19	12.00	Ericsson.AO: Update to SRCS scope to align with WG11 mission as communicated to ETSI
2025.03.19	12.00	Ericsson: Resolution for ETSI comments BSI #43, 48, 49, and 51
2025.03.19	12.00	Ericsson: Resolution for ETSI editorial comments Huawei
2025.03.19	12.00	Ericsson: Resolution for ETSI comments BSI #19, 23, 24, and 25
2025.03.19	12.00	Ericsson: Resolution for ETSI comments BI #7
2025.03.19	12.00	Ericsson: Resolution for ETSI comments BI #19 and Huawei #34
2025.03.19	12.00	Ericsson: Resolution for ETSI comments BI #20
2025.03.19	12.00	Ericsson: Resolution for ETSI comments BI #5, BSI #14, and Huawei #8
2025.03.19	12.00	MTR.AO: Update of App LCM requirements in response to ETSI comments Huawei #16, 17, 21, 22, 23, 24
2025.03.19	12.00	NEC.AO: Security requirements for Model Distillation to AI/ML models
2025.03.19	12.00	NEC.AO: Security requirements for Agility to AI/ML models by retraining
2025.03.19	12.00	NEC.AO: Security requirements for Ensemble Methods for AI/ML models
2025.03.19	12.00	NEC.AO: Security requirements related to Data augmentation for AI/ML Models
2025.03.19	12.00	NEC.AO: Security requirements for Explainable AI Techniques applied to AI/ML models
2025.03.19	12.00	NIST.AO: IETF RFC reference update for UUID ver 4
2025.03.19	12.00	NOKIA: Note on solution 1
2025.03.19	12.00	NOKIA: Security requirements for near RT RIC databases confidentiality
2025.03.19	12.00	NOKIA: Security requirements for AIML Energy and Latency Obfuscation
2025.03.19	12.00	NOKIA: Security requirements for robust AIML models
2025.03.19	12.00	NOKIA: Update of the c-plane related authentication requirements
		NOKIA: SRCS note on IEs for the xApp CSR
2025.03.19	12.00	Rakuten Mobile: Security requirements for secure AI/ML models
2025.03.19	12.00	Rakuten Mobile: Requirement addition : New requirement for authentication and authorization for sensitive data modification/deletion
2025.03.19	12.00	Rakuten Mobile.AO: Update of O-Cloud requirements and controls in response to ETSI feedback
2025.03.19	12.00	RakutenMobile.AO: Update to SEC-CTL-OCLOUD-INST-ID-1 to reference O-RAN Security Protocol Specifications in response to ETSI comment
2025.03.19	12.00	Rakuten Symphony: Update the U-Plane authentication and authorization requirements by changing 'should' to 'shall,' ensuring alignment with the C-Plane requirements.
2025.03.19	12.00	Rakuten Symphony: ETSI recommended corrections for SRCS References
2025.03.19	12.00	Rakuten Symphony: Shared O-RU Requirements to support MACsec.
2024.11.27	11.00	Accenture.AO: Editorial modification of requirement to mitigate exploitability
2024.11.27	11.00	AT&T: PKIX Abbreviation
2024.11.27	11.00	AT&T.AO: SBOM Updates to Security Requirements and Controls Specifications
2024.11.27	11.00	DTAG: Changing reference to TR to be an informative reference
2024.11.27	11.00	DTAG: Rewording of O2ims/dms interface mentions to clearly state O2 interface
2024.11.27	11.00	Ericsson.AO: Access to O-Cloud Platform
2024.11.27	11.00	Ericsson.AO: MACsec for S-plane
2024.11.27	11.00	Ericsson.AO: Reformulation of App package validation procedure
2024.11.27	11.00	Ericsson.AO: Update O1 Security Requirements
2024.11.27	11.00	Ericsson.AO: Authorization with the Principle of Least Privilege
2024.11.27	11.00	Ericsson.AO: Summary of Security Controls
2024.11.27	11.00	Ericsson.AO: Correct TLS/mTLS controls specifications
2024.11.27	11.00	Ericsson.AO: Architecture Elements
2024.11.27	11.00	Ericsson.AO: Update O2 Security Requirements
2024.11.27	11.00	Ericsson.AO: Security Requirements for O-Cloud Platform
2024.11.27	11.00	Ericsson: Security requirements for Certificate enrolment for new NF Deployment using CMPv2
2024.11.27	11.00	Ericsson: To propose the security procedure for SEC-CTL-CMF-VNF_CNF-1 in C.3.1 Certificate enrolment for new NF Deployment based on E/// CR 139 security requirement(REQ-SEC-CMF-VNF_CNF-3)
2024.11.27	11.00	Ericsson: Proposing additional text for API in clause 5.3.10
2024.11.27	11.00	Ericsson: SRCS Security Terms
2024.11.27	11.00	Keysight: Correction in the DoS Control

2024.11.27	11.00	Keysight.AO: New informative Annex to map security requirements and controls
2024.11.27	11.00	MITRE.AO: Update ETSI NFV App Pkg security control
2024.11.27	11.00	NEC: Security requirements for sanitization of AI/ML Model data
2024.11.27	11.00	NEC: Security requirements for feature selection training of AI/ML Model
2024.11.27	11.00	NEC: Security requirements for the transformation of AIML Model input data
2024.11.27	11.00	NEC: Security requirements for adversarial training of AI/ML Model
2024.11.27	11.00	NEC.AO: Security requirements for AI model poisoning control
2024.11.27	11.00	NOKIA: MACsec ciphers conditional
2024.11.27	11.00	NOKIA: Security requirements for AI data security
2024.11.27	11.00	NOKIA: Security requirements for AI Differential Privacy
2024.11.27	11.00	NOKIA: Security requirements for AI model protection
2024.11.27	11.00	NOKIA: Security requirements for AI model integrity and confidentiality
2024.11.27	11.00	NOKIA: Security requirements for AI Model Splitting
2024.11.27	11.00	NOKIA: Security requirements for notifications and/or alarms for certificate storage exhaustion.
2024.11.27	11.00	NOKIA: Y1security controls completion
2024.11.27	11.00	NOKIA: Near-RT RIC: A1 security requirements completion
2024.11.27	11.00	NOKIA: Security requirements for monitoring the expiry of vendor-signed certificates for PNFs
2024.11.27	11.00	NOKIA: Security requirements for notifications and/or alarms related to CRL failures
2024.11.27	11.00	Red Hat: Modifications of O-Cloud certificate management requirements
2024.11.27	11.00	Red Hat.AO: Removal of O-Cloud certificate management control for VNFs/CNFs certificates in a VNFs/CNFs section
2024.11.27	11.00	Rakuten Mobile.AO: Usage of Operator CA for issuing certificates for O-Cloud O2 interface
2024.11.27	11.00	Rakuten Mobile.AO: Security control: O-Cloud platform support for encryption
2024.11.27	11.00	WG11.AO: Update on the O-Cloud signature verification to align with the App LCM requirements
2024.11.27	11.00	WG11.AO: Addition of U-Plane authentication and authorization requirements, along with the corresponding 802.1X control, aligned with the C-Plane
2024.11.27	11.00	WG11.AO: Update to security requirements 5 to 7 on the security descriptor: NFO responsibility for Application descriptor and resource monitoring
2024.11.27	11.00	WG11.AO: Addition of requirements and controls for the enforcement of security policies by the O-Cloud
2024.11.27	11.00	WG11.AO: Addition of a new security requirement and associated control to enhance protection against side-channel attacks on O-Cloud secure environment.
2024.07.14	10.00	Accenture.AO: Separation of non-atomic requirements
2024.07.14	10.00	Accenture.AO: Editorial Changes and corrections conform to O-RAN Rules
2024.07.14	10.00	Ericsson.AO: Making LDAP the preferred protocol for centralized user management
2024.07.14	10.00	Ericsson.AO: Update Shared O-RU Security Requirements
2024.07.14	10.00	Ericsson: Security requirements for improving least privilege of O1 NACM
2024.07.14	10.00	Ericsson: Clarification of using micro perimeter terminology
2024.07.14	10.00	NIST.AO: Splitting Compound O-RAN Requirements
2024.07.14	10.00	Rakuten Mobile.AO: Adding security control for Near-RT RIC for validation of data received from an xApp through E2 related APIs
2024.07.14	10.00	Rakuten Symphony.AO: End-to End MACsec as a security control to protect C-Plane messages
2024.07.14	10.00	Rakuten Symphony.AO: IEEE 1588 Authentication TLV for securing S-Plane ANNOUNCE messages.
2024.07.14	10.00	Rakuten Symphony.AO: End-to End MACsec as a security control to protect U-Plane messages
2024.07.14	10.00	Rakuten Symphony: Consistency of Security Control for Non RT-RIC based on the security control defined for R1
2024.07.14	10.00	WG11.AO: Addition of the mapping Threats-Requirements
2024.07.14	10.00	WG11.AO: Addition of sensitive definition
2024.03.20	09.00	AT&T.AO: Correct usages of "Must"
2024.03.20	09.00	Ericsson: Update NFO and FOCOM security requirements and controls
2024.03.20	09.00	Ericsson: Add Shared O-RU Security Requirements

2024.03.20	09.00	Keysight.AO: Added unexpected input management requirements for S-Plane and C-Plane
2024.03.20	09.00	MITRE: Resolve duplicate requirement reference IDs in SLM section
2024.03.20	09.00	MITRE: SRS Typos in SLM Reqs
2024.03.20	09.00	NEC.AO: Removal of Requirement REQ-SEC-DEL-1, REQ-CTL-DEL-1, REQ-CTL-DEL-2
2024.03.20	09.00	NOKIA.AO: Security requirements for PSK/Refnum based certificate enrolment
2024.03.20	09.00	NOKIA.AO: Security requirements for vendor root CA certificate renewal for PNFs
2024.03.20	09.00	NOKIA.AO: Security requirements for Certificate Renewal procedure for PNFs, CNFs and VNFs
2024.03.20	09.00	NOKIA.AO: Security requirements for vendor certificate based certificate initial enrolment for PNFs
2024.03.20	09.00	Rakuten Symphony: Correction to 802.1X security control clause
2024.03.20	09.00	WG11.AO: New requirement for the support of CMPv2 by VNF/CNF
2024.03.20	09.00	WG11.AO: Update of O-Cloud controls on secure storage
2024.03.20	09.00	WG11: New requirements focusing on O-Cloud SW images verification, vulnerability scanning and secure update
2023.11.06	08.00	Ericsson: Update the outdated reference of 3GPP references in Clause 2 and Annex B
2023.11.06	08.00	Ericsson: Editorial update in Clause 5.1.2.2 Security Controls
2023.11.06	08.00	Ericsson: Proposed changes in Clause 5.3.2 Common Application Lifecycle Management
2023.11.06	08.00	MITRE: New requirements on rAppIDs
2023.11.06	08.00	MITRE: New requirement on App decommissioning
2023.11.06	08.00	MITRE: Duplicate Account and Identity Security Event Log Requirement.
2023.11.06	08.00	NIST: SecRecSpec–O1-Interface-Modification
2023.11.06	08.00	NOKIA.AO: Near-RT RIC Secure mechanisms for Y1 interface
2023.11.06	08.00	NOKIA: Security requirements and controls for xApp registration procedure
2023.11.06	08.00	NOKIA: Security requirements for preventing tampering of log data
2023.11.06	08.00	NOKIA: security requirements for prevention of (D)DoS to Security Log Data management
2023.11.06	08.00	NOKIA: Security requirements for prevention of (D)DoS to Security Log Data management
2023.11.06	08.00	NOKIA: Security Log data one-way access
2023.11.06	08.00	NOKIA: Near-RT RIC Secure mechanisms for E2 interface
2023.11.06	08.00	Rakuten Symphony: New security requirements and controls for NFO/FOCOM
2023.11.06	08.00	Rakuten Symphony: New security controls for DoS / DDoS mitigation requirement REQ-SEC-DOS-1
2023.11.06	08.00	Rakuten Symphony: New security control covering REQ-SEC-AAL-4
2023.11.06	08.00	Rakuten Symphony: New Security Control for User Management Requirements for Cloud Platform Management
2023.11.06	08.00	WG11: New requirements on O-Cloud logging
2023.11.06	08.00	WG11: New requirements on O-Cloud instance ID
2023.11.06	08.00	WG11: New requirements on O-Cloud Time Synchronization
2023.07.12	07.00	AT&T.AO: Security Requirements specifications CMPv2
2023.07.12	07.00	AT&T.AO: Security Requirements specifications TA Provisioning
2023.07.12	07.00	Ericsson.AO: API Security Requirements
2023.07.12	07.00	Ericsson.AO: Update to informative SBOM statements
2023.07.12	07.00	Ericsson.AO: Revise Password requirements clause
2023.07.12	07.00	Ericsson: Shared O-RU Security Requirements and Security Controls
2023.07.12	07.00	Ericsson: Kafka Security Requirements
2023.07.12	07.00	Fujitsu.AO: Update Security requirements documents with secure deletion
2023.07.12	07.00	Fujitsu: Update Security requirements documents with secure decommissioning
2023.07.12	07.00	MITRE.AO: Common application package requirements
2023.07.12	07.00	MITRE: Security Log Management requirement for a standard security log format and security related log fields
2023.07.12	07.00	MITRE: Common application package security controls
2023.07.12	07.00	MITRE: Common application terminology
2023.07.12	07.00	MITRE: Security related activities and events to be logged

2023.07.12	07.00	MITRE: PART 2: Security related activities and events to be logged
2023.07.12	07.00	NOKIA: First security log management related requirements
2023.07.12	07.00	NOKIA: Near-RT RIC Secure mechanisms for A1 interface
2023.07.12	07.00	NOKIA: Security requirements for the Y1 interface
2023.07.12	07.00	NOKIA: Security requirements for storage and transfer of logs
2023.07.12	07.00	NOKIA: Security requirements on Trusted Environment for Cluster Node
2023.07.12	07.00	NOKIA: Security requirements on Trusted Environment for Log-data Repository
2023.07.12	07.00	NOKIA: Security Requirements for Log-data Lifecycle Management
2023.07.12	07.00	NOKIA: Security controls for the Y1 interface solution 1
2023.07.12	07.00	NOKIA: Security Requirements for Time stamps in Log-data
2023.07.12	07.00	NOKIA: Security requirements for Authenticated Time Stamping (Sol#5) and (Missing) Common Time Source (Sol#15)
2023.07.12	07.00	NOKIA: Security Requirements for Due Diligence and (Security) Log-Data Auditing (Sol#6)
2023.07.12	07.00	NOKIA: Security requirements for the support of syslog over tls
2023.07.12	07.00	Rakuten Symphony :Remove references to <running> and <candidate> datastores for NACM rules of O1 interface
2023.07.12	07.00	Rakuten Symphony: NACM group O1_software_management of O1 interface is applicable only for PNFs
2023.07.12	07.00	Rakuten Symphony.AO: New security requirements and controls for O-Cloud hardware
2023.07.12	07.00	Rakuten Symphony.AO: New security requirements and controls for O-Cloud Virtualization and Isolation
2023.07.12	07.00	Rakuten Symphony: ETSI PAS Adaption for O-RAN Security Requirement Specification
2023.07.12	07.00	Rakuten Symphony.AO: Rename the Security Requirement Specification document to include Security Controls
2023.07.12	07.00	Rakuten Symphony.AO: ETSI Adaptation and changes for the Near-RT RIC Section in the Security Requirement Specification
2023.07.12	07.00	Rakuten Symphony.AO: ETSI Adaptation and Changes for the Security Requirement Specification_Ocloud
2023.07.12	07.00	Rakuten Symphony: ETSI PAS Adaption for O-RAN Security Requirement Specification_Interfaces maintained by ORAN
2023.07.12	07.00	Rakuten Symphony: ETSI PAS Adaption for O-RAN Security Requirement Specification_Ph3_Section5.3_Transversal Requirements
2023.07.12	07.00	WG11: Update on the requirement REQ-SEC-DOS-1 against O-RAN DoS attacks
2023.07.12	07.00	WG11: Minor updates: VNF/CNF are replaced by Application, some reference have been updated
2023.03.21	06.00	Ericsson: Update format for references to O-RAN documents
2023.03.21	06.00	Ericsson: O-Cloud Management User Authentication and Authorization
2023.03.21	06.00	Ericsson: SMO Security Requirements and Security Controls
2023.03.21	06.00	Orange: New security requirements on AAL components
2023.03.21	06.00	Orange: New security requirements on security descriptor
2023.03.21	06.00	Qualcomm Incorporated: Security requirements and controls for O-CU-CP/UP, O-DU, O-RU and O-eNB
2023.03.21	06.00	Orange: New security requirements on AAL interfaces
2023.03.21	06.00	MITRE: New security requirements on secure update for apps/VNFs/CNF
2023.03.21	06.00	Orange: New security requirements on the protection of O2 interface and O-Cloud notification APIs
2023.03.21	06.00	MITRE: Update SBOM requirements from AppLCMSec TR recommendation
2022.11.10	05.00	Tbd.
2022.07.20	04.00	Added/updated requirements and controls for: O-Cloud Image Security Non-RT RIC, rApps, and A1 and R1 Interfaces Near-RT RIC
2022.03.23	03.00	Added/updated requirements and controls for: Near-RT RIC and xApps Open Fronthaul Interface - C, S and U Planes Open Fronthaul Point-to-Point LAN Segment

2021.11.09	02.00	Added requirements for Open Fronthaul Point-to-Point LAN Segment SBOM Network Protocols and Services Robustness of Common Transport Protocols Robustness against Volumetric DDoS Attack Robustness of OS and Applications Password-Based Authentication
2021.07.01	01.00	Final initial version 01.00